



Ain Shams University
Faculty of Engineering
Computer Engineernig and Software Systems

CFI - Care: Collaborative Flow of Intelligence for Care

Graduation Project Thesis

Author: Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Wagdy 21P0124
Salma Mohamed Yousef 21P0148
Belal Anas Awad 21P0072
Supervisors: Prof Dr Haitham Azmi

Submission Date: 27 January, 2026

Mohamed Salah Fathy 21P0117
Youssef Tamer Hossam 21P0138
Salma Hisham Wagdy 21P0124
Salma Mohamed Yousef 21P0148
Belal Anas Awad 21P0072
Date: 27 January, 2026

Contents

Acknowledgments	XIII
1 Introduction	1
1.1 The Global Digital Health Revolution	1
1.2 The Situation in Egypt	1
1.3 Problem Statement	1
1.4 The Proposed Solution: CFI Care	2
1.5 Thesis Objectives	2
1.6 Thesis Structure	3
2 Literature Review	4
2.1 Background and Context	4
2.1.1 State of Health Data in Egypt	4
2.1.2 Challenges to Implementation	4
2.2 Theoretical Framework	5
2.2.1 Patient-Centricity in Healthcare	5
2.2.2 Data Governance and Interoperability	5
2.2.3 Security: Role-Based Access Control	5
2.2.4 Artificial Intelligence: Retrieval-Augmented Generation	5
2.2.5 Version Control for Health Records	5
2.3 HL7 - Health Level Seven	5
2.3.1 Evolution of Standards	6
2.4 Fast Healthcare Interoperability Resources (FHIR)	6
2.4.1 Core Architecture	7
2.4.2 Key Technical Advantages	7
2.4.3 Comparison of Standards	7
2.5 Authentication and Authorization Standards	9
2.5.1 Open Authorization (OAuth) 2.1 and OpenID Connect (OIDC)	9
2.5.2 JSON Web Tokens (JSON Web Token (JWT))	9
2.5.3 Proof Key for Code Exchange (PKCE)	9
2.6 Healthcare Security and Integration Standards	9
2.6.1 Fast Healthcare Interoperability Resources (FHIR) and Substitutable Medical Applications and Reusable Technology (SMART) on FHIR	9
2.7 Token-Based Architecture and Session Management	10
2.7.1 The Backend-for-Frontend (BFF) Pattern	10
2.7.2 Distributed Session State Cache	10
2.8 Edge Security and Infrastructure Defense	10

2.8.1	Perimeter Protection and Rate Limiting	10
2.8.2	Mobile Application Isolation	10
2.9	Audit Logging, Diagnostics, and Forensic Compliance	10
2.9.1	Security Event Auditing	10
3	Proposed Design Architecture	12
3.1	Backend	12
3.1.1	System Architecture	12
3.1.2	High-Level Architecture	12
3.1.3	Node.js Application Server	13
3.1.4	Data Persistence and Schema	14
3.1.5	Request/Response Flow and Data Transformation Pipeline . . .	16
3.1.6	Error Handling and Fault Tolerance	20
3.1.7	Security and Infrastructure Layer	21
3.1.8	HAPI FHIR Server Implementation	21
3.2	API Design and Endpoints	22
3.2.1	RESTful Structure and Formats	22
3.2.2	FHIR-Compliant Endpoints	22
3.2.3	Custom History Graph Endpoints	22
3.3	Patient History Graph Implementation	23
3.3.1	Motivation: Beyond Linear Medical Records	23
3.3.2	Graph Data Model	24
3.3.3	Temporal Branching and Concurrent Episodes	25
3.3.4	Relationship Classification	26
3.3.5	Handling Edge Cases	27
3.3.6	Query Patterns and Optimization	27
3.4	Performance Optimization	28
3.4.1	Tier 1: Standard Resource Cache	29
3.4.2	Tier 2: Specialized Graph Cache	30
3.5	Frontend	33
3.5.1	Overview and Design Objectives	33
3.5.2	Technology Stack	34
3.5.3	System Architecture	34
3.5.4	Styling and UX Philosophy	35
3.5.5	Authentication and Navigation Shell	37
3.5.6	Patients Dashboard	40
3.5.7	Patient Journey Dashboard	44
3.5.8	Patient Journey Dashboard — Categorical View	46
3.5.9	Patient Journey Dashboard — Chronological View	48
3.5.10	Complementary Roles of the Two Views	51
3.5.11	Interactive Tutorial System	51
3.5.12	AI-Assisted Clinical Chat	53
3.5.13	Doctor Profile and Schedule Management	56
3.5.14	Domain Models and State Services	57
3.5.15	Error Handling and Resilience	58
3.5.16	Sequence Diagram	58
3.5.17	Component Diagram	60

3.5.18	Data Flow Diagram	60
3.5.19	Architectural Rationale	62
3.5.20	Graph Logic Test Suite	62
3.5.21	Summary	64
3.5.22	Mobile	65
4	Security	107
4.1	Introduction	107
4.2	Architecture Overview	107
4.3	Identity and Lifecycle Management	109
4.3.1	Keycloak Configuration and Clients	109
4.3.2	User Registration and Resource Provisioning	109
4.3.3	Custom Security Extensions (SPIs)	110
4.3.4	Persistence Layer	111
4.4	Authentication Framework	111
4.4.1	Web Browser Authentication	111
4.4.2	Mobile Authentication	112
4.4.3	Session Management and Revocation	114
4.5	Authorization and Policy Enforcement	115
4.5.1	BFF Middleware Pipeline	115
4.5.2	Capability-Based Access Control (CBAC)	116
4.5.3	The Just in Time (JIT) Consent Handshake Protocol	116
4.5.4	API Specification and Control Endpoints	117
4.5.5	Dynamic JIT Consent & Capability-Based Access Lifecycle	120
4.5.6	State Management and Auditing	124
4.6	Operational Hardening and Infrastructure	125
4.6.1	Perimeter Firewall and System Access Plan	125
4.6.2	Infrastructure Security and Gateway Configuration	126
4.6.3	Application Layer Hardening	127
4.6.4	Secrets Management	127
4.6.5	Audit Logging and Observability	128
4.6.6	Container and Network Isolation	130
4.6.7	Mitigated Risks Analysis	130
4.7	Challenges and Security Analysis	130
4.7.1	Architectural Challenges	130
4.7.2	Threat Model and Residual Risks	132
4.7.3	Gaps and Future Work	132
4.8	Summary and Conclusion	133
5	AI System	135
5.1	Problem Definition & Clinical Motivation	135
5.1.1	Clinical Workflow Breakdown	135
5.1.2	Failure Modes of Current Systems	135
5.1.3	Safety-Critical Nature of the Problem	136
5.2	System Objectives & Design Principles	136
5.2.1	Functional Objectives	136
5.2.2	Non-Functional Objectives (Architectural Principles)	137

5.2.3	Explicit Non-Goals	137
5.3	Related Work & Gap Analysis	137
5.3.1	Traditional Clinical Decision Support Systems	138
5.3.2	LLMs in Healthcare	138
5.3.3	RAG in High-Risk Domains	138
5.3.4	Gap Statement	139
5.4	System Architecture	139
5.4.1	High-Level Architecture Overview	139
5.4.2	Data Ingestion & Normalization (TOON)	139
5.4.3	Retrieval Layer Design	140
5.5	Medical Document Digitization: OCR and Layout Analysis	140
5.5.1	System Architecture and Inference Backend	140
5.5.2	OCR Processing Pipeline	141
5.6	Markdown to FHIR: LLM-Powered Data Mapper	142
5.6.1	Mapper Architecture and Workflow	143
5.6.2	Prompt Engineering and Extraction Strategy	143
5.6.3	Data Validation and Schema Enforcement	144
5.6.4	OCR-Mapper Pipeline Verification	144
5.6.5	Generation, Reasoning & Agentic Workflow	145
5.6.6	Architectural Diagrams	146
5.6.7	Evidence Grounding & Citation Enforcement	148
5.7	Use Cases & Clinical Scenarios	148
5.7.1	Clinical Synthesis and Retrieval-Augmented Generation	148
5.7.2	Diagnostic Evolution and Differential Reasoning	149
5.7.3	External Knowledge Retrieval via MedMCP	150
5.8	Evaluation & Benchmarks	150
5.8.1	Evaluation Dataset & Methodology	151
5.8.2	Component-Level Evaluation	151
5.8.3	Summary of Evaluation Findings	152
5.9	Performance, Scalability & Deployment	152
5.9.1	Hardware & Infrastructure	152
5.9.2	Latency & Throughput	153
5.9.3	Cost & Scalability	154
5.10	Limitations & Open Challenges	154
5.10.1	Technical Constraints	154
5.10.2	Clinical and Operational Hurdles	154
5.11	Value Proposition & Impact	155
5.11.1	Clinical Efficiency and Burnout Mitigation	155
5.11.2	Organizational and Operational Impact	155
6	Testing and Verification	156
6.1	Backend Testing Overview	156
6.1.1	Execution Environment	156
6.1.2	Scope	156
6.1.3	API Route Coverage	156
6.1.4	Service and Integration Tests	157
6.1.5	Test Design and Data	157

6.1.6	End-to-End Workflows	157
6.1.7	Validation and Middleware	157
6.1.8	Caching and Redis	158
6.1.9	Database Checks	158
6.1.10	Gaps and Next Steps	158
6.1.11	Test Result Summary	158
6.1.12	Interpretation of Results	159
6.2	Mobile App Testing	159
6.2.1	Unit Testing	159
6.2.2	Widget Testing	159
6.2.3	Integration Testing	160
6.2.4	Testing Architecture and Tools	160
6.2.5	Unit Testing Implementation	161
7	Conclusion and Future Work	163
7.1	Conclusion	163
7.2	Future Work	163
7.2.1	System Security	163
7.2.2	Mobile	164
	Appendix	166
A	Lists	167
	List of Abbreviations	167
	References	169

List of Figures

2.1	Evolution of HL7 Standards from Messaging to RESTful Resources. . .	6
2.2	Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.	8
3.1	High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.	13
3.2	Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.	14
3.3	Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table.	15
3.4	Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.	17
3.5	Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade.	19
3.6	Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.	24
3.7	Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).	28
3.8	Registration form enforcing field completeness. The form cannot be submitted until all required fields are populated, preventing incomplete account creation.	37
3.9	Email verification step requiring entry of a six-digit code sent to the clinician's registered address, confirming ownership before account activation.	38
3.10	Recovery code generation screen presented at account activation. The clinician must copy or download the codes as a text file before proceeding, establishing a secure fallback authentication method.	38
3.11	Multi-factor authentication method selection screen, offering the clinician a choice between a TOTP authenticator application and a recovery authentication code.	39
3.12	Password reset interface allowing clinicians to securely regain access to their account through a guided credential recovery flow.	39
3.13	Patients Dashboard showing the master-detail layout. The left sidebar presents the patient navigator with search, filter, and episode management controls. The main panel displays the full clinical summary for the selected patient, including active conditions, medications, recent laboratory results, procedures, and a scoped encounter history.	40

3.14	Patient access grant modal presenting the six-cell OTP input field. The clinician enters the code generated on the patient’s device to initiate the access request handshake.	42
3.15	Categorical Patient Journey view representing medical events as a hierarchical left-to-right graph. High-priority events display animated priority rings, sibling relationships are labelled on each node, and the detail sidebar is visible on the right.	47
3.16	Chronological Patient Journey view displaying medical events along a horizontal D3.js timeline with pan and zoom. Parallel sub-branches represent alternative diagnostic hypotheses, each on its own horizontal track. The completed branch is merged back into the main timeline via a green arc, and the discontinued branch is blocked with a red wall marker. A “CASE CLOSED” flag is rendered at the timeline terminus when the main timeline is set to the Finished state.	50
3.17	Zoomed view of a completed branch in the chronological timeline. The green curved merge arc connects the branch’s final node back to the main timeline, with a “MERGED” label rendered above the arc. The branch line is rendered in green to indicate the validated state.	50
3.18	Zoomed view of a discontinued branch in the chronological timeline. A pulsing red wall marker is rendered at the branch terminus with a “DISCONTINUED” label. The branch line is rendered in red, and all add, edit, and delete operations on nodes within this branch are blocked. . .	50
3.19	Tutorial Step 4 of 18: Expand a branch. The categorical view shows first-level nodes in their collapsed default state. The + button on the CBC Blood Test node is highlighted with a pulse animation, and the tutorial card instructs the clinician to click it to expand the sub-tree. The step advances automatically upon interaction.	52
3.20	Tutorial Step 10 of 18: Switch to Chronological view. The view toggle in the header is highlighted, and the tutorial card instructs the clinician to click “Chronological” to transition the layout from the hierarchical tree to the D3.js timeline. The step advances automatically once the toggle is activated.	53
3.21	Tutorial Step 16 of 18: Main timeline state. The chronological view is shown with the branch state menu open on the main timeline line, presenting the In Progress and Finish Case options. The tutorial card instructs the clinician to click the main timeline to open this menu, advancing automatically once the interaction occurs.	53
3.22	AI-assisted clinical chat in its compact panel view, rendered alongside the Patient Journey Dashboard. The session list, message history, response mode selector, and composer are all visible within the panel.	55
3.23	AI-assisted clinical chat in maximised mode, expanding to fill the full viewport. This mode is intended for extended clinical reasoning sessions and is also the default view for conversations opened via the Fork action.	56
3.24	Doctor Profile page showing the practitioner information panel on the left and the Schedule Manager on the right, with slot creation form, status filters, and a today’s summary sidebar.	57

3.25	Sequence diagram illustrating the full MedGraph interaction lifecycle: iframe initialisation, postMessage-based node operations, backend confirmation, optimistic rollback on failure, and stateful mode switching. . .	59
3.26	Component diagram illustrating the architecture of the dashboard, MedGraph iframe boundary, AI chat module, application services, and backend integration points.	60
3.27	Data flow diagram for a MedGraph node CRUD operation. The flow begins with a user interaction in the graph engine (iframe), passes through the postMessage boundary into the Angular host, is forwarded to the FHIR backend, and returns via a confirmation or error path. On success, the temporary node ID is replaced with the persistent UUID. On failure, the pending operation is rolled back from the corresponding state map.	61
3.28	CFI-Care Graph Logic Test Suite dashboard after a full run. All 62 tests across five suites pass with zero failures and zero warnings in 22ms total. The scoreboard, per-suite result panels, performance bar chart, and log console are visible.	64
3.29	Login with KeyCloak	65
3.30	Register with KeyCloak	66
3.31	Verification Code	67
3.32	Recovery Codes	68
3.33	Enter Recovery Code #1	68
3.34	Authenticator Setup	69
3.35	Unauthenticated Reset Password	70
3.36	Verify your Identity	71
3.37	Enter & Confirm New Password	72
3.38	Episode of Care	72
3.39	Documents Screen	74
3.40	Add Document Form	75
3.41	trapezoid-shaped Image	77
3.42	Green Spirit Level because parallel to the surface	77
3.43	Red Spirit Level because tilted to the surface	78
3.44	Text Extraction Failed	79
3.45	OCR processing	79
3.46	Text Extract successfully and synced with backend	80
3.47	Notification with doctor requesting access to your data	81
3.48	Doctor appearing in Doctors that can access your data list and user can revoke access	82
3.49	Patient Generating Code	83
3.50	Caregiver entering Patient's code	83
3.51	Caregiver request access (Patient view)	84
3.52	Caregiver is notified and their list updates	84
3.53	Patient sees Caregiver in their family accessors list and ability to revoke access	85
3.54	Caregiver updating Patient data	86
3.55	Patient receiving notification that Caregiver updated Patient data . . .	86
3.56	Patient update their own data	87
3.57	Caregiver receiving notification that Patient updated their own data . .	87

3.58	List of doctor specialities	88
3.59	List of doctors with the speciality chosen (in this case Dermatology) . .	89
3.60	Doctor Profile with slots available	90
3.61	Thank You Screen	91
3.62	Health_Connect Diagram	92
3.63	Granular Permissions	93
3.64	Data Sources & Priority	94
3.65	Health_Connect with GalaxyWatch & AndroidSmartphone	95
3.66	OMRON Connect requesting to read & write Samsung Health data . .	96
3.67	Withings requesting access to Health Connect	97
3.68	Layered Clean Architecture adopted in the mobile application	98
3.69	Using handlePermission for Camera Access in code	100
3.70	Best Practices for Handling Permissions in Flutter	101
3.71	Dialog to allow the app to access the camera	102
4.1	Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (Nginx, OAuth2 proxy), Backend-for-Frontend (Node.js), Identity (Keycloak), Storage (Redis, Postgres), and Resource Server (HAPI FHIR).	108
4.2	Registration Provisioning Sequence: Event-driven synchronization between Keycloak and the FHIR Resource Server.	110
4.3	Browser Authentication Sequence: Gateway-mediated OIDC flow and session cookie management.	111
4.4	Browser Authentication Sequence: Browser Operational Lifecycle and Revocation.	112
4.5	Mobile Authentication Flow: Native AppAuth integration and secure token persistence.	113
4.6	Mobile Authentication Flow: Mobile Operational Lifecycle and Revocation	113
4.7	Token Flow Overview: Unified management of browser and mobile session lifecycles.	115
4.8	Consent Grants issuance logic state diagram	119
4.9	Consent Lifecycle Part 1: Patient granting access to a practitioner. . .	121
4.10	Consent Lifecycle Part 2: Practitioner accessing authorized patient data.	122
4.11	Consent Lifecycle Part 3: Patient verifying their own data access. . . .	122
4.12	Consent Lifecycle Part 4: Patient-initiated revocation of access.	123
4.13	Caregiver consent and JIT grant lifecycle (patient issues a transient grant to a caregiver)	124
4.14	System Access diagram	126
4.15	OPNsense Perimeter Administration Interface: Active validation environment mapping network interface distribution, load profiles, and system operational states.	126
4.16	Vault architecture diagram	128
4.17	Grafana Security Dashboard mapping runtime volumetric authorization metrics, credential access violations, and structural log alerts.	129
4.18	Structured security log streams containing granular authorization events, runtime timestamps, and user identifiers.	129

5.1	OCR to HL7 FHIR Transformation Architecture	142
5.2	High-Level System Architecture. The flow connects the Streamlit UI to the FastAPI backend, which orchestrates the LangGraph agent. The agent routes between the RAG pipeline (Ingestion → Qdrant → MedGemma) and the External MCP Tools (eg. PubMed Access) based on query classification.	146
5.3	TOON Ingestion Pipeline. Raw FHIR JSON resources are processed by the <code>ToonNormalizer</code> , extracting semantic value and temporal metadata to create token-optimized strings before vector embedding by <code>ModernPubMedBERT</code>	147
5.4	LangGraph Reasoning State Machine. The decision logic for the agent, illustrating the bifurcation between <code>LocalRAG</code> (Patient Specific) and <code>MCPSearch</code> (General Knowledge) paths, converging at the grounded generation node.	148
5.5	AI-generated longitudinal patient summary utilizing RAG to synthesize data from 10 distinct clinical encounters.	149
5.6	Diagnostic reasoning workflow showing the transition from initial clinical impressions to a final confirmed diagnosis based on patient progression.	150
5.7	Interface of the MedMCP system demonstrating a RAG (Retrieval-Augmented Generation) response. The output includes synthesized clinical guidelines supported by specific evidence sources and PMIDs.	150
6.1	Graph view of the two end-to-end suites; edges align to assertions within each test.	157
6.2	Number of Test Cases and its status.	158
6.3	Unit, integration and End-to-end workflow suite status.	159

Acknowledgments

We would like to extend our deepest gratitude to our esteemed supervisor, Prof Dr. Haitham Azmi, whose guidance, support, and invaluable insights have been instrumental in the successful completion of our senior project. His unwavering dedication and expertise have enhanced our understanding of the complexities involved in building an AI-Powered, Patient-Centric Healthcare Platform. Prof Dr. Azmi provided us with the intellectual stimulation and encouragement necessary to navigate the challenges we encountered throughout this research. His constructive feedback and meticulous mindfulness have significantly improved the quality of our work.

We are also grateful to Ain Shams University (ASU) for providing us with the resources and environment necessary to pursue this project. Special thanks to the Faculty of Engineering and the Computer and Systems Engineering Department for their continuous support and encouragement throughout our academic journey.

We would like to acknowledge the contributions of our colleagues and friends who provided valuable feedback and assistance during the development of this project. Their support and collaboration have been invaluable in overcoming technical challenges and refining the final product.

Abstract

Healthcare today is characterized by fragmented experiences where patient medical information is often dispersed across various institutions and providers. This project proposes a comprehensive, patient-centric healthcare application designed to consolidate all medical reports into a single, secure, and unified platform. The system employs Role-Based Access Control (RBAC) to ensure privacy and controlled information sharing. To enhance clinical decision-making, the platform features a medical history visualization graph for tracking health trends and integrates a Retrieval-Augmented Generation (RAG)-enabled AI model to generate diagnostic reports and insights. By transforming isolated data into an interconnected ecosystem, this project aims to establish meaningful relationships between patients, caregivers, and doctors for personalized healthcare delivery.

Chapter 1

Introduction

1.1 The Global Digital Health Revolution

Healthcare is shifting from reactive treatment toward proactive, data-driven prevention. The global digital health market was valued at roughly USD 288 billion in 2024 and is projected to approach USD 946 billion by 2030, growing at more than 22% annually. This acceleration is powered by mobile health, telemedicine, and Artificial Intelligence (AI), which promise cheaper, faster, and more effective care. Yet adoption is uneven: while leading systems deploy AI for personalized care, many Low- and Middle-Income Countries (LMICs) still struggle with basic record keeping because of weak infrastructure, unclear policy, and fragmented data.

1.2 The Situation in Egypt

Egypt, home to over 106 million people and the largest healthcare market in MENA, has improved outcomes but faces a persistent data void. Records in many Public Health Centers (PHCs) remain paper-based, locked in filing rooms, and rarely interoperable across facilities. Digital systems that do exist often operate in silos, so a patient moving between providers loses continuity of care. Data quality is frequently incomplete or error-prone, and patients seldom provide formal written consent, reflecting limited trust and awareness of data value. This fragmentation prevents AI from learning accurate patterns and delivering benefits to Egyptian patients.

1.3 Problem Statement

When a patient sees multiple specialists, their medical records scatter across disconnected systems. Radiology images sit at one hospital, lab results at another, prescriptions at a third. Clinicians piece together incomplete histories from memory or phone calls. Patients have no way to track their own health trends over time. Care coordination breaks down because nobody has the full picture. Egypt needs modern, AI-enabled healthcare but lacks the foundational data ecosystem. The core challenges are:

- **Fragmentation:** Records scattered across clinics with no single longitudinal home.
- **Analog Dominance:** Paper-first workflows impede longitudinal tracking and lossless sharing.
- **Lack of Control:** Patients cannot easily access or share their own histories.
- **Privacy and Consent Gaps:** No standardized, auditable consent flows.
- **Missed AI Opportunities:** Absent or inaccessible digital data blocks safe clinical decision support such as Retrieval-Augmented Generation (RAG).

1.4 The Proposed Solution: CFI Care

CFI Care is an AI-powered, collaborative, patient-centric health record platform that unifies medical reports in one secure ecosystem while keeping patients in control.

- **Unified Records:** Consolidates data from disparate sources into a single, secure repository with timeline visualization.
- **Git-Inspired Version Control:** Tracks evolving treatment plans as a medical history graph to reveal branches, merges, and longitudinal trends.
- **Role-Based Access Control (RBAC):** Lets patients grant time-bound, role-specific access to clinicians or caregivers, creating a clear consent audit trail.
- **AI Integration (RAG):** Grounds generative summaries and answers in the patient's own records to support safer diagnostics and triage.
- **Mobile Digitization:** A camera scanner digitizes legacy paper reports, crowd-sourcing data ingestion despite PHC device constraints.

1.5 Thesis Objectives

This thesis aims to design and develop CFI Care to modernize health data management in Egypt by:

- Documenting digital health barriers in Egypt, including infrastructure gaps and consent practices.
- Designing a secure, scalable, and usable architecture for patient-centric records and clinician workflows.
- Implementing robust RBAC and consent enforcement to safeguard privacy while enabling necessary sharing.
- Engineering AI (RAG) services that can interpret medical records and deliver actionable insights.
- Empowering patients with tools for data ownership, appointments, caregiver sharing, and mobile digitization.

1.6 Thesis Structure

- Chapter 1: Introduction to the global digital health revolution, Egypt's healthcare challenges, and the CFI Care solution.
- Chapter 2: Standards (HL7/FHIR), governance, authentication, and security foundations.
- Chapter 3: CFI Care system architecture including backend, frontend, and mobile components.
- Chapter 4: Defense-in-depth security architecture with OAuth 2.0, JWT Tokens, RBAC, Rate Limiting on API endpoints, and audit logging.
- Chapter 5: AI integration using Retrieval-Augmented Generation for clinical decision support.
- Chapter 6: Testing methodology, implementation milestones, and validation.
- Chapter 7: Conclusion, expected impact, and future enhancements.

Chapter 2

Literature Review

2.1 Background and Context

2.1.1 State of Health Data in Egypt

Egypt’s largest-in-MENA healthcare market still operates with a persistent data void. Many Public Health Centers (PHCs) rely on paper records stored in locked rooms, producing data silos that cannot be queried or shared across providers. Even when digital systems exist, they often function in isolation, so patients effectively lose their history when moving between facilities. Data quality is frequently incomplete, error-prone, and difficult to audit, and formal written consent is rarely collected, reflecting limited trust and awareness of data value. These factors prevent AI systems from learning reliable patterns and delivering safe support to clinicians.

2.1.2 Challenges to Implementation

Key barriers identified in the Egyptian context include infrastructure limits, low digital literacy among frontline workers, organizational fragmentation, constrained funding, and cultural hesitancy around data sharing. Table 2.1 summarizes these obstacles.

Table 2.1: Implementation Barriers in Egypt’s Health Data Landscape

Barrier	Description
Infrastructure	Limited connectivity and device availability in PHCs.
Digital literacy	Nurses and clerks often lack training on digital tools.
Fragmentation	Providers operate in silos and resist data sharing.
Funding	Budgets for devices and training are inadequate.
Culture and trust	Patients may hesitate to share data or perceive little value in doing so.

2.2 Theoretical Framework

2.2.1 Patient-Centricity in Healthcare

Traditional institution-centric models keep data under provider control. A patient-centric approach shifts ownership to patients, ensuring portability and empowerment. When patients upload documents, manage appointments, and share records, adherence and outcomes improve.

2.2.2 Data Governance and Interoperability

High-quality, ethical data use depends on governance principles that prioritize protection, value, and equity. Interoperability—particularly via FHIR—enables systems to exchange and reuse structured health information, avoiding vendor lock-in and enabling national-scale insights.

2.2.3 Security: Role-Based Access Control

Role-Based Access Control (RBAC) restricts access by clearly defined roles. Patients can grant time-bound access to doctors or caregivers, creating auditable consent and aligning with privacy requirements.

2.2.4 Artificial Intelligence: Retrieval-Augmented Generation

Retrieval-Augmented Generation (RAG) grounds AI outputs in a patient’s actual records. By retrieving relevant documents before generation, it reduces hallucinations and offers safer clinical decision support for summarization and question answering.

2.2.5 Version Control for Health Records

A Git-inspired model captures branching and merging in treatment histories, forming a medical history graph. This temporal view helps clinicians understand forks in care plans, compare outcomes, and track longitudinal trends.

2.3 HL7 - Health Level Seven

Health Level Seven (HL7) International is a standards development organization that has defined the framework for the exchange, integration, sharing, and retrieval of electronic health information for decades [2]. Understanding the evolution of these standards is crucial to appreciating the architectural shifts in modern healthcare applications.

2.3.1 Evolution of Standards

- **HL7 v2 (The Workhorse):** Established in 1989, HL7 v2 remains the most widely implemented standard for hospital workflows (e.g., ADT - Admission, Discharge, Transfer messages). It utilizes a non-XML, pipe-delimited syntax (e.g., MSH|^~\&|...). While highly efficient for legacy backend systems, its lack of semantic strictness leads to significant implementation variances, posing challenges for modern web and mobile application development [2].
- **HL7 v3 (The Theoretical Model):** Introduced in the 1990s to address the vagueness of v2, HL7 v3 was built on a rigorous Reference Information Model (RIM). It enforced strict semantic correctness using complex XML structures. However, this theoretical purity resulted in a steep learning curve and bloated message sizes, leading to poor adoption rates and a lack of backward compatibility with v2 [2].
- **HL7 CDA (Clinical Document Architecture):** A component of v3, CDA focuses on the exchange of clinical documents (such as discharge summaries). While effective for static snapshots of care, it is document-centric rather than data-centric, making it difficult to extract granular data (like a single heart rate reading) required for real-time interactive applications [4].

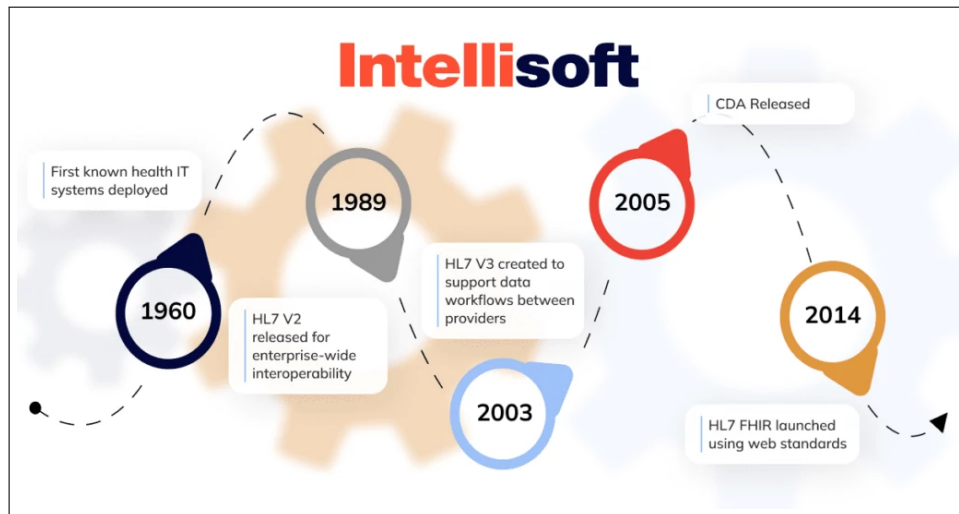


Figure 2.1: Evolution of HL7 Standards from Messaging to RESTful Resources.

2.4 Fast Healthcare Interoperability Resources (FHIR)

In response to the complexity of HL7 v3 and the limitations of v2, HL7 introduced **FHIR** (Fast Healthcare Interoperability Resources) in 2012. FHIR represents a paradigm shift from complex, custom healthcare protocols to modern web standards.

2.4.1 Core Architecture

Unlike its predecessors, FHIR is built on the RESTful API approach widely used in modern IT industries (e.g., by Google, Facebook, Twitter). It treats data elements as independent "Resources"—modular components like *Patient*, *Observation*, or *Medication*—that can be accessed and manipulated via standard HTTP methods (GET, POST, PUT, DELETE) [4].

2.4.2 Key Technical Advantages

- **Granularity via Resources:** FHIR allows systems to access specific data elements using unique URLs (e.g., `GET /Patient/123`), rather than exchanging entire heavy documents. This makes it ideal for mobile devices with limited bandwidth [4].
- **Modern Formats (JSON & XML):** While previous standards relied on complex XML or pipe-delimited text, FHIR natively supports JSON (JavaScript Object Notation), which is lightweight and directly parsable by web browsers and mobile apps [2].
- **The 80/20 Rule:** FHIR focuses on defining the 20% of requirements that satisfy 80% of common healthcare use cases. For the remaining complex or local requirements, it uses a built-in extension mechanism, ensuring the core standard remains simple and implementable [3].

2.4.3 Comparison of Standards

Table 2.2 highlights the fundamental differences between the major HL7 standards, illustrating why FHIR was chosen as the interoperability backbone for this project.

Table 2.2: Comparison of HL7 v2, v3, CDA, and FHIR Standards

Feature	HL7 v2	HL7 v3 / CDA	FHIR
Primary Paradigm	Event-Driven Messaging	Reference Model (RIM) / Documents	RESTful API & Resources
Data Format	Pipe-delimited text	Complex XML	JSON, XML, RDF
Transport	LLP / MLLP (TCP/IP)	SOAP / Web Services	HTTP / REST
Complexity	Moderate (Vague semantics)	High (Steep learning curve)	Low (Web-standard based)
Use Case	Hospital Backend (ADT, Orders)	Clinical Documents (Summaries)	Mobile, Web, Cloud, & Backend

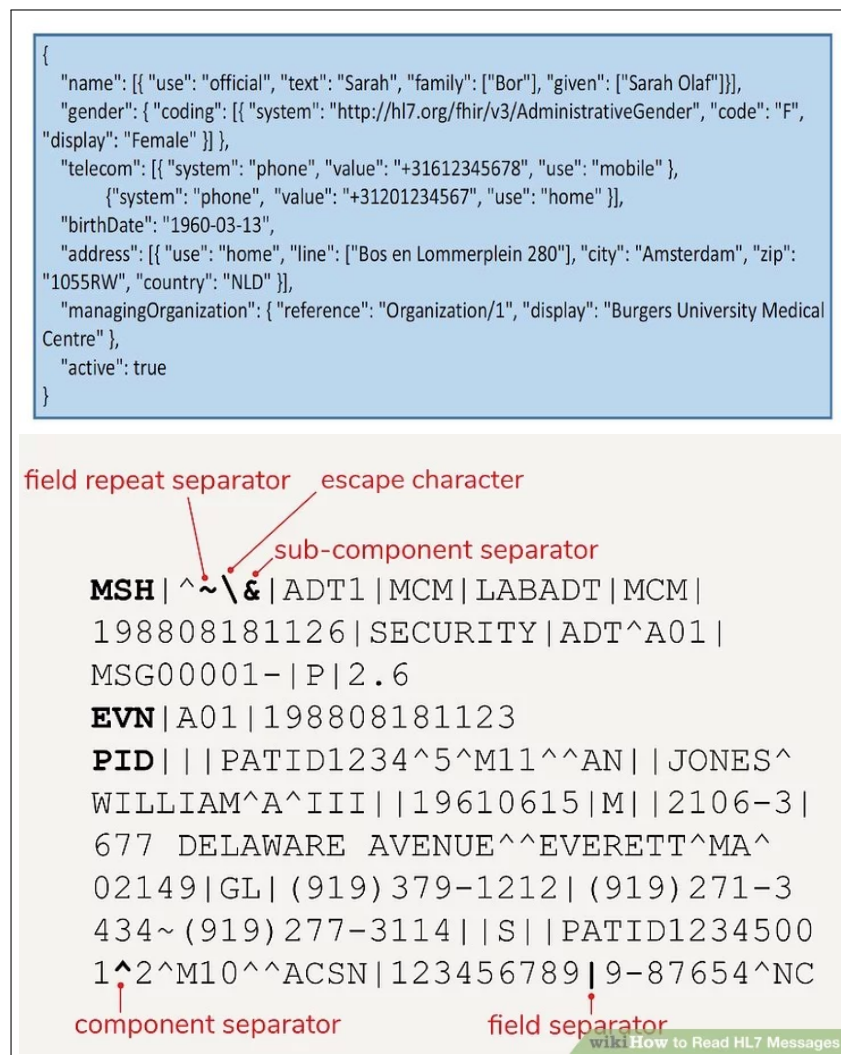


Figure 2.2: Visual Comparison of Data structure: HL7 v2 Message vs. FHIR JSON Resource.

2.5 Authentication and Authorization Standards

2.5.1 OAuth 2.1 and OpenID Connect (OIDC)

Modern web and mobile security paradigms have transitioned toward the OAuth 2.1 consolidation framework, which deprecates inherently insecure vectors -such as the Resource Owner Password Credentials grant- due to the risks associated with client-side credential handling [9]. The standard explicitly mandates the Authorization Code Flow combined with dynamic cryptographic extensions for native applications, and delegates browser session management to secure edge boundaries. OpenID Connect (OIDC) [8] extends this framework by introducing an identity layer via ID tokens, enabling robust Single Sign-On (SSO) capabilities. Within decoupled health architectures, this project leverages gatekeeper abstractions to securely manage token translation scopes out-of-band.

2.5.2 JSON Web Tokens (JWT)

JWTs [11] are cryptographically signed structural tokens that encode user identity claims, access scopes, and session longevity attributes (e.g `iss`, `aud`, `exp`). Utilizing asymmetric signing algorithms (such as RS256) allows distributed microservices and backend API workers to perform stateless signature validation against an Identity Provider's JSON Web Key Sets (JWKS), removing the performance overhead of database lookups.

2.5.3 PKCE

PKCE [15] mitigates authorization code interception attacks on public and native clients by introducing a dynamic cryptographic secret exchange loop. By validating a high-entropy `code_verifier` against a pre-computed `code_challenge`, the protocol ensures that malicious actors tracking custom OS deep links cannot intercept or exchange leaked authorization codes for active token clusters [12].

2.6 Healthcare Security and Integration Standards

2.6.1 FHIR and SMART on FHIR

The FHIR specification [5] provides structural consistency for healthcare models, but relies on external security profiles for transactional protection. The SMART on FHIR framework [7] addresses this by mapping OAuth 2.0 access scopes directly to granular medical resources (e.g `patient/Observation.read`, `user/Condition.write`). This allows patient-controlled capability policies to interoperate seamlessly with standardized FHIR Consent resource models [6], enforcing time-bound, actor-specific boundaries directly over Protected Health Information (PHI).

2.7 Token-Based Architecture and Session Management

2.7.1 The Backend-for-Frontend (BFF) Pattern

To guard web clients against Cross-Site Scripting (XSS) token exfiltration, modern architectures employ the Backend for Frontend (BFF) pattern [13]. By containing OAuth token loops entirely behind an edge gateway, access and refresh tokens are kept out of reach of browser storage layers. The frontend-to-backend connection is secured via encrypted HTTP-only, Secure, and SameSite-restricted session cookies, preventing both script-based extraction and Cross-Site Request Forgery (CSRF) vectors.

2.7.2 Distributed Session State Cache

While stateless JWT tokens simplify transaction execution, immediate security invalidation (e.g during logout) requires backchannel tracking. Utilizing low-latency, in-memory data structures (such as Redis) allows systems to maintain a real-time blacklist or session map, striking a secure balance between stateless processing speed and immediate session revocation capabilities.

2.8 Edge Security and Infrastructure Defense

2.8.1 Perimeter Protection and Rate Limiting

Securing electronic health records requires robust defenses at the ingestion boundary. Reverse proxies and API gateways (such as Nginx) isolate internal application nodes by terminating TLS profiles, dropping non-conforming HTTP payloads, and establishing strict rate-limiting boundaries backed by sliding-window token buckets to block distributed brute-force attempts and Denial of Service (DoS) vectors [25].

2.8.2 Mobile Application Isolation

Native environments require a completely different security profile than web applications. Lacking standard cookie containment scopes, mobile applications mitigate malicious data access by isolating long-lived refresh tokens and active access JWTs inside hardware-backed storage containers, such as the Android Keystore [35], keeping secrets cryptographically secure even if the host operating system is compromised.

2.9 Audit Logging, Diagnostics, and Forensic Compliance

2.9.1 Security Event Auditing

Security tracing requires structured log recording for authentication lifecycles, user state transitions, data access denials, and cryptographic key rotations. To preserve forensic

utility, processing engines must isolate audit trails in real time to automated storage pipelines to prevent accidental downstream data exposure [27].

Chapter 3

Proposed Design Architecture

3.1 Backend

3.1.1 System Architecture

The CFI-Care system is built upon a robust three-tier architecture designed to facilitate secure and interoperable healthcare data management. The system integrates a modern frontend, a logic-heavy middleware layer, and a standards-compliant backend to ensure data consistency and security. The architecture adheres to the FHIR (Fast Healthcare Interoperability Resources) standard for all medical data exchange and utilizes OAuth 2.0 via Keycloak for identity management.

3.1.2 High-Level Architecture

The application operates through a strict separation of concerns. The Presentation Layer is an Angular-based Single Page Application (SPA) that serves as the user interface. It does not communicate directly with the data stores. Instead, all client requests are intercepted by an Nginx Reverse Proxy, which handles SSL/TLS termination and routes traffic to the appropriate internal services.

The core of the backend processing is handled by the Node.js Application Server. This server acts as the primary API gateway, implementing business logic, enforcing security policies, and managing user sessions. It communicates with the HAPI FHIR Server, a specialized Java-based component responsible for persisting clinical data in compliance with the FHIR R5 standard. Data storage is consolidated in PostgreSQL databases, while high-speed data access and session management are handled by Redis instances.

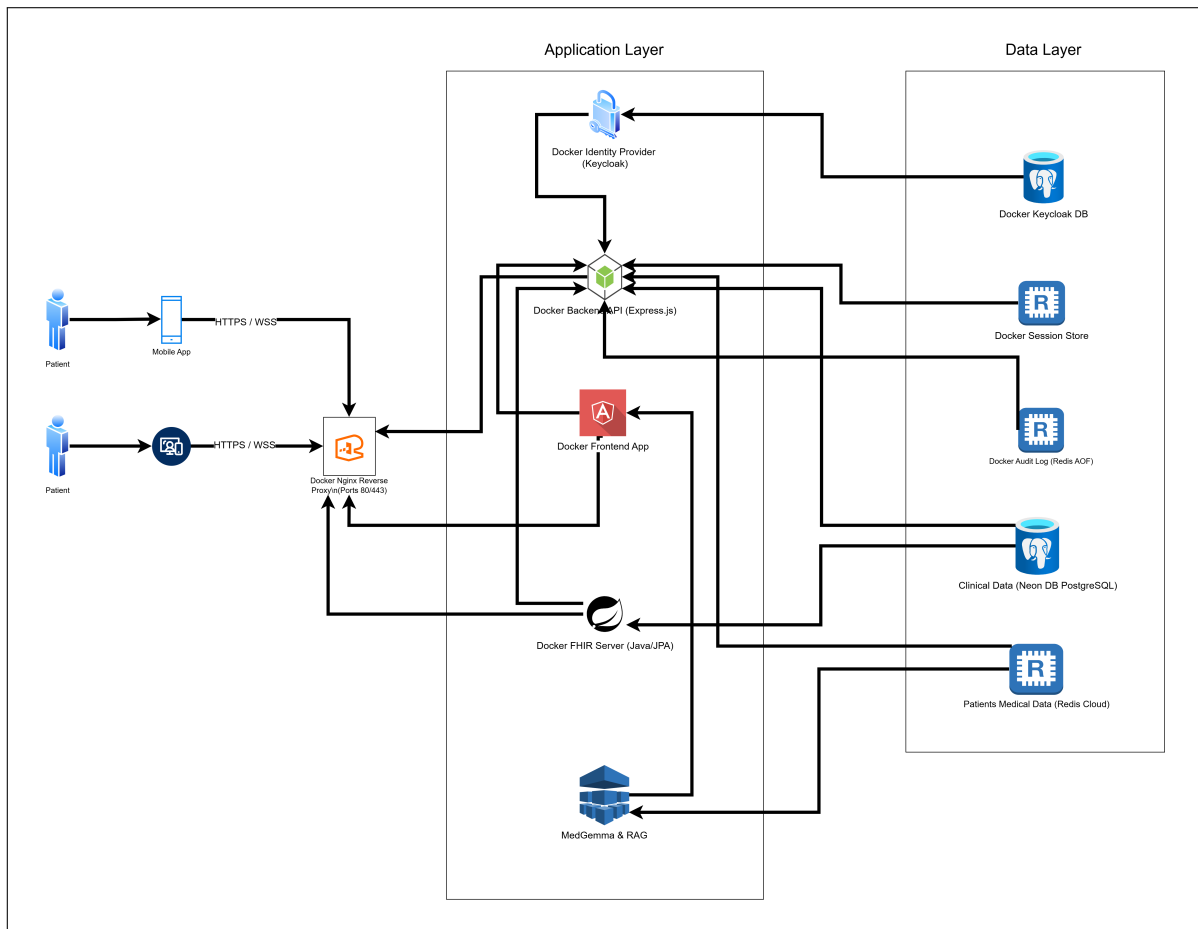


Figure 3.1: High-Level Container Architecture showing the interaction between the Nginx proxy, application services, and data persistence layers.

3.1.3 Node.js Application Server

The Node.js server, built with the Express.js framework, serves as the middleware layer that bridges the gap between the user interface and the standardized medical records. It is designed with a modular layered architecture to ensure scalability and maintainability.

Middleware and Security

Upon receiving a request, the server passes it through a comprehensive middleware stack. Security headers are applied using Helmet to prevent common web vulnerabilities. Cross-Origin Resource Sharing (CORS) is configured to restrict access to authorized domains. Crucially, the server implements rate limiting to protect API endpoints from abuse and utilizes a Redis-backed session store to manage user authentication states efficiently.

Routing and Services

The application is divided into specific route modules corresponding to healthcare domains. Dedicated endpoints manage Patients, Practitioners, Encounters, and Episodes

of Care. A specialized "History Graph" module handles the retrieval and processing of graph visualization data.

Beneath the routing layer lies the service layer, which contains the core business logic. These services act as proxies to the FHIR server, transforming raw FHIR JSON into formats optimized for the frontend, such as the D3.js visualizations. They also handle document processing tasks, such as converting base64 strings to PDF files for binary storage.

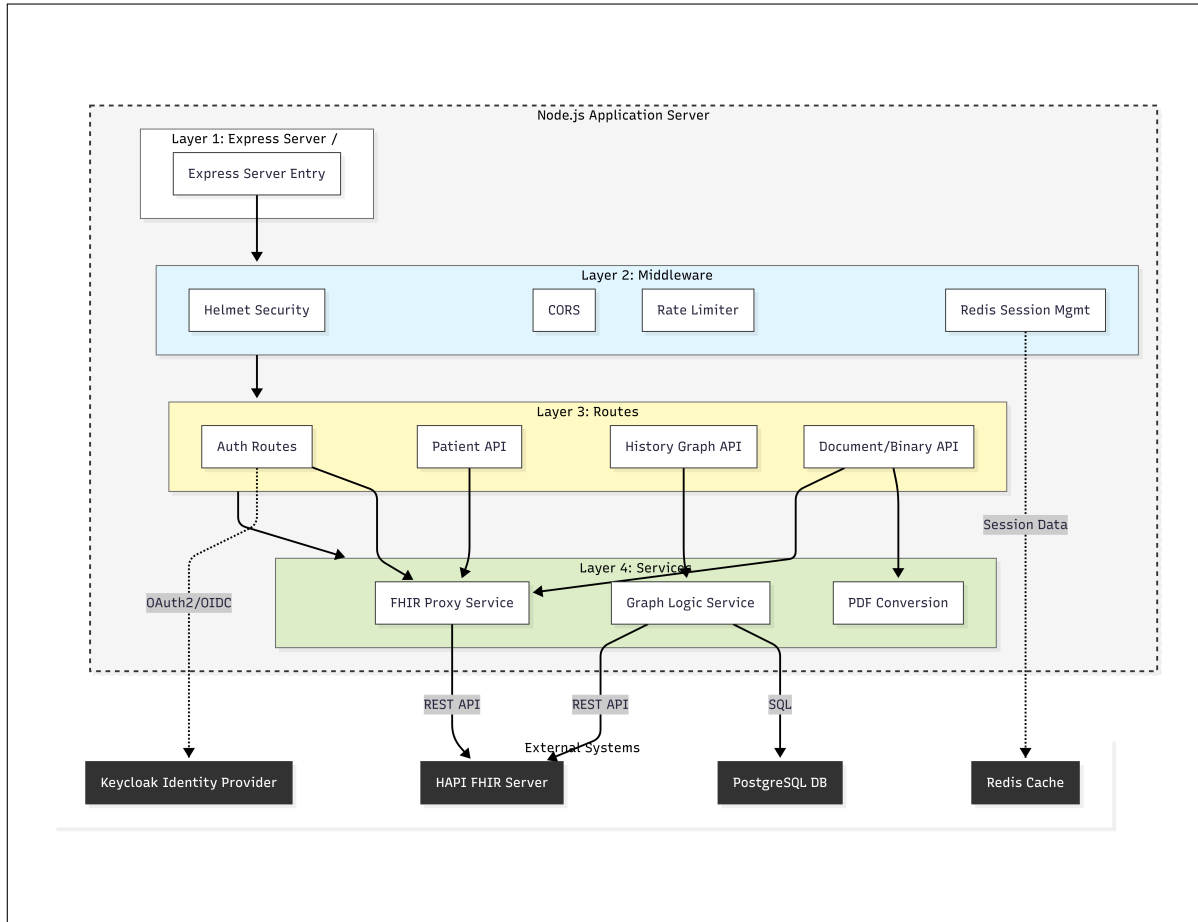


Figure 3.2: Internal layered architecture of the Node.js Application Server, detailing the middleware stack and service distribution.

3.1.4 Data Persistence and Schema

The system utilizes a polyglot persistence strategy, employing different database technologies for specific use cases to maximize performance.

Relational Data

The primary storage engine is PostgreSQL. It is divided into two logical segments. The first segment supports the HAPI FHIR server, storing all standard clinical resources

(like Patients and Observations) in a highly structured format managed by Hibernate. The second segment supports the Keycloak identity provider, storing user credentials and realm configurations.

Custom Graph Schema

To support the unique "Medical History Graph" feature, a custom schema was designed alongside the standard FHIR tables. This schema consists of `encounter_nodes` and `node_relations`. These tables allow the system to map standard FHIR Encounters into a Directed Acyclic Graph (DAG), enabling the visualization of a patient's journey through time with causal links between medical events.

Caching and Auditing

Redis is utilized for ephemeral data storage. One instance is dedicated to storing user sessions, ensuring fast authentication checks. A second Redis instance operates in Append-Only File (AOF) mode to store audit logs, providing a persistent and high-speed trail of system activities.

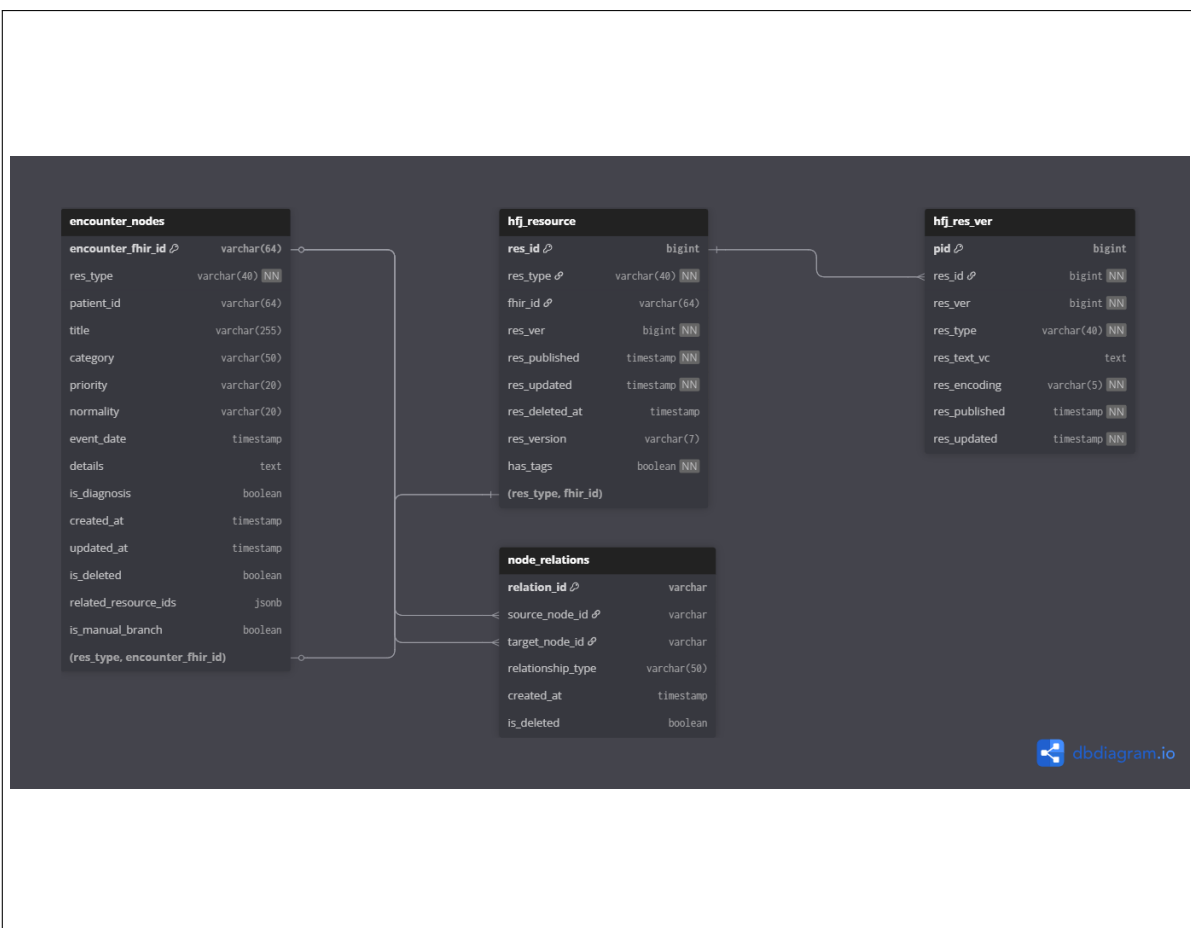


Figure 3.3: Entity-Relationship Diagram (ERD) illustrating the integration of custom graph tables with the standard FHIR resource table.

3.1.5 Request/Response Flow and Data Transformation Pipeline

Understanding how requests traverse the CFI-Care system is essential for comprehending the architecture’s design decisions. A typical request from the frontend follows a well-defined path through multiple layers, each contributing specific functionality: authentication verification, input validation, business logic execution, data transformation, and response formatting.

Request Ingress and Authentication

A request originates from the Angular frontend as an HTTPS request, typically including a Bearer token in the Authorization header. The request first reaches the Nginx reverse proxy, which acts as the external-facing gateway. Nginx terminates the TLS/SSL connection, decrypts the HTTPS payload, and forwards the unencrypted request to the Node.js server over the private Docker network. Before the request reaches application logic, it passes through the Helmet middleware, which applies security headers to prevent common web vulnerabilities such as XSS (Cross-Site Scripting), CSRF (Cross-Site Request Forgery), and clickjacking. The CORS middleware then validates that the request originates from an authorized frontend domain; requests from unauthorized origins are rejected immediately.

The next critical middleware validates the JWT token embedded in the Authorization header. The Node.js server maintains a cached set of public keys (JWKS) from Keycloak, updated periodically to handle key rotations. The token is cryptographically verified against these keys. If verification succeeds, the token claims (user ID, roles, permissions) are extracted and attached to the request context. If verification fails—due to an invalid signature, expired token, or missing token—the middleware returns a 401 Unauthorized response, and the request is rejected before reaching downstream services.

Concrete Example: Patient Data Retrieval

Consider a clinician’s request to retrieve a patient’s full medical history. The frontend issues a GET request to `/api/patients/:patientId`. After passing authentication and security middleware, the request reaches the routing layer, which dispatches it to the PatientService controller. The controller immediately implements input validation: the `patientId` parameter is checked to ensure it conforms to expected format (numeric ID or UUID, depending on the system design), and the authenticated user’s roles are verified to confirm they have permission to access that patient’s data (enforcing Health Insurance Portability and Accountability Act (HIPAA) privacy principles).

Before querying the database, the controller checks the Tier 1 cache (managed by `cacheHelper`). The middleware generates a deterministic cache key from the request URL: `cache:patients:patientId:{id}`. If a valid cache entry exists, the cached patient data is immediately returned with a 200 OK response, bypassing all downstream processing. This cache hit path typically completes in 20-50 milliseconds.

If a cache miss occurs, the request proceeds to the PatientService layer. The service constructs a FHIR query and forwards it to the HAPI FHIR server via an HTTP call:

GET /fhir/Patient/{patientId}. The FHIR server retrieves the patient resource from PostgreSQL, performs any necessary transformations or computations required by the FHIR R5 standard, and returns the response in FHIR JSON format.

The PatientService receives the FHIR response and performs transformation operations: extracting relevant fields, formatting dates to match frontend expectations, computing derived values (e.g., age from birthdate), and sanitizing sensitive information if necessary. The transformed data is then stored in the Redis cache with a 1-hour TTL for future requests. Finally, the response is serialized to JSON and returned to the frontend with a 200 OK status code and appropriate cache headers to guide browser-side caching.

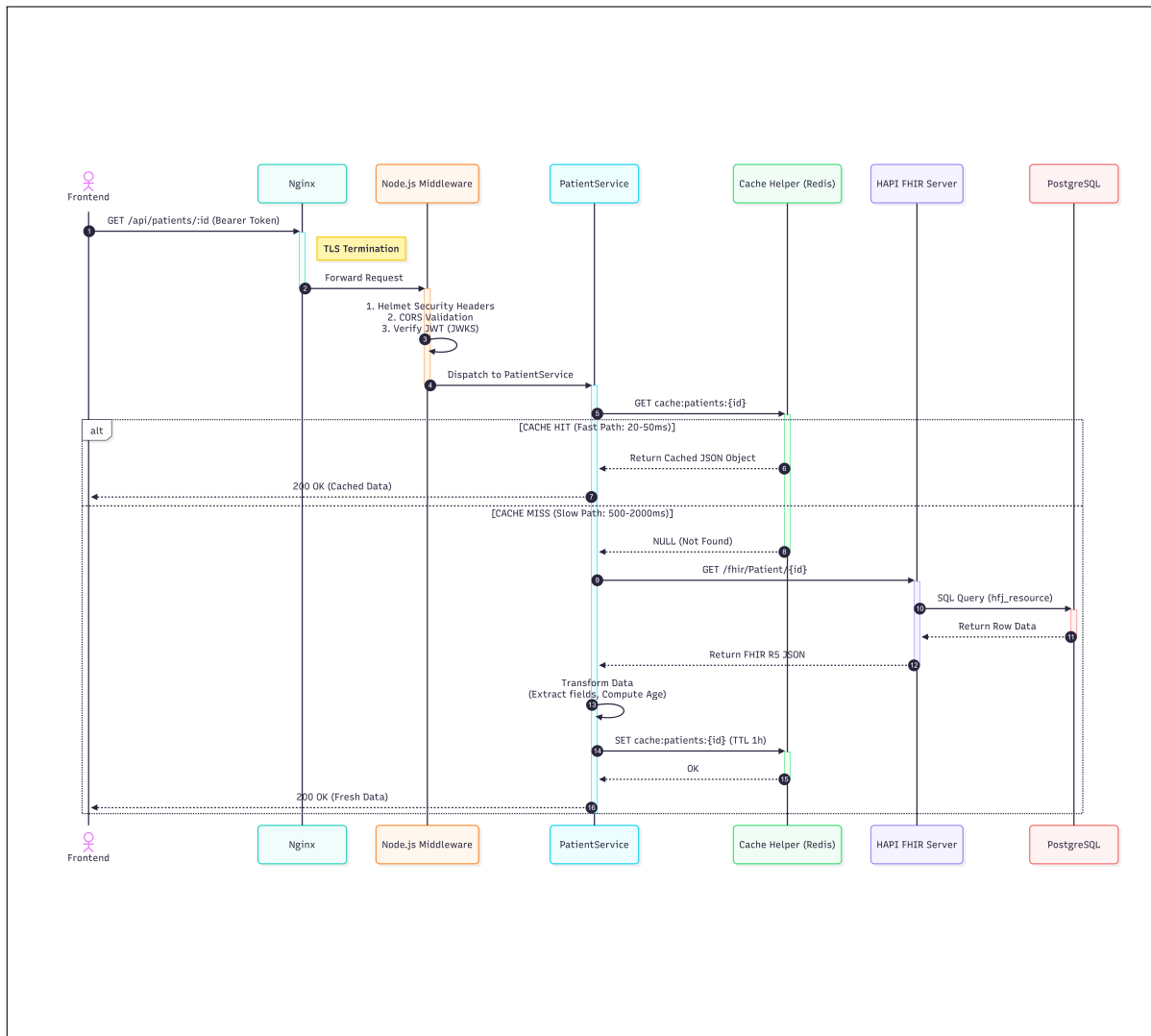


Figure 3.4: Request/Response flow for patient data retrieval, showing cache hit and miss scenarios with complete middleware pipeline.

Concrete Example: Encounter Creation and Graph Update

The encounter creation flow demonstrates more complex interactions across multiple system layers. When a clinician records a new consultation, the frontend issues a POST

request to `/api/encounters` with a JSON payload containing encounter details (patient ID, encounter type, date, notes, etc.).

The request undergoes the same initial security and authentication pipeline as before. Upon reaching the `EncounterService` controller, the request enters the input validation phase. The encounter data is validated against a schema ensuring that all required fields are present and correctly formatted. The encounter date is verified to be a valid date and logically consistent. The patient ID is validated to ensure the patient exists in the system.

Next, the `EncounterService` constructs a FHIR Encounter resource conforming to the FHIR R5 standard and submits a POST request to the HAPI FHIR server: `POST /fhir/Encounter`. The FHIR server validates the resource, generates a unique FHIR resource ID, persists the resource to PostgreSQL, and returns the created resource with its new ID.

The encounter creation triggers a cascade of downstream operations. The `EncounterService` receives the FHIR response and extracts the newly created encounter's ID. It then invokes the `historyGraphService`, passing the new encounter data. The `historyGraphService` performs a temporal scan of existing nodes for the patient, identifies potential parent nodes based on clinical rules and temporal windows, and creates appropriate edges in the `node_relations` table. This graph construction may take several hundred milliseconds to several seconds depending on the patient's history size.

Concurrently, multiple cache entries are invalidated. The patient-specific Tier 2 graph cache is cleared immediately, ensuring that the next graph visualization request triggers a fresh reconstruction. The Tier 1 cache entry for the `/api/patients/{patientId}` endpoint is also invalidated, forcing a fresh FHIR server query for updated patient data.

Finally, the `EncounterService` returns the newly created encounter resource to the frontend with a 201 Created status code. The response includes the encounter's FHIR ID, allowing the frontend to reference this specific encounter in subsequent requests.

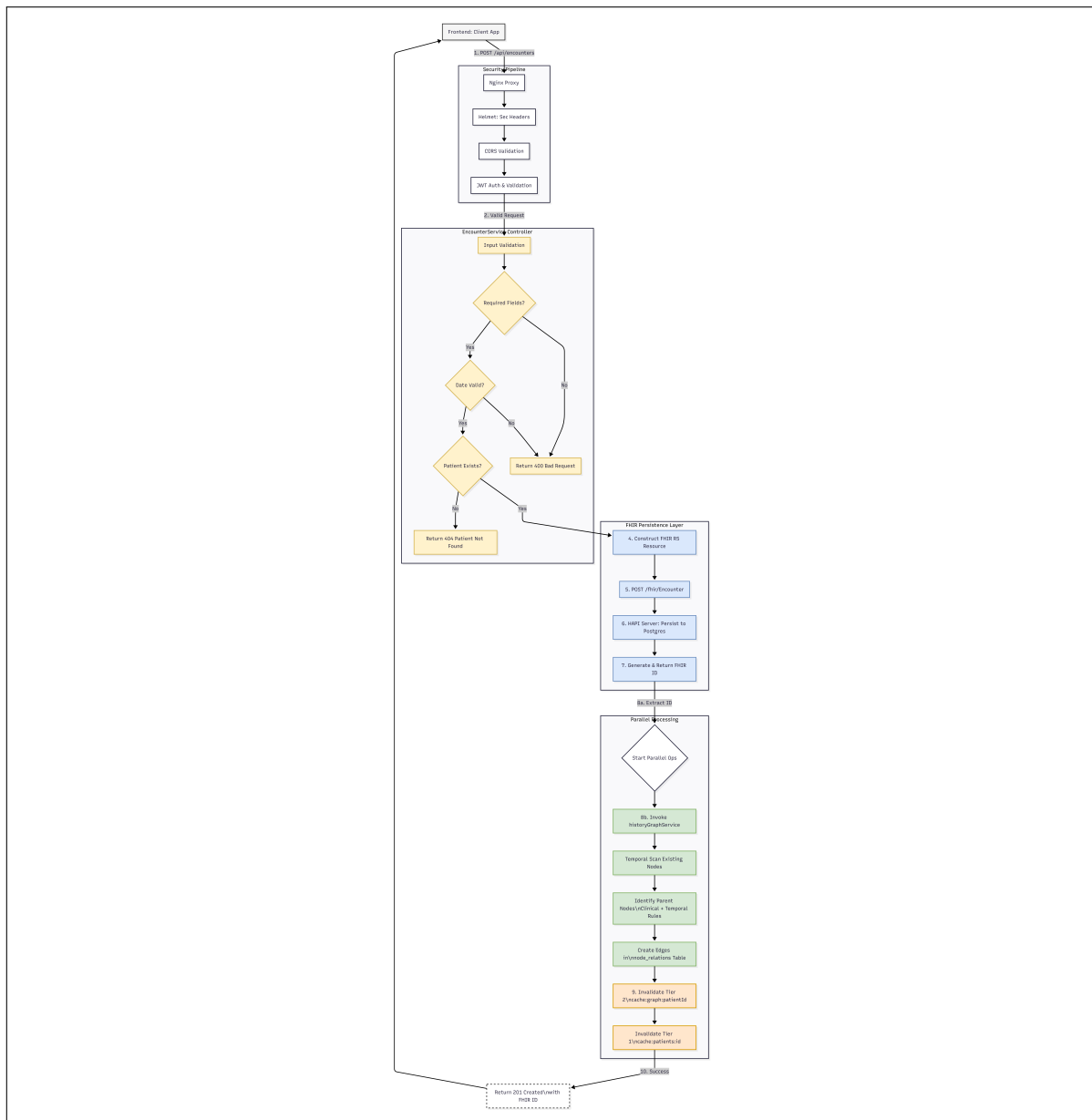


Figure 3.5: Complete encounter creation workflow showing FHIR resource persistence, graph construction, and cache invalidation cascade.

Validation Points and Error Conditions

Throughout this flow, validation occurs at multiple critical junctures. Input validation at the controller layer ensures that user-supplied data conforms to expected types and ranges. Business logic validation in the service layer verifies that operations are consistent with clinical rules. FHIR resource validation at the HAPI FHIR server ensures that resources conform to the FHIR R5 specification, preventing invalid data from being persisted.

Error conditions at any stage result in appropriate HTTP status codes and error messages: 400 Bad Request for input validation failures, 403 Forbidden for authorization

violations, 404 Not Found for missing resources, 409 Conflict for data consistency violations, and 500 Internal Server Error for unexpected server failures. Each error response includes a structured JSON object with a unique error code, human-readable message, and optionally, detailed information about the nature of the failure, enabling clinicians and developers to understand and address issues.

3.1.6 Error Handling and Fault Tolerance

The CFI-Care architecture recognizes that healthcare systems cannot tolerate downtime or data loss. Error handling and fault tolerance are designed into every layer to ensure reliable operation and graceful degradation under failure conditions.

Fallback Mechanisms and Graceful Degradation

When the FHIR server becomes temporarily unavailable, the CFI-Care system implements fallback strategies to maintain partial functionality. The caching layer becomes the primary data source: clinicians can still access patient records that were recently viewed, as these records remain in the Redis cache. While cached data may not reflect the absolute latest updates, it permits continued operation during brief FHIR server outages.

For the Patient History Graph, if the graph reconstruction fails due to FHIR server unavailability, the system returns a cached version of the graph if one exists, even if it is slightly stale. This allows clinicians to view previously computed graphs rather than receiving a complete failure. A notification is displayed to indicate that the graph may not reflect recent changes.

For new operations that require FHIR server access (creating encounters, adding diagnoses), if the FHIR server is unavailable, the system cannot proceed and returns a 503 Service Unavailable response, informing the clinician that the action cannot be completed at this moment. Rather than accepting incomplete or invalid data, the system fails safely, requiring the user to retry when the service recovers.

Logging and Observability for Error Diagnosis

All errors are logged with structured logging that includes timestamp, error level (ERROR, WARN, INFO), service component generating the error, error code and message, request context (user ID, patient ID, operation being performed), and stack trace for unexpected exceptions. This structured logging enables rapid diagnosis of issues: operators can search logs by error code to identify all instances of a particular failure, by user ID to understand a user's experience during an outage, or by component to focus on specific services.

Critical errors are propagated to alerting systems, enabling operators to be notified of failures in real-time. For instance, if the FHIR server becomes unavailable, an alert is triggered within seconds. If error rates exceed thresholds, alerts notify operators that the system is degrading. This proactive monitoring enables rapid response to emerging issues before they impact clinicians' ability to deliver care.

3.1.7 Security and Infrastructure Layer

The infrastructure is secured through a centralized Identity and Access Management (IAM) system using Keycloak. Keycloak handles all OAuth 2.0 and OpenID Connect flows, issuing JSON Web Tokens (JWT) that the Node.js backend validates against a public key set (JWKS).

All components are containerized using Docker and orchestrated via Docker Compose. The environment is isolated within a private bridge network, with Nginx acting as the sole entry point. Nginx enforces SSL/TLS encryption using locally generated certificates, ensuring that all data in transit is encrypted. Containers are configured with read-only file system mounts and strict privilege limitations to minimize the security attack surface.

3.1.8 HAPI FHIR Server Implementation

The core component responsible for standardizing healthcare data within the CFI-Care system is the FHIR Server. This server is implemented using the HAPI FHIR JPA Server Starter framework. It is built upon the Java Spring Boot ecosystem and provides a fully compliant implementation of the FHIR Release 5 (R5) standard. This choice ensures that all clinical data, regardless of its source, adheres to international interoperability protocols and persists reliably within the database.

To tailor the server for the specific needs of this project, several important configuration changes were applied to the default setup. To maintain a lightweight and efficient runtime, advanced features that were not immediately required were explicitly disabled. This includes the Clinical Reasoning module and the CDS Hooks service. Similarly, bulk export and import operations were deactivated to prevent unnecessary resource consumption. Conversely, the OpenAPI documentation endpoints were enabled. This configuration allows developers to inspect the API structure and test endpoints directly through a web interface.

The persistence layer is powered by a PostgreSQL database connected via the Hibernate JPA engine. Specific configurations were applied to the Hibernate settings to optimize performance. The system uses the dedicated `HapiFhirPostgresDialect` to ensure efficient SQL generation. Additionally, the database schema management is configured to automatically update the table structures upon server startup, ensuring that the database remains synchronized with the code.

The server is responsible for managing a wide array of clinical resources necessary for the application. These include foundational entities such as Patient and Practitioner, as well as clinical events like Encounters, Procedures, and Observations. It also handles complex data types, including MedicationRequests for prescriptions and Binary resources for storing documents like PDF files.

For deployment, the server utilizes a secure multi-stage Docker build process. The first stage uses Maven to compile the application code and generate the necessary artifacts. The final runtime image is built upon a "distroless" Java 17 base image. This approach significantly reduces the final container size and improves security by removing unnecessary operating system tools and shells from the production environment.

3.2 API Design and Endpoints

The communication between the frontend client and the backend server is established through a structured RESTful API. This design ensures that the system remains stateless and scalable, utilizing standard HTTP methods to perform operations on resources. The Node.js application server acts as the centralized gateway, exposing a unified set of endpoints that handle both standard clinical data and custom graph logic.

3.2.1 RESTful Structure and Formats

All API interactions strictly adhere to the Javascript Object Notation (JSON) format for both request bodies and response payloads. The system utilizes standard HTTP verbs to define the nature of the operation. GET requests are used exclusively for retrieving data without side effects, while POST requests handle the creation of new resources. PUT methods are employed for updating existing records, and DELETE methods remove specific resources when permitted.

Responses from the server are standardized to ensure predictability for the client application. Successful operations return a 200 OK status code accompanied by the requested data object. In cases of resource creation, a 201 Created status is returned. Error handling is centralized, ensuring that any failure creates a consistent JSON error object containing a human-readable message and a specific error code, rather than exposing raw server stack traces.

3.2.2 FHIR-Compliant Endpoints

A significant portion of the API is dedicated to proxying standard FHIR resources. Endpoints such as `/api/patients` and `/api/encounters` act as a validation and caching layer sitting in front of the HAPI FHIR server. When the frontend requests patient details, the Node.js server intercepts this call, validates the parameters, and then forwards the request to the underlying Java server. The response is strictly compliant with the FHIR R5 standard, ensuring that the data structure remains interoperable with other external healthcare systems.

3.2.3 Custom History Graph Endpoints

Beyond standard FHIR resources, the API exposes specialized endpoints designed to support the Patient History Graph visualization. The primary endpoint, `/api/historyGraph`, does not return a simple list of records. Instead, it aggregates data from multiple FHIR resources and transforms them into a graph structure containing nodes and relational edges. This allows the frontend to render the complex temporal relationships between medical events without needing to perform heavy data processing in the browser.

Method	Endpoint	Description
GET	/api/patients	Retrieve list of patients with pagination support
POST	/api/patients	Register a new patient with FHIR validation
GET	/api/encounters/:id	Get specific encounter details including clinical observations
GET	/api/historyGraph/:id	Get patient history graph nodes and causal relationships
POST	/auth/login	Authenticate user and obtain JWT token via Keycloak

Table 3.1: Key REST API Endpoints provided by the Node.js Backend.

3.3 Patient History Graph Implementation

A core distinguishing feature of the CFI-Care backend is the Patient History Graph, which visualizes a patient’s medical journey as a Directed Acyclic Graph (DAG). Unlike standard FHIR lists, which present data linearly, this graph models causal and temporal relationships between medical events. This representation provides clinicians with a sophisticated tool for understanding the evolution of a patient’s condition, particularly in complex cases involving multiple concurrent diagnoses or extended treatment histories.

3.3.1 Motivation: Beyond Linear Medical Records

Traditional Electronic Health Records (Electronic Health Record (EHR)s) typically present patient data as chronologically ordered events: a consultation on January 1st, a lab test on January 3rd, a prescription on January 5th, and so forth. While this linear representation is straightforward to implement and understand, it obscures the causal relationships that are essential to clinical reasoning. Consider a patient with Type 2 Diabetes presenting with hypertension and elevated cholesterol levels. In a linear record, these appear as separate events without explicit connection. However, a clinician recognizes that these conditions are causally related—elevated cholesterol and hypertension may be comorbidities stemming from the underlying metabolic dysfunction of diabetes.

The Patient History Graph addresses this limitation by explicitly modeling causality and temporal dependencies. Each medical event is represented as a node in the graph, and directed edges represent causal or temporal relationships. This graphical representation allows clinicians to trace the progression of a specific condition across multiple encounters and interventions, identify temporal clusters of related events that may indicate disease progression or treatment response, visualize the impact of therapeutic interventions on

subsequent clinical outcomes, and differentiate between independent medical episodes and related sequences of events. By making these relationships explicit, the graph transforms raw temporal sequences into clinically meaningful narratives that support more effective decision-making.

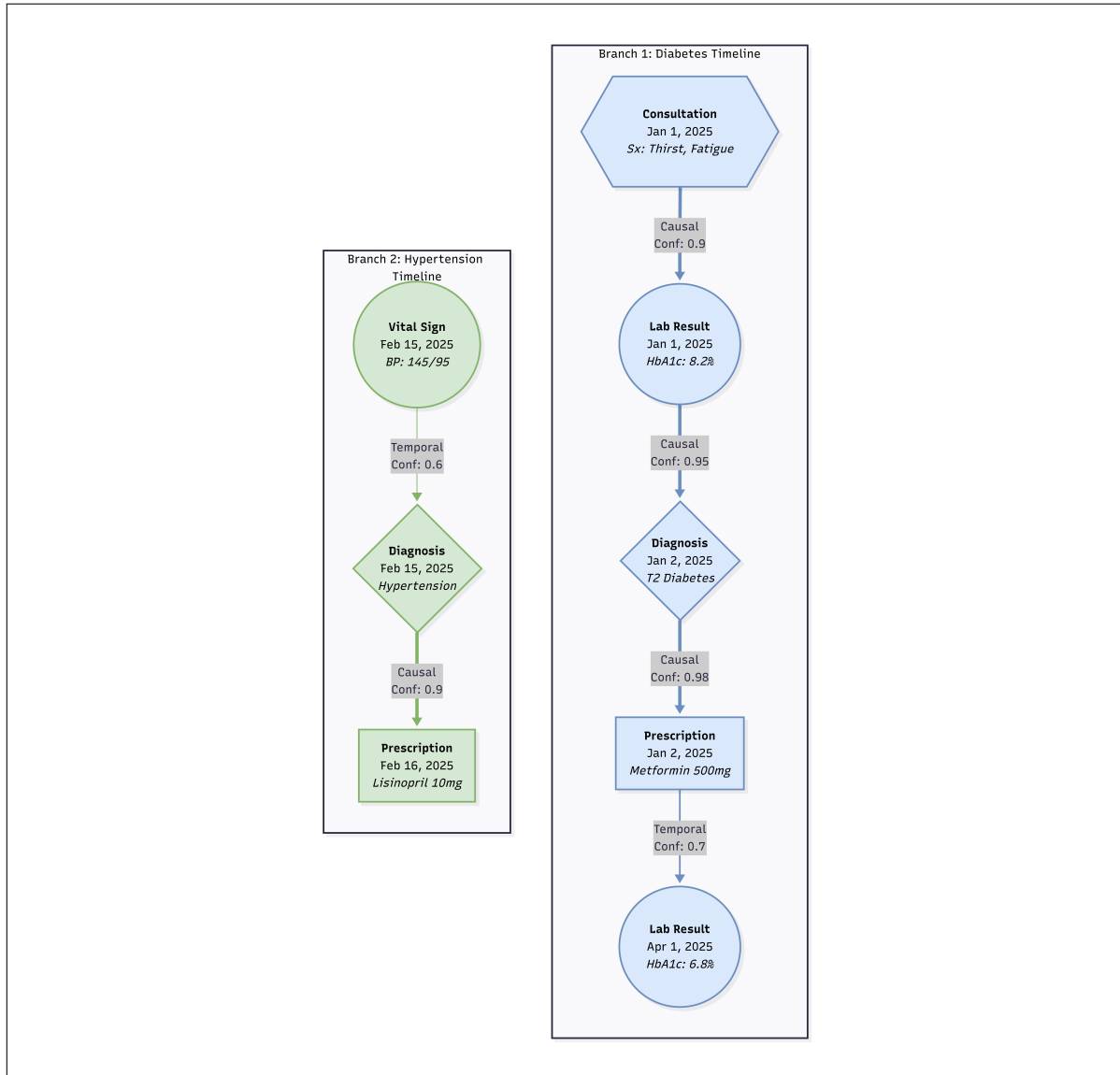


Figure 3.6: Example Patient History Graph showing a diabetes patient with concurrent hypertension, demonstrating temporal branching and multiple relationship types.

3.3.2 Graph Data Model

The Patient History Graph is built upon a relational foundation with two primary tables: `encounter_nodes` and `node_relations`.

Node Representation

Each node in the graph represents a distinct clinical event or observation. The system recognizes six primary node types: **Consultation** represents a clinical encounter between patient and clinician; **Diagnosis** denotes a confirmed medical condition recorded during or after a consultation; **Prescription** indicates a medication prescribed to address a specific condition; **LabResult** captures laboratory or diagnostic test results; **Vital** encompasses blood pressure, temperature, and other vital signs; and **Symptom** represents patient-reported subjective findings.

Each node stores rich metadata including its creation timestamp, an associated FHIR resource ID for traceability, its clinical category, and the patient to which it belongs. A fundamental design principle of the Patient History Graph is immutability: nodes, once created, cannot be modified or deleted. This architectural choice ensures that the graph preserves a complete and auditable record of the patient's medical journey, enabling clinicians to understand not just what happened, but also when records were created and by whom.

Edge Representation

Edges in the graph represent causal or temporal relationships. An edge from node *A* to node *B* indicates that event *A* preceded and potentially caused or informed event *B*. The system maintains an explicit `node_relations` table storing parent-child pairs, enabling efficient graph traversal for visualization and analysis.

3.3.3 Temporal Branching and Concurrent Episodes

Real-world patient histories are rarely linear. A patient may have multiple concurrent health issues being managed in parallel. For example, a patient may simultaneously receive treatment for diabetes, hypertension, and arthritis. In a traditional linear EHR, this complexity is flattened; all events appear chronologically without indication of which episode they belong to.

The CFI-Care graph model handles this through an explicit branching mechanism:

Head Node Concept

A "Head Node" is a node with no outgoing edges to other nodes in the current timestamp window. When a new clinical event arrives that does not fit within any existing causal chain (i.e., no valid parent is found), the system creates a new Head Node, effectively initiating a new branch in the history graph.

For example, consider a patient's history:

1. Consultation for chest pain (2025-01-01)
2. EKG test (2025-01-01)

3. Cardiology referral (2025-01-02)
4. New consultation for joint pain (2025-02-15) — **New Branch**
5. X-ray of knee (2025-02-15)
6. Rheumatology referral (2025-02-16)

The system recognizes that the joint pain consultation on 2025-02-15 cannot be causally linked to the earlier cardiology events (temporal gap exceeds threshold, clinical context is unrelated). Therefore, it creates a new Head Node for the rheumatology branch, allowing clinicians to visually separate the two episodes.

Visual Implications

From a visualization perspective, branching creates a multi-root forest structure (multiple separate trees within the graph). The frontend rendering engine positions these branches side-by-side or in hierarchical layout, enabling clinicians to track multiple concurrent conditions without visual clutter or confusion.

Clinical Advantages

Explicit branching provides significant clinical benefits that improve the utility of the Patient History Graph. Clinicians immediately recognize which events belong to which condition through visual separation, substantially reducing cognitive load compared to linearly ordered records. The system can provide condition-specific recommendations by analyzing the isolated branch rather than considering the entire patient history, enabling more targeted and relevant clinical decision support. Additionally, each branch can be summarized independently for specialist-to-specialist referrals, allowing specialists to focus on the specific problem domain without irrelevant context from other concurrent conditions.

3.3.4 Relationship Classification

Not all edges in the Patient History Graph carry the same semantic weight or clinical significance. The system classifies relationships into three distinct types to preserve this important distinction. Causal relationships represent situations where Node *A* directly caused or necessitated Node *B*. For example, a Diabetes Diagnosis directly necessitates a Metformin Prescription. These edges carry high confidence scores and strong clinical significance, indicating a clear cause-and-effect relationship. Temporal relationships occur when Node *A* preceded Node *B* within the same clinical episode, but causality is not explicitly established. For instance, a Consultation followed by a Blood Pressure Reading taken during the same visit represents a temporal relationship rather than a causal one. Associative relationships capture scenarios where Node *A* and Node *B* are related through shared clinical context—such as both addressing the same underlying condition—but neither directly causes the other. For example, a High Cholesterol Lab

Result and a Diabetes Diagnosis both present in the same patient might be associated through their shared metabolic dysfunction.

Each relationship in the graph stores a confidence score ranging from 0.0 to 1.0, generated by the construction algorithm based on how well the relationship satisfies the various constraint criteria. High-confidence relationships with scores exceeding 0.8 are displayed prominently in the visualization, while lower-confidence relationships are shown with reduced visual emphasis or as optional links that the clinician can explore if desired.

3.3.5 Handling Edge Cases

The Patient History Graph implementation must gracefully handle several challenging scenarios that arise in real-world clinical practice. Retroactive diagnosis occurs when a patient receives a diagnosis that applies to earlier symptoms after those symptoms have already been recorded. For example, a patient might experience chest pain on January 1st and only receive a diagnosis of coronary artery disease on March 1st. The algorithm detects this temporal mismatch and retroactively relinks the symptom node to the new diagnosis, maintaining causal clarity and preventing the false impression that the symptom was unexplained.

Conflicting information presents another challenge. When new FHIR data contradicts previously recorded information—such as a diagnosis being changed, retracted, or corrected—the system must handle this gracefully. Rather than deleting nodes (which would violate the immutability principle and destroy the audit trail), the system creates a new node representing the correction and links it appropriately to existing nodes. This approach preserves the complete historical record while accurately reflecting the current clinical understanding.

Circular references represent a potential structural problem. Although directed acyclic graphs (DAGs) cannot, by definition, contain cycles, the algorithm must validate that no accidental cycles are introduced during edge creation. This validation is enforced through topological sorting checks performed before persisting relationships to the database, preventing data consistency issues that could arise from cycles.

3.3.6 Query Patterns and Optimization

The frontend visualization layer requires efficient access to the graph structure through several common query patterns, each optimized for specific clinical use cases. Full Graph Retrieval fetches all nodes and edges for a patient, which is necessary during the initial page load when clinicians first view a patient's complete medical history. This operation is optimized through caching strategies discussed in Section 3.4. Ancestor Traversal answers questions such as "What led to this prescription?" by fetching all ancestor nodes of a specific event. This pattern is implemented via recursive queries that are bounded by depth to prevent unbounded traversals. Branch Isolation allows clinicians to focus on specific medical episodes, such as "Show only cardiology-related events," by fetching all nodes within a specific branch. This operation uses topological partitioning to efficiently

isolate branches without scanning the entire graph. Temporal Range Queries retrieve nodes within a specific date range, enabling clinicians to analyze disease progression over a specific time period. These queries leverage indexed timestamp columns to achieve $O(\log n)$ lookup time complexity, ensuring responsiveness even for patients with extensive histories.

3.4 Performance Optimization

To ensure low-latency responses for the frontend visualizations, the backend implements a specialized Two-Tier Caching Strategy using Redis. This hierarchical caching approach balances data freshness with response times, recognizing that different types of medical data have different update frequencies and computational costs.

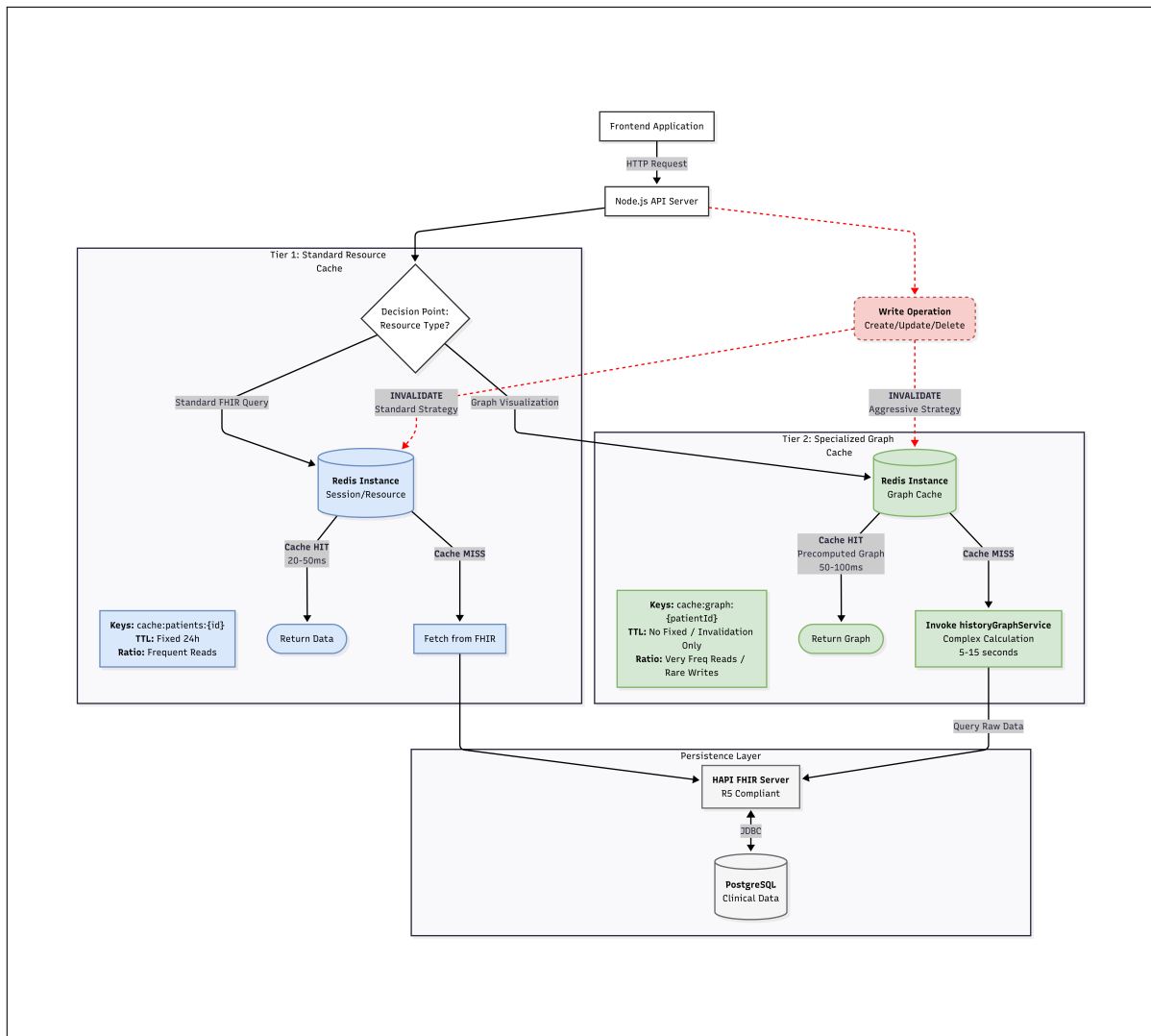


Figure 3.7: Two-Tier Caching Architecture showing distinct strategies for standard FHIR resources (Tier 1) and complex graph structures (Tier 2).

3.4.1 Tier 1: Standard Resource Cache

The first tier utilizes a generic `cacheHelper` middleware that intercepts HTTPS requests for standard FHIR resources. This middleware operates at the request level, functioning as a transparent cache layer between the frontend client and the backend processing pipeline.

Mechanism and Interception

When an HTTPS request arrives at the backend (such as a GET request to `/api/patients`), the `cacheHelper` middleware performs a sequence of operations to determine whether a cached response can be served. The middleware first generates a deterministic cache key from the request URL and query parameters—for example, a request to `/api/patients?page=1&limit=20` generates the key `cache:patients:page:1:limit:20`. The middleware then queries the Redis cache for an entry matching this key. If a valid cache entry exists, meaning the entry has not expired, the cached response is immediately returned to the client, entirely bypassing the FHIR server, database query execution, and all downstream processing. This direct cache-to-client path reduces latency from potentially 500-2000ms (database query time) to sub-50ms (Redis in-memory retrieval). If no entry exists or the entry has expired, the request proceeds through the normal processing pipeline: the backend queries the FHIR server, processes the response, and returns it to the client. Before returning, the response is stored in Redis for future requests, repopulating the cache.

Time-To-Live (TTL) Management

Cached FHIR resources are assigned a default Time-To-Live (TTL) of 1 hour, representing a clinically acceptable window where cached data is considered sufficiently fresh for clinical use. This 1-hour window is chosen based on several practical considerations. From a clinical workflow perspective, most healthcare workflows operate on new fresh data every hour. A patient's medication list, diagnosis history, and vital signs are statistically unlikely to change multiple times within a single hour in most clinical scenarios. From a system load perspective, a 1-hour TTL significantly reduces the query volume to the underlying FHIR server and database, minimizing computational load during peak usage hours when many clinicians are accessing patient data simultaneously. While the 1-hour window does introduce some degree of data staleness, this tradeoff is clinically acceptable for read-heavy operations on relatively stable data that changes infrequently.

However, the TTL is configurable on a per-resource-type basis to accommodate different data freshness requirements. Real-time vital signs or active medication adjustments might use a shorter TTL of one hour to ensure clinicians see recent changes, while historical diagnoses that rarely change might use a longer TTL of 12 hours to reduce computational overhead.

Cache Invalidation for Tier 1

Although Tier 1 uses a fixed TTL-based expiration, certain write operations trigger explicit cache invalidation to ensure data consistency. When a patient record is modified—such as contact information changes or new allergies being recorded—the corresponding cache entries for that patient are immediately removed, forcing a fresh fetch on the next request. Similarly, when a new encounter is recorded or an existing one is updated, the cache entries for `/api/encounters` are invalidated to reflect the changes. The system maintains a comprehensive mapping of dependencies between cache keys and FHIR resources. When a resource is modified, all dependent cache entries are invalidated simultaneously, preventing scenarios where multiple cache entries contain stale references to the same resource.

Practical Impact

The practical benefit of Tier 1 caching becomes apparent in typical clinic workflows where healthcare providers request the same patient’s record multiple times during a single day. Without caching, each request would trigger a database query taking 500-1000ms, and checking the same patient 5 times would incur 2500-5000ms of cumulative latency. With Tier 1 caching in place, the first request incurs the full latency of 500-1000ms, but subsequent requests within 24 hours are served from cache in approximately 20-50ms each. For five checks of the same patient, the total latency becomes 500-1000ms plus 80-200ms for the cached requests, totaling 580-1200ms. This represents a 75-80 percent reduction in latency, dramatically improving the responsiveness of the system and reducing clinician wait times during patient data retrieval.

3.4.2 Tier 2: Specialized Graph Cache

The second tier is specifically designed for the computationally intensive Patient History Graph. While Tier 1 caches simple resource retrieval, Tier 2 caches the results of complex graph construction and relationship mapping.

Computational Cost of Graph Construction

Constructing a Patient History Graph from raw FHIR resources is computationally expensive for several interconnected reasons. Data aggregation requires retrieving all FHIR resources for a patient, including consultations, diagnoses, prescriptions, lab results, vitals, and symptoms, potentially from multiple FHIR repositories. A patient with an extensive medical history might have hundreds of such resources, necessitating multiple server calls and database queries. Relationship inference constitutes the most computationally intensive phase. For each new node, the algorithm must scan all existing nodes for that patient, evaluate whether causal relationships should exist by checking temporal windows, clinical context compatibility, and event type rules, compute confidence scores for each potential relationship, and determine the most relevant parent. This represents an $O(n)$ operation where n is the number of existing nodes, and complex

patients with 500+ nodes can require significant computational resources. Graph formatting transforms the raw graph structure into a visualization-ready format suitable for the frontend rendering library. This transformation includes computing optimal node positions in the visual layout, determining visual attributes such as color, size, and emphasis, serializing the entire structure to JSON, and applying any additional formatting for the specific frontend framework. For a patient with 500 nodes, these cumulative operations can collectively require 5-15 seconds of computational time—far too slow for the responsive interactive experience that clinicians expect.

The Graph Cache Manager: `toonNodesCacheHelper`

The `toonNodesCacheHelper` service manages caching specifically for the Patient History Graph. Unlike the generic Tier 1 cache which uses simple TTL expiration, the graph cache is patient-specific and extensively optimized for the unique characteristics of graph data. Each patient has a dedicated cache entry with the key `cache:graph:{patientId}`, containing their complete precomputed graph structure. The cache value stores a comprehensive JSON object containing all nodes with their associated metadata (type, timestamp, clinical details), all edges with their relationship types and confidence scores, and precomputed visual attributes including node positions and branch assignments. Unlike Tier 1 caching which relies on fixed TTL expiration, the graph cache does not use time-based expiration at all. Instead, it relies entirely on explicit invalidation to ensure that cached data always reflects the current patient history.

Aggressive Invalidation Strategy

The graph cache employs an aggressive invalidation approach that prioritizes data consistency over computational efficiency. Any write operation to a patient’s medical history immediately invalidates their corresponding graph cache entry. This design reflects a fundamental tradeoff in the caching strategy: write operations are relatively rare compared to read operations in clinical workflows, while read operations dominate. A single patient might have their graph read hundreds of times per day across multiple clinicians viewing the same patient from different workstations or different clinical contexts, yet the patient’s medical history is modified only a few times per day. Given this asymmetry, it is computationally more efficient to invalidate the cache upon writes (an immediate operation) than to maintain cache staleness during reads or to implement complex update-in-place strategies. The invalidation is triggered by several categories of events: recording a new clinical event such as a consultation, diagnosis, prescription, or lab result; updating or correcting an existing node; modifying relationships between nodes; or retracting or changing a diagnosis or medication. Any of these operations immediately removes the cached graph, forcing reconstruction on the next request.

Cache Reconstruction Workflow

When a graph cache miss occurs, either due to invalidation from a write operation or because the cache has never been populated for that patient, a well-defined reconstruction workflow is executed. The frontend or backend first requests the graph

for the patient. The `toonNodesCacheHelper` detects the cache miss and invokes the `historyGraphService` to reconstruct the graph from scratch. The reconstruction process retrieves all FHIR resources for the patient, executes the complete graph construction algorithm including temporal scanning and parent identification, and computes visual attributes. Once complete, the entire graph structure is serialized to JSON and stored in Redis. The fully reconstructed cache is then returned to the requesting client. Subsequent requests within the same session or from other clinicians viewing the same patient retrieve the cached graph in sub-100ms latency, providing responsive interactive performance.

Hit Rate and Performance Impact

The effectiveness of the graph cache in improving system performance depends heavily on the read-to-write ratio, which varies depending on the clinical workflow pattern. In read-heavy workflows, which represent the typical clinical use case, a clinician views a patient's graph multiple times during a consultation, compares it with previous snapshots to track disease progression, and discusses findings with colleagues or consulting specialists. The same graph may be read 10-20 times before any modification to the patient record occurs. In these scenarios, the graph cache achieves hit rates of 85-95 percent, resulting in dramatic performance improvements. A graph that would normally require 15-20 seconds of computational time to construct is served from cache in 50-100ms, a 100-200x latency reduction. In contrast, write-heavy workflows are rare but do occur, such as when a clinician is entering comprehensive historical data for a newly-registered patient, recording 20-30 events that generate new medical events in quick succession. Each new event triggers cache invalidation, causing multiple cache misses and requiring full reconstructions. In these scenarios, the cache hit rate drops to 20-30 percent. The aggressive invalidation strategy in this case sacrifices caching efficiency to ensure that data consistency is always maintained. In typical clinical workflows, the combination of read-heavy access patterns and Tier 2 caching provides a 100-200x latency improvement for graph visualization, translating to substantially more responsive clinical interfaces and reduced clinician wait times.

Coordination Between Tier 1 and Tier 2

The two caching tiers work in close coordination to maximize performance across different types of requests. When the frontend requests standard FHIR resources such as a patient list or individual patient demographic data, Tier 1 cache is checked first, providing rapid responses for frequently accessed basic information. When the frontend requests the complex Patient History Graph visualization, Tier 2 cache is consulted, serving the precomputed graph structure with all relationships and visual attributes already prepared. Invalidation operations propagate across both tiers simultaneously. For example, recording a new prescription invalidates both the Tier 1 cache entry for `/api/prescriptions` (which would now be stale relative to the 24-hour TTL) and the Tier 2 cache for that patient's history graph (which must be reconstructed to include the new node and relationships). This coordinated invalidation ensures that regardless of which API endpoint a clinician accesses, the data reflects the most recent state of the patient's record.

Memory Management and Cache Eviction

Redis is configured with a maximum memory limit to prevent unbounded growth and to integrate into production server resource constraints. To manage memory efficiently, the CFI-Care backend employs an LRU (Least Recently Used) eviction policy. When Redis approaches its configured maximum memory capacity, the system automatically evicts the least recently accessed cache entries to make space for new data. This dynamic approach to cache management creates a natural working set where the cache automatically retains entries for patients with active clinical workflows (frequently accessed by multiple clinicians) while entries for inactive patients are evicted and subsequently reconstructed on-demand if and when those patients are accessed again. This ensures that memory usage remains bounded and predictable while simultaneously maximizing cache hit rates for the active subset of patients. In practice, this means that high-volume clinical workflows benefit from maximum cache coverage, while less frequently accessed patients gracefully degrade to on-demand reconstruction without requiring administrator intervention or manual cache management.

3.5 Frontend

3.5.1 Overview and Design Objectives

The frontend of *CFI-Care* was designed as an interactive medical information system aimed at enabling healthcare professionals to efficiently explore, manage, and reason about patient data. The primary objective was to transform fragmented medical records into a coherent, visual, and navigable representation of a patient’s medical journey, while maintaining clinical clarity, responsiveness, and usability across the full scope of the application.

The frontend follows a component-based architecture implemented using the Angular framework. Advanced data visualisation is achieved through the integration of D3.js and Treviz, while Bootstrap and Bootstrap Icons provide responsive layout, visual consistency, and accessibility across devices.

The main design goals of the frontend include:

- Clear separation of concerns between navigation, visualisation, and data manipulation.
- Visual prioritisation of clinically critical events through deliberate colour coding and animated indicators.
- Support for both categorical and temporal reasoning over patient medical data through two complementary visualisation modes.
- A patient-access grant workflow that balances security requirements with a smooth, low-friction clinical experience.

- A fully integrated AI-assisted chat interface that enables real-time clinical reasoning alongside patient data.

Component-based frontend architectures have been shown to improve scalability, maintainability, and development efficiency in large-scale systems [92].

3.5.2 Technology Stack

Table 3.2 summarises the main technologies used in the frontend implementation.

Table 3.2: Frontend Technology Stack

Technology	Purpose
Angular 17	Core frontend framework, routing, and state management
D3.js (v7)	Data-driven visualisation and interaction logic
Treeviz	Hierarchical graph layout abstraction
Bootstrap	Responsive layout and UI consistency
Bootstrap Icons	Visual indicators and interaction affordances
RxJS	Reactive streams for async data flow and polling
ng-otp-input	Six-digit OTP input component for grant handshake

Angular’s declarative templates and reactive change-detection model make it suitable for highly interactive, state-driven medical interfaces [48]. RxJS operators such as `interval`, `switchMap`, and `takeWhile` are used to implement the patient-access grant polling loop, avoiding manual timer management and ensuring automatic teardown on component destruction.

3.5.3 System Architecture

The CFI-Care frontend is structured as a modular, component-based single-page application (SPA) built with Angular. The system follows a layered frontend architecture that cleanly separates presentation, state management, domain models, and visualisation logic.

At a high level, the architecture consists of the following layers:

- **Application Shell:** Responsible for route registration, authentication guards, and top-level layout composition.
- **Feature Modules:** Self-contained UI modules grouped by clinical concern, covering the patient dashboard, doctor profile and schedule management, grant management screens, and the AI chat interface.
- **MedGraph Visualisation Module:** A dedicated visualisation boundary hosting both the categorical tree and the chronological timeline, isolated from Angular’s change-detection loop via an `iframe` boundary to prevent rendering interference.

- **Shared Domain Models and Services:** Centralised TypeScript interfaces and injectable Angular services that carry application state and mediate all HTTP communication with the backend.
- **Graph Rendering Engine:** A self-contained HTML file (loaded inside an iframe) that combines Treeviz, D3.js, and vanilla JavaScript to render interactive patient journey graphs, communicating with the Angular host via the `postMessage` API.

Route Structure and Navigation Guards

The application defines the following client-side routes:

Table 3.3: Application Route Configuration

Path	Component	Guard
/	Redirect to /dashboard	—
/dashboard	Dashboard	authGuard
/med-graph/:id	MedGraph	authGuard
/chat-section	ChatSection	authGuard
/doctor-profile	DoctorProfileComponent	authGuard
/grants/pending	GrantPendingComponent	authGuard
/grants/active	GrantActiveComponent	authGuard
/error/:status	GatewayErrorComponent	—

All clinically sensitive routes are protected by `authGuard`, an Angular route guard that verifies session validity before permitting navigation. Unauthenticated users are redirected to the login flow. The `/error/:status` route accepts a dynamic HTTP status code and renders a contextual error page, handling backend or gateway failures gracefully without exposing raw error traces to the user.

The `/med-graph/:id` route accepts a patient identifier as a path parameter and an optional `eocId` query parameter, enabling direct deep-linking to a specific episode of care’s visualisation.

Component Hierarchy

Figure 3.26 illustrates the full component tree. The `Dashboard` component acts as a layout compositor, combining three child components: `TopBar` (global navigation and account controls), `UsersPanel` (patient search, filter, and list), and `UserInfo` (detailed clinical summary for the selected patient). The `MedGraph` component operates independently, receiving its patient context from route parameters and communicating with the embedded iframe via `postMessage`.

3.5.4 Styling and UX Philosophy

The CFI-Care frontend adopts a *High-Contrast Clinical Design System*, intentionally crafted to balance institutional medical trust with modern, interactive sophistication. This design approach prioritises clarity, confidence, and rapid information recognition, all critical requirements in high-stakes clinical environments.

Colour Theory and Semantic Encoding

The visual palette is dominated by blue-scale tones combined with cyan and teal gradients. Deep blue hues are widely associated with trust, security, and professionalism in healthcare interfaces, while cyan gradients introduce a contemporary, technology-forward aesthetic suited to an AI-augmented system.

Colour is used not merely as decoration but as a primary semantic layer. Medical event categories such as laboratory results, consultations, imaging studies, AI-generated suggestions, prescriptions, and allergies are consistently colour-coded across every view of the system. This allows clinicians to identify event types instantly through pre-attentive visual processing, without requiring explicit text reading, a principle well-supported in visualisation research [88, 89].

The same colour assignments are maintained across the categorical tree, the chronological timeline, node detail panels, and the legend, ensuring that the visual vocabulary is learned once and remains coherent throughout the application.

Visual Hierarchy and Layout Strategy

The interface relies on a card-based information architecture layered over a neutral background. Glassmorphism and soft elevation effects are applied selectively to authentication cards and dashboard panels, creating visual depth without introducing clutter.

A master-detail layout is employed throughout the patient dashboard, with a persistent high-contrast sidebar acting as a stable navigational anchor. This structure reduces spatial disorientation and supports rapid context switching, which is essential in time-constrained clinical workflows [90].

Typography, Iconography, and Micro-Interactions

The Inter typeface is used consistently throughout the application to maximise legibility across varying screen sizes and lighting conditions. Minimalist line-based Bootstrap Icons provide language-independent visual cues, accelerating recognition and navigation.

Within the Patient Journey Dashboard, medical events are represented as stylised circular nodes. High-priority nodes carry red rings rendered through CSS, drawing clinical attention without requiring user interaction. Hover states on node circles include a smooth scale transform and an enhanced drop-shadow filter, reinforcing the interactive affordance of each element.

The application additionally provides a dark mode, toggled via a persistent button in the top-right corner of the graph view. The user's preference is persisted to `localStorage`, ensuring continuity across sessions. Dark mode applies a comprehensive set of CSS variable overrides across all panels, the SVG canvas, modal dialogs, and sidebar components.

3.5.5 Authentication and Navigation Shell

Login Interface

The Sign In page serves as the primary entry point to the system and was designed to establish trust and professionalism, which are critical factors in healthcare software adoption. The interface follows a split-view layout: the left pane reinforces the system's value proposition through concise messaging emphasising security and patient-centred care, while the right pane presents a modern authentication card. Authentication is handled via Keycloak and OAuth 2.0, providing industry-standard session management.

The registration flow enforces input completeness before submission, preventing partial account creation. As shown in Figure 3.8, all required fields must be populated for the form to proceed. Once a user registers, they are required to verify their email address using a six-digit code sent to their registered address, as illustrated in Figure 3.9. Upon first activation, the system also generates a set of recovery codes that the clinician must copy or download as a text file, providing a fallback authentication mechanism should primary credentials be lost (Figure 3.10).

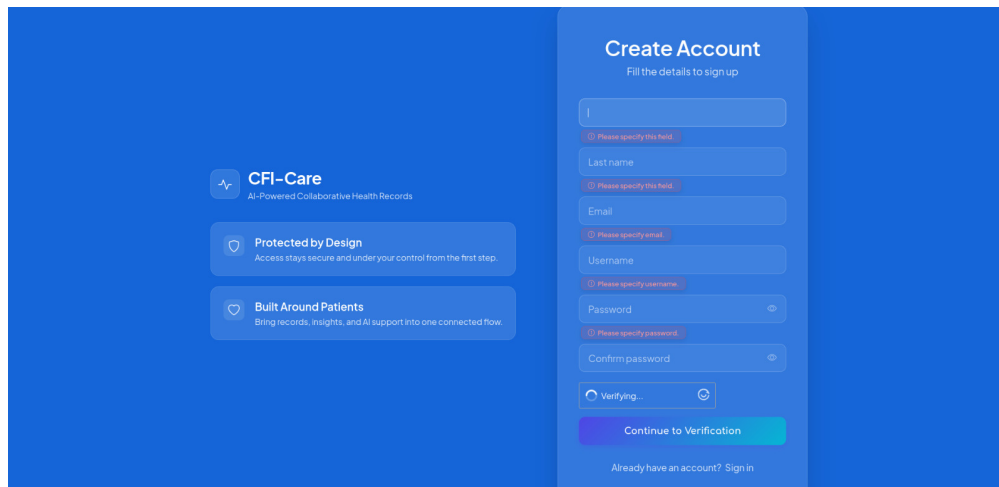


Figure 3.8: Registration form enforcing field completeness. The form cannot be submitted until all required fields are populated, preventing incomplete account creation.

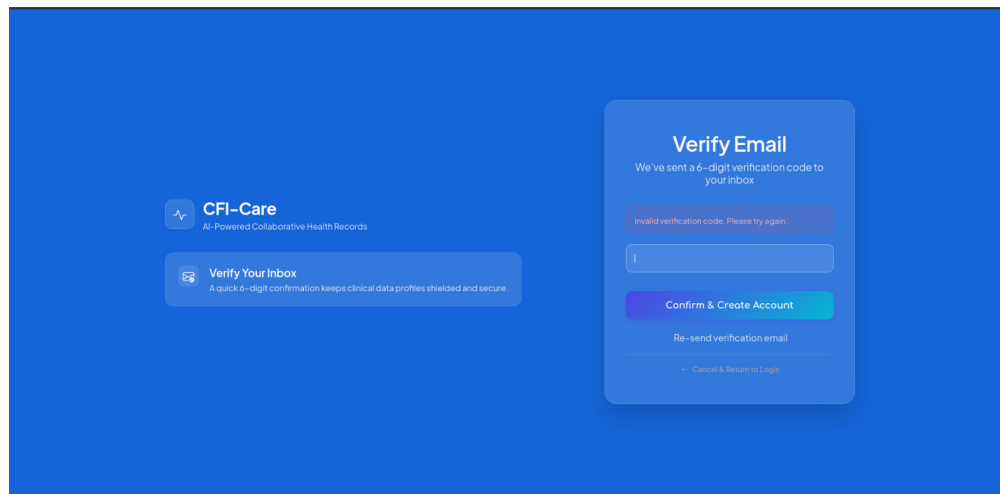


Figure 3.9: Email verification step requiring entry of a six-digit code sent to the clinician’s registered address, confirming ownership before account activation.

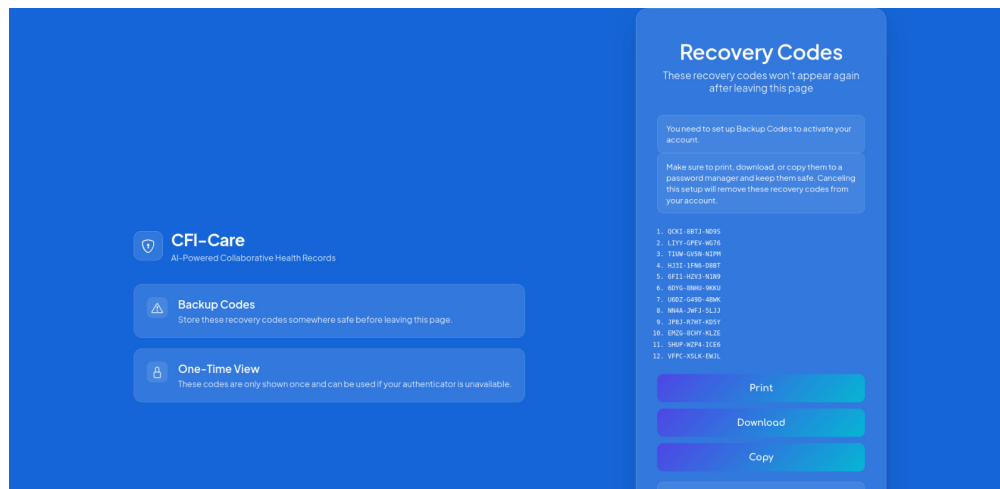


Figure 3.10: Recovery code generation screen presented at account activation. The clinician must copy or download the codes as a text file before proceeding, establishing a secure fallback authentication method.

For subsequent logins, the system provides two multi-factor authentication options: a time-based authenticator application (TOTP) or a recovery authentication code, as shown in Figure 3.11. Should a clinician need to recover access, a dedicated password reset flow is also available (Figure 3.12).

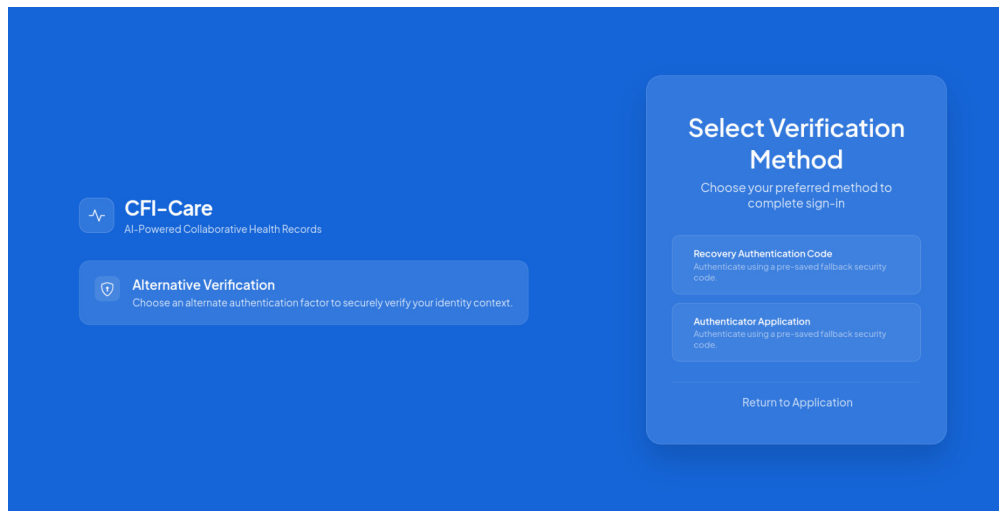


Figure 3.11: Multi-factor authentication method selection screen, offering the clinician a choice between a TOTP authenticator application and a recovery authentication code.

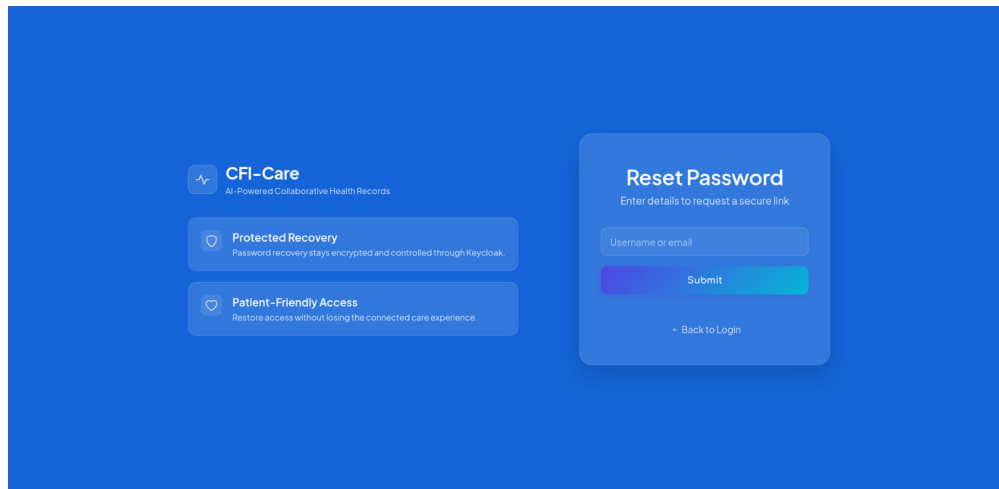


Figure 3.12: Password reset interface allowing clinicians to securely regain access to their account through a guided credential recovery flow.

Top Bar and Global Navigation

A persistent `TopBar` component is rendered across all authenticated views. It provides contextual navigation including a return link to the patient dashboard, access to the doctor's profile, account management options, and logout functionality. Within the `MedGraph` view specifically, the top bar includes a back-to-dashboard button rendered prominently to the left, ensuring the clinician is never more than one click from the patient list regardless of the depth of graph exploration.

The consistent presence of the top bar across all routes ensures spatial orientation is maintained throughout the application, following established guidelines for navigation in complex information systems.

3.5.6 Patients Dashboard

Overview

The Patients Dashboard, shown in Figure 3.13, functions as the primary data management hub of the system. It enables clinicians to search, select, and review patient profiles, manage episodes of care, and navigate to the patient journey visualisation. The dashboard is composed of three Angular components that operate in concert: `UsersPanel`, `Users`, and `UserInfo`.

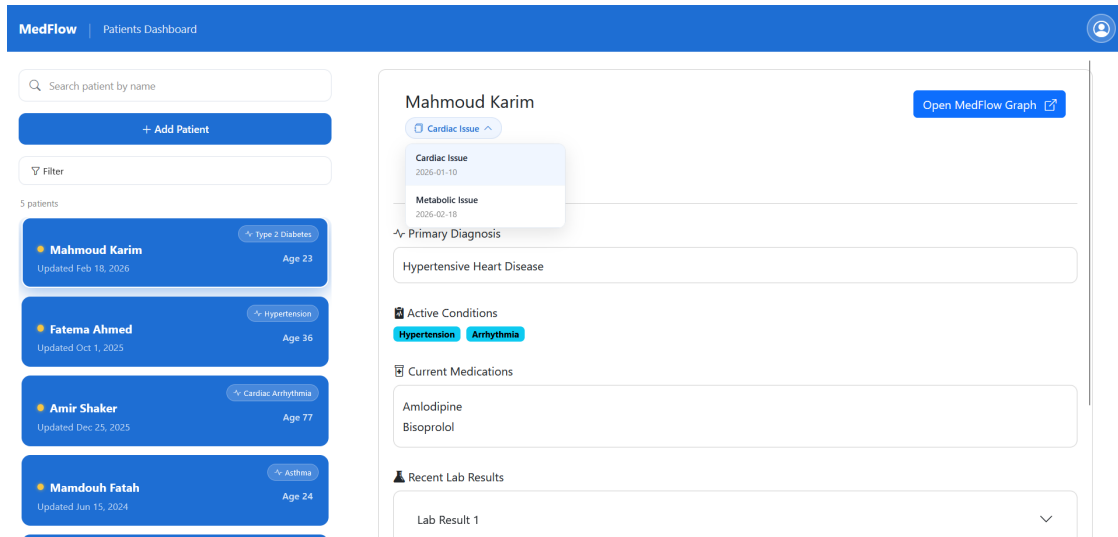


Figure 3.13: Patients Dashboard showing the master-detail layout. The left sidebar presents the patient navigator with search, filter, and episode management controls. The main panel displays the full clinical summary for the selected patient, including active conditions, medications, recent laboratory results, procedures, and a scoped encounter history.

Master-Detail Layout

The dashboard follows a master-detail layout, a design pattern widely adopted in medical information systems [90]. The layout consists of:

- **Patient Navigator (Left Sidebar):** Rendered by `UsersPanel`, this panel contains a search bar, a filter panel, an “Add Patient” action, and a scrollable list of patient cards rendered by the `Users` component.
- **Clinical Summary View (Main Panel):** Rendered by `UserInfo`, this panel displays structured patient information in a card-based layout, updating reactively when a new patient is selected.

Patient Navigator: Search, Filter, and Selection

The `UsersPanel` component implements a reactive search mechanism that filters the patient list in real time as the clinician types. A filter panel toggles open to expose additional controls for sorting (by name, age, ID, or last-updated timestamp) and filtering by age range. The `applyFilter` method recombines all active criteria into a single filtered list, and the filter panel closes automatically upon application. A reset action restores all defaults without requiring manual field clearing.

Each patient card in the `Users` component displays the patient’s name, age, and last-updated timestamp. A colour-coded status dot provides an immediate freshness indicator: green indicates the record was updated within the past 30 days, and yellow indicates a stale record. This status is computed by the `getStatus` method using a precise day-difference calculation, providing a passive clinical alert without requiring explicit user interrogation of individual records.

Patient selection is mediated entirely through the `SelectedPatientService`, an injectable Angular service that exposes a reactive `selectedPatientId$` observable. Both the `Users` component (which sets the selected ID on click) and the `UserInfo` component (which subscribes to trigger a detail load) communicate through this shared service without any direct parent-to-child binding, exemplifying a clean observable-based state management pattern [48].

Patient Access Grant Workflow (OTP Handshake)

A key usability and security feature of the patient navigator is the patient access grant workflow, accessible via the “Add Patient” button at the top of the navigator. This workflow allows a clinician to request access to a patient’s data through a time-limited, patient-initiated one-time password (OTP). The six-digit OTP input modal is shown in Figure 3.14.

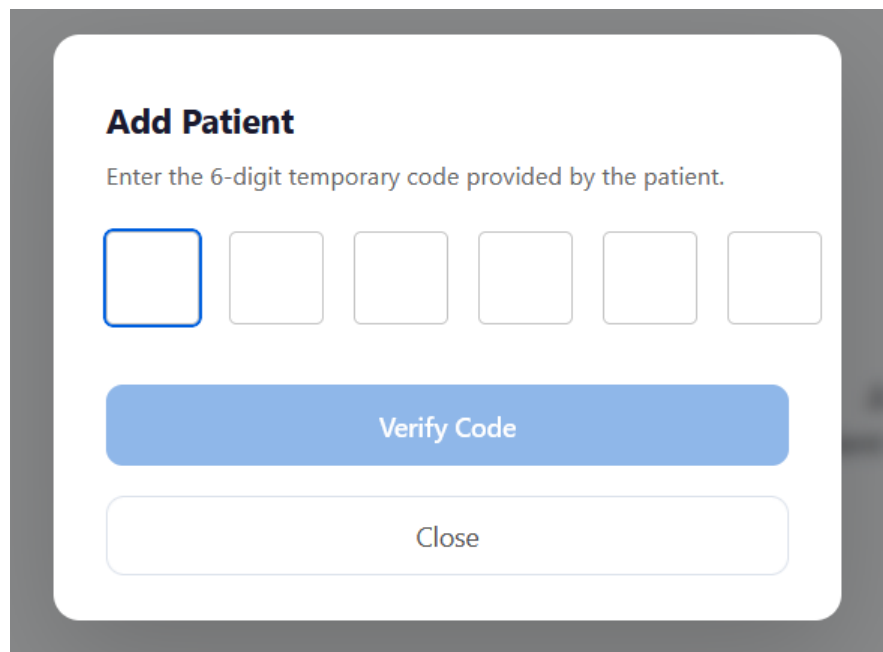
The image shows a modal dialog titled "Add Patient". Below the title is a subtitle: "Enter the 6-digit temporary code provided by the patient." Below this is a row of six square input boxes for the OTP. The first box is highlighted with a blue border. Below the input boxes is a blue button labeled "Verify Code". At the bottom of the modal is a light gray button labeled "Close".

Figure 3.14: Patient access grant modal presenting the six-cell OTP input field. The clinician enters the code generated on the patient’s device to initiate the access request handshake.

The process operates as follows:

1. The patient generates a six-digit OTP on their own device.
2. The clinician clicks “Add Patient” and a modal dialog opens presenting a six-cell OTP input field (powered by `ng-otp-input`) with confirm and cancel actions.
3. Upon submission, the frontend calls `handshake.verifyOtp()` and transitions to a “forwarded” state, displaying a confirmation that the request has been sent for the patient’s approval.
4. The component begins polling the backend via `handshake.pollStatus()` on a three-second interval, implemented using the RxJS `interval` and `switchMap` operators with `takeWhile` to automatically terminate polling when a terminal state is reached.
5. On patient approval, the modal transitions to a “success” state, the polling subscription is cleaned up, and the patient list refreshes to include the newly granted patient.
6. If the OTP is invalid, expired, or not found, distinct error states are rendered inline within the modal with specific, actionable messages.

This design keeps the entire workflow within a single modal without page reloads, minimising disruption to the clinician’s working context.

Clinical Summary View

The `UserInfo` component loads full patient details via a `forkJoin` of seven concurrent FHIR API calls, covering patient demographics, conditions, encounters, medications, procedures, document references, and episodes of care, ensuring that all data is fetched in parallel and the UI transitions to a loaded state only once all requests complete. The component maps raw FHIR resources to structured domain transfer objects using a set of dedicated transformation functions (`fhirPatientToDetailsDTO`, `fhirEOCToEpisode`, `extractConditionDisplay`, etc.), isolating FHIR-specific parsing logic from presentation concerns.

The clinical summary view organises data into clearly defined sections:

- Demographics: name, age, gender, and patient identifier.
- Primary diagnosis, active conditions with coloured pill badges, and current medications.
- Recent laboratory results with direct PDF viewing via inline `DocumentReference` binary resolution.
- Recent procedures.
- A full encounter history scoped to the selected episode, with each encounter typed and styled according to a comprehensive encounter type map spanning twelve clinical categories.

Episode of Care Management

The clinical summary panel includes an episode-of-care selector allowing the clinician to switch between multiple episodes for the same patient. The episode selector presents a dropdown of existing episodes, and each episode selection triggers a fresh encounter-scoped filter of conditions, medications, and procedures, ensuring that all displayed clinical data corresponds precisely to the chosen episode context.

New episodes can be created inline via a name input and a “+ Add Episode” button, which calls the FHIR `EpisodeOfCare` creation endpoint and immediately appends the result to the episode list. Fallback logic handles cases where FHIR filtering returns no data for a given episode, deriving medications from `Medication-type` encounters and diagnosing from `AI-Diagnosis-type` encounters as a secondary inference mechanism.

Patient-Scoped MedGraph Access

Rather than exposing the journey visualisation globally, access to the MedGraph is embedded within the patient details card. A prominent “Open History Graph” button navigates to `/med-graph/:id`, passing the currently selected episode’s ID as an `eocId` query parameter. This design ensures that any transition to the MedGraph view is explicitly scoped to the selected patient and episode, preventing context errors and reinforcing the principle that advanced visualisation actions should be clearly associated with their target data objects.

3.5.7 Patient Journey Dashboard

While traditional medical dashboards present patient data as isolated records, clinical decision-making often requires understanding how events evolve, relate, and unfold over time. To address this limitation, CFI-Care introduces the *Patient Journey Dashboard*, a dedicated interactive environment that provides a holistic, visual view of a patient's complete medical history.

The Patient Journey Dashboard enables clinicians to:

- Explore relationships between medical events through a hierarchical tree structure.
- Understand disease progression from initial presentation through to treatment and follow-up.
- Analyse alternative diagnostic or treatment pathways via independent branches.
- Identify clinically critical events at a glance without losing contextual awareness.
- Add, edit, and delete medical events in-place with full bidirectional backend synchronisation.

Rather than enforcing a single representation, the dashboard provides two complementary visualisation modes: *Categorical* and *Chronological*. Each mode offers a distinct analytical perspective over the same underlying patient data, allowing clinicians to switch between structural and temporal reasoning as needed.

Iframe Isolation Architecture

The graph engine is implemented as a self-contained HTML document loaded inside an iframe within the Angular **MedGraph** component. This isolation is a deliberate and well-reasoned architectural choice driven by three compounding concerns. First, D3.js and Treviz both perform direct, synchronous DOM mutations at high frequency during zoom, pan, and re-render cycles. Angular's Zone.js patches every asynchronous operation and triggers change detection on each one, so running D3 inside the Angular component tree would cause hundreds of unnecessary change-detection cycles per second during graph interaction, degrading performance meaningfully. Second, the iframe provides a complete DOM isolation boundary: the graph's global event listeners, CSS rules, and third-party library globals (D3 registers several of these) cannot leak into or conflict with the Angular host application. This goes beyond what `NgZone.runOutsideAngular()` would achieve, which suppresses Angular's change detection but still shares the same DOM, the same global CSS cascade, and the same JavaScript namespace. Third, full DOM isolation enables the visualisation layer to be developed, tested, and replaced independently, without destabilising the broader Angular application during iteration.

Communication between the Angular host and the iframe is implemented entirely via the `window.postMessage` API. The Angular host sends an `INIT_GRAPH` message on iframe load, carrying the full node list, patient ID, and episode of care ID. The iframe dispatches `NODE_UPDATE` messages for every add, edit, and delete operation,

which the Angular host intercepts and forwards to the corresponding backend API calls. Backend responses are relayed back to the iframe as `NODE_SAVED` or `NODE_ERROR` messages, enabling optimistic UI updates with rollback on failure. Figure 3.25 illustrates this message-passing sequence in full, and Figure 3.27 illustrates the complete data flow from user interaction through to backend persistence and rollback.

Node Data Model

Each node in the patient journey graph carries the following fields:

- **id**: Unique identifier (temporary client-side ID prefixed `temp-` until the backend assigns a persistent UUID).
- **text_1**: Display title of the medical event.
- **father**: Parent node ID (`null` for the root node).
- **category**: One of nine clinical categories, each mapped to a distinct colour.
- **priority**: Low, Medium, or High.
- **normality**: Normal, Abnormal, or Pending.
- **dateIssued**: ISO date string.
- **details**: Free-text clinical notes.
- **isDiagnosis** / **isManualBranch**: Flags marking branch-starter nodes in the chronological view.
- **branchState**: In-progress, discontinued, or completed, governing branch rendering and interaction permissions.

Global Controls and Interaction Modes

The graph header provides a consistent set of controls applicable to both views:

- **Add Node**: Activates a crosshair cursor and highlights all selectable nodes with a green ring. Clicking any node opens a modal form to specify the child event's title, date, category, priority, normality, and details. The new node is added optimistically to the data array and rendered immediately; the backend is notified asynchronously and the temporary ID is replaced with the real UUID upon confirmation.
- **Delete Node**: Activates a “not-allowed” cursor and highlights deletable nodes with a red ring. Selecting a node triggers a confirmation dialog and recursively removes the target node and all its descendants. If the backend delete fails, all removed nodes are restored from a `pendingDeletes` map.

- **Filters:** Toggles a filter panel allowing refinement by category, priority, normality, and date range. Filtering is applied reactively to both views with parent-node inclusion logic ensuring that matching nodes are never orphaned from the tree.
- **View Toggle:** Switches between Categorical and Chronological modes without page reload, preserving all filter and expansion state.

Guard logic prevents modifications within discontinued branches, completed branches, or a finished case, surfacing contextual toast messages that explain the restriction and describe how to lift it.

3.5.8 Patient Journey Dashboard — Categorical View

Purpose and Conceptual Model

The categorical view presents the patient journey as a hierarchical, relationship-oriented structure. Its primary purpose is to visualise **clinical relationships, causality, and dependency** between medical events. In this mode clinicians can clearly observe how diagnostic steps lead to subsequent decisions, which medical events are logically connected, and complete clinical paths from disease onset to treatment.

Hierarchical Graph Representation

Medical events are rendered as nodes within a directed node-link graph, laid out left-to-right using the Treviz library. A single root node represents the patient case origin, from which first-level category branches emerge. When more than one root node exists in the data, for example when a patient has multiple concurrent care pathways, the system automatically inserts a hidden virtual root node to produce a single connected tree, ensuring Treviz always receives a valid hierarchy without requiring manual data normalisation.

Expand and Collapse Semantics

First-level nodes directly connected to the root carry a small expand/collapse trigger button rendered in the top-right corner of their dot. Clicking this button expands or collapses the entire sub-tree rooted at that node, including all deeper descendants via the recursive `addAllDescendants` and `removeAllDescendants` functions. To contain visual complexity, a maximum of two first-level branches may be expanded simultaneously; activating a third branch automatically collapses the oldest expanded branch. This constraint preserves a coherent visual field without preventing access to any part of the tree.

High-Priority Propagation Mechanism

Clinically critical events are visually marked with an animated pulsing red ring rendered via a CSS `@keyframes pulse` animation. When a high-priority node exists within a collapsed branch, the priority indicator propagates upward to the corresponding first-level parent node. This ensures that urgent information is never visually hidden from a collapsed state. Upon expansion, the indicator is removed from the parent and appears solely on the originating node, preserving both visibility and clinical accuracy [88].

Node Relationship Indicators

Each non-root node carries a coloured sibling badge indicating whether it is the sole child of its parent (“SINGLE”, rendered in green) or one of multiple siblings (“SIBLING”, rendered in blue). These indicators allow clinicians to infer structural branching without expanding the full hierarchy, supporting rapid structural scanning.

Node Detail Sidebar

Clicking any node opens a slide-in detail sidebar on the right of the canvas, displaying the node’s title, normality status tag, priority tag, date, category with colour swatch, and full clinical detail text. The sidebar includes an “Edit Node” button that opens a draggable, resizable floating form prepopulated with the node’s current values. All edit operations are subject to the same branch-state guard logic as add and delete operations. The form itself is draggable via a `mousedown`-based drag handler and resizable via CSS `resize: both`, giving clinicians flexible screen real estate management during data entry.

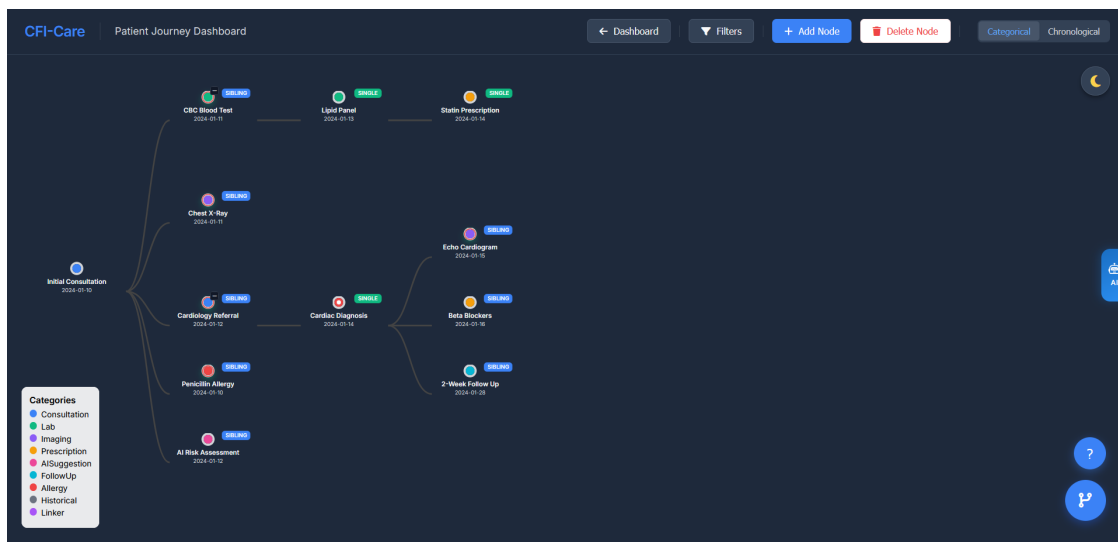


Figure 3.15: Categorical Patient Journey view representing medical events as a hierarchical left-to-right graph. High-priority events display animated priority rings, sibling relationships are labelled on each node, and the detail sidebar is visible on the right.

3.5.9 Patient Journey Dashboard — Chronological View

Purpose and Conceptual Model

The chronological view reorganises the same patient data into a time-oriented representation rendered using D3.js. Its purpose is to support **temporal reasoning** by allowing clinicians to read the patient journey as a sequential narrative. Unlike the categorical view, which emphasises relationships, the chronological view emphasises event order, time intervals between clinical decisions, and the progression of care across time [90].

Temporal Layout and Event Stacking

Events are distributed along a horizontal timeline scaled by a configurable `DATE_SCALE` constant, ensuring even temporal spacing regardless of event density. Each unique date is marked with a vertical tick and label rendered by the `drawDateMarkers` function. When multiple events occur on the same date within the same lane, they are stacked vertically using an alternating offset algorithm that places successive same-date nodes above and below the lane centreline, preventing overlap while preserving temporal accuracy.

The entire canvas supports pan and zoom via D3’s `zoom` behaviour, with a configurable scale range of $0.05\times$ to $3\times$. An automatic fit-to-view transform is computed and applied immediately after each render, ensuring the full timeline is visible on first load regardless of data density.

Branching Mechanism for Clinical Reasoning

A key feature of the chronological view is its branching mechanism. The main timeline represents the primary clinical pathway. When diagnostic uncertainty arises or alternative treatment strategies must be explored, clinicians can create independent sub-branches by activating the **branch creation button** (a blue code-branch icon in the bottom-right corner) and clicking any main-timeline node. This action opens the node creation form with the category preset to “Diagnosis”, and the resulting node is flagged with `isDiagnosis: true` and `isManualBranch: true`.

Sub-branches are rendered as distinct horizontal tracks below the main timeline, connected to their origin on the main line via smooth cubic Bézier divergence paths drawn by the `generateLinkPath` function. Each branch maintains its own horizontal baseline drawn at a fixed vertical offset determined by `BRANCH_VERTICAL_GAP`, ensuring consistent visual separation between parallel clinical reasoning paths.

Branching from an existing branch is explicitly prohibited; a contextual toast message is displayed if this is attempted, guiding the user to branch only from main-timeline nodes. This constraint reflects the clinical model that sub-branches represent direct hypotheses against the main care pathway.

Branch State Management

Every branch carries a **branch state** that governs its visual presentation and edit permissions:

- **In Progress** (blue): The branch is active. Nodes may be added, edited, and deleted freely.
- **Discontinued** (red): The branch has been ruled out. A prominent “DISCONTINUED” wall marker and pulsing wall animation are rendered at the branch terminus. All add, edit, and delete operations within the branch are blocked with an explanatory message. Figure 3.18 shows a zoomed view of a discontinued branch.
- **Completed** (green): The branch has been validated and merged back into the main timeline. A green curved merge arc is drawn from the branch’s last node to the nearest main-timeline node, and a “MERGED” label is rendered above the arc. If the branch’s last event post-dates all main-timeline events, the system automatically creates a *Linker* node on the main timeline at that date to serve as the merge target, ensuring geometric accuracy of the arc. Figure 3.17 shows a zoomed view of a completed and merged branch.

Branch state is changed by clicking the branch line itself to open a state-selection menu. The main timeline also carries a state that can be set to **Finish Case**, which renders a “CASE CLOSED” flag at the timeline terminus, displays a “Case Finished” banner in the header, and blocks all modifications to the entire graph until the case is reopened.

High-Priority Visualisation

High-priority events in the chronological view are highlighted using a red “HIGH PRIORITY” label rendered beneath the node’s date stamp. This visual hierarchy ensures that urgent clinical issues remain immediately noticeable within the temporal flow regardless of zoom level.

Stateful Mode Switching

A toggle control in the header allows instant switching between categorical and chronological views. This interaction is fully stateful: all filter selections, expansion state, and data mutations carry over seamlessly between modes. No page reload is required, and the `refreshGraph` function pointer is reassigned to the appropriate renderer on each mode switch, ensuring that subsequent filter changes or node operations automatically re-render in the correct mode.



Figure 3.16: Chronological Patient Journey view displaying medical events along a horizontal D3.js timeline with pan and zoom. Parallel sub-branches represent alternative diagnostic hypotheses, each on its own horizontal track. The completed branch is merged back into the main timeline via a green arc, and the discontinued branch is blocked with a red wall marker. A “CASE CLOSED” flag is rendered at the timeline terminus when the main timeline is set to the Finished state.

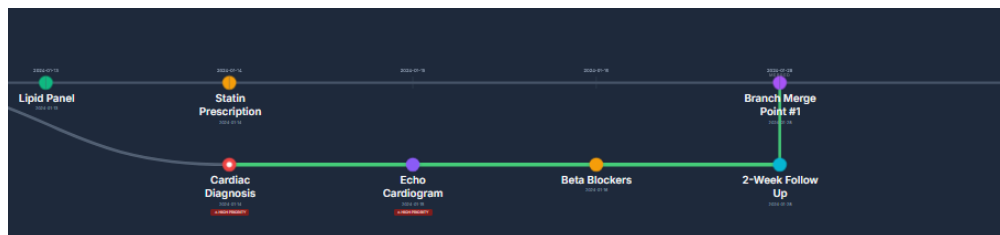


Figure 3.17: Zoomed view of a completed branch in the chronological timeline. The green curved merge arc connects the branch’s final node back to the main timeline, with a “MERGED” label rendered above the arc. The branch line is rendered in green to indicate the validated state.

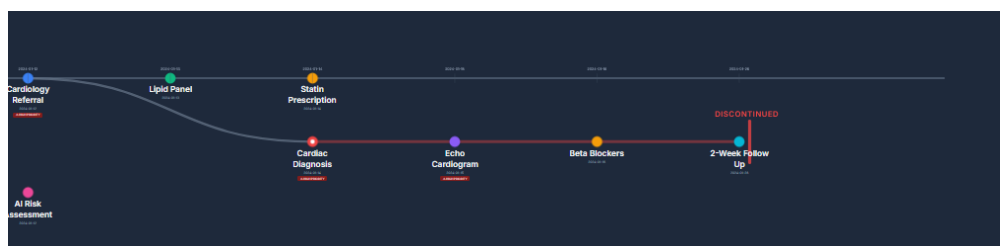


Figure 3.18: Zoomed view of a discontinued branch in the chronological timeline. A pulsing red wall marker is rendered at the branch terminus with a “DISCONTINUED” label. The branch line is rendered in red, and all add, edit, and delete operations on nodes within this branch are blocked.

3.5.10 Complementary Roles of the Two Views

The categorical and chronological views address fundamentally different cognitive tasks. The categorical view focuses on **structural understanding**, enabling clinicians to reason about relationships, dependencies, and complete clinical paths. The chronological view focuses on **temporal understanding**, enabling clinicians to interpret the sequence and timing of events and to visualise parallel reasoning paths.

Providing both views allows clinicians to:

- Understand how events are connected (categorical).
- Understand when events occurred and how the case evolved (chronological).
- Reduce cognitive load by selecting the most appropriate representation for the current analytical task.

This dual-view approach follows established guidelines for multiple coordinated visualisations, which have been shown to improve usability and analytical effectiveness in complex information systems [88].

3.5.11 Interactive Tutorial System

A built-in interactive tutorial system guides new users through every major feature of the Patient Journey Dashboard on first login. The tutorial operates in two modes:

1. **Welcome Prompt:** On first visit (controlled via a `localStorage` flag), a modal dialog appears offering the clinician the choice to begin the tour immediately or skip it.
2. **Step-by-Step Tour:** The tutorial progresses through eighteen distinct steps covering categorical nodes, priority propagation, expand/collapse interaction, the node detail sidebar, add and delete modes, filters, the dashboard navigation button, chronological layout, diagnosis nodes, sub-branch tracks, the branch creation button, the completed-and-merged arc, the merge hint button, and both the main and sub-branch state menus.

Each step highlights the relevant UI element using a CSS outline pulse animation. Steps that require a direct user interaction (such as clicking the expand trigger, clicking a node, switching to chronological mode, or opening a branch state menu) display a “**Interact to continue**” badge in place of the Next button, and the tutorial advances automatically once the interaction is detected via targeted DOM event listeners.

To ensure the tutorial demonstrates the full feature set without depending on the live patient data, the system silently saves the clinician’s real data array, substitutes a rich pre-defined demo dataset covering all categories, branch types, and states, and restores the real data array when the tour ends or is dismissed. A help button (?) in the fixed bottom-right corner allows the tutorial to be replayed at any time.

Figure 3.19 illustrates tutorial Step 4, which introduces branch expansion. First-level nodes are shown in their collapsed default state, with each node carrying its SIBLING badge and a highlighted + button in the top-right corner of its dot. The tutorial card instructs the clinician to click the highlighted button to expand a branch, and the step advances automatically once the interaction is detected. Figure 3.20 shows Step 10, which guides the clinician to switch from the categorical view to the chronological timeline using the toggle control highlighted in the header. The step advances automatically when the toggle is activated, exposing the D3.js timeline without requiring a manual “Next” click. Figure 3.21 demonstrates Step 16, in which the clinician is instructed to click the main horizontal timeline line to open its branch state menu. The menu presents two options: In Progress (the current default) and Finish Case. The step is classified as an interaction step, so the tutorial waits for the clinician to open the menu before advancing, ensuring they observe the state-change mechanism in context.

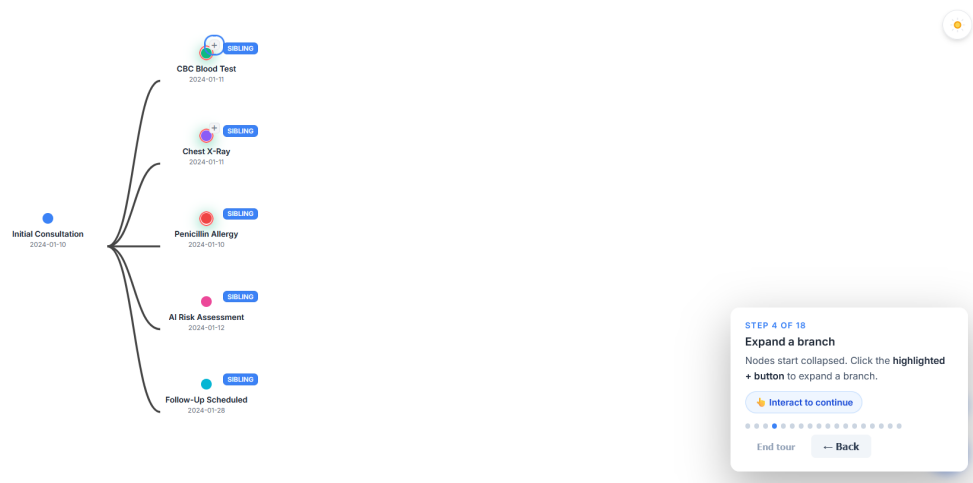


Figure 3.19: Tutorial Step 4 of 18: Expand a branch. The categorical view shows first-level nodes in their collapsed default state. The + button on the CBC Blood Test node is highlighted with a pulse animation, and the tutorial card instructs the clinician to click it to expand the sub-tree. The step advances automatically upon interaction.

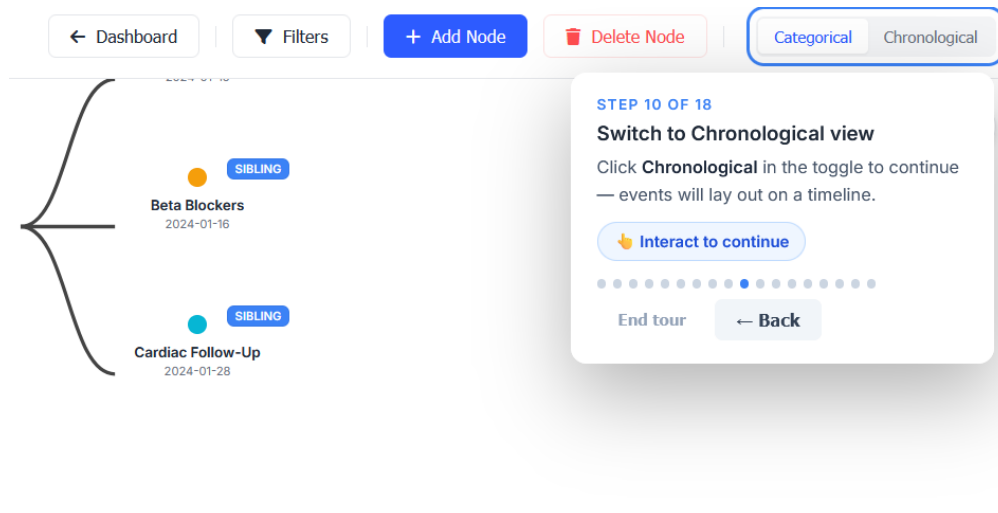


Figure 3.20: Tutorial Step 10 of 18: Switch to Chronological view. The view toggle in the header is highlighted, and the tutorial card instructs the clinician to click “Chronological” to transition the layout from the hierarchical tree to the D3.js timeline. The step advances automatically once the toggle is activated.

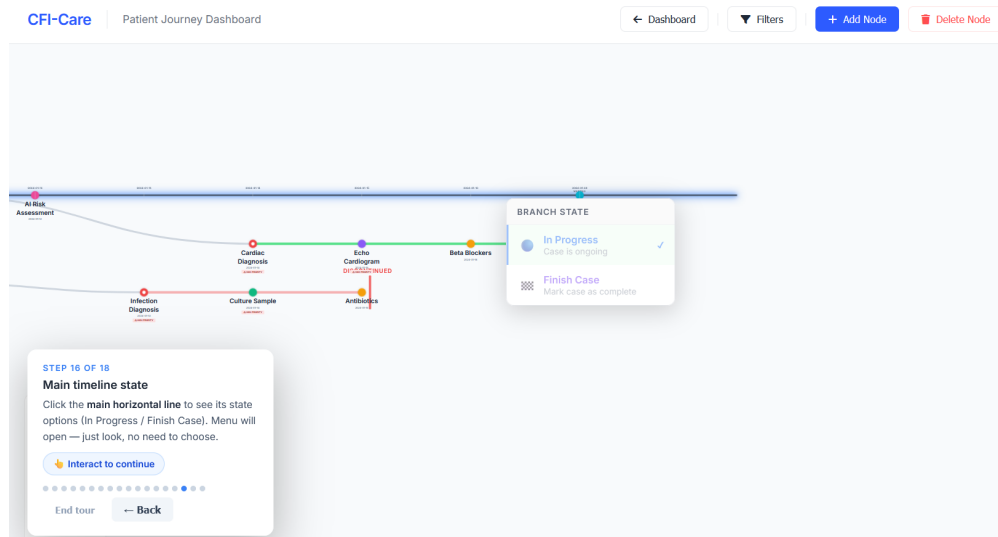


Figure 3.21: Tutorial Step 16 of 18: Main timeline state. The chronological view is shown with the branch state menu open on the main timeline line, presenting the In Progress and Finish Case options. The tutorial card instructs the clinician to click the main timeline to open this menu, advancing automatically once the interaction occurs.

3.5.12 AI-Assisted Clinical Chat

The `ChatSection` component provides an integrated AI chat interface accessible from within the MedGraph view, supporting real-time clinical reasoning alongside patient journey data. The component is designed for sustained, multi-turn clinical dialogue and incorporates a range of usability features tailored to medical workflows.

Conversation and Session Management

The chat interface maintains a list of named conversation sessions. A “New Chat” action saves the current session’s messages and initialises a blank session. Switching between sessions restores the full message history for the selected session. Sessions are auto-titled from the first user message (truncated to 27 characters for display), and titles can be manually edited inline via a double-click interaction on the session list item.

A search field filters the session list in real time, matching sessions by title prefix.

Message Composition and Input Controls

The message composer features a self-expanding textarea that grows vertically up to a maximum of 180 pixels as the user types, implemented via the `autoResize` event handler. File attachments (images and PDFs) can be added via a file picker; attached files are base64-encoded and displayed as inline previews in the outgoing message bubble, with individual removal controls. A voice input button activates the Web Speech API (`webkitSpeechRecognition`) for continuous speech-to-text input with real-time interim transcript display.

Response Mode Selection

Four response modes, Concise, Detailed, Bullet Points, and Differential, allow the clinician to specify the desired output format for AI responses, adapting the interface to different clinical contexts such as rapid triage versus comprehensive case review.

Message-Level Interactions

Each AI response bubble exposes a set of interaction controls:

- **Like / Dislike:** Binary feedback toggles allowing the clinician to rate response quality.
- **Copy:** Copies the full response text to the clipboard.
- **Retry:** Replaces the AI response in-place with a new generation, preserving conversation position.
- **Fork:** Opens a new browser tab pre-loaded with a snapshot of the conversation up to and including the selected response, encoded in URL parameters, allowing independent exploration of alternative follow-up threads from any prior point.
- **Delete:** Removes the AI response and its corresponding user message from the session.
- **Citations:** Opens an inline citations panel listing the reference sources associated with the AI response.

A confidence score is displayed with each AI response, giving the clinician a visible signal of response certainty.

Maximised View and Branch Tabs

The chat panel supports a maximised mode that expands the component to fill the available viewport, providing a focused environment for extended clinical dialogue. Sessions opened via the Fork action automatically launch in maximised mode and display a visual divider message indicating the branch origin session and message index, preserving chain-of-custody of the conversation thread.

Figure 3.22 shows the chat interface in its compact panel form, as it appears alongside the patient journey graph. Figure 3.23 shows the same interface in its maximised mode, expanding to fill the viewport for extended clinical dialogue.

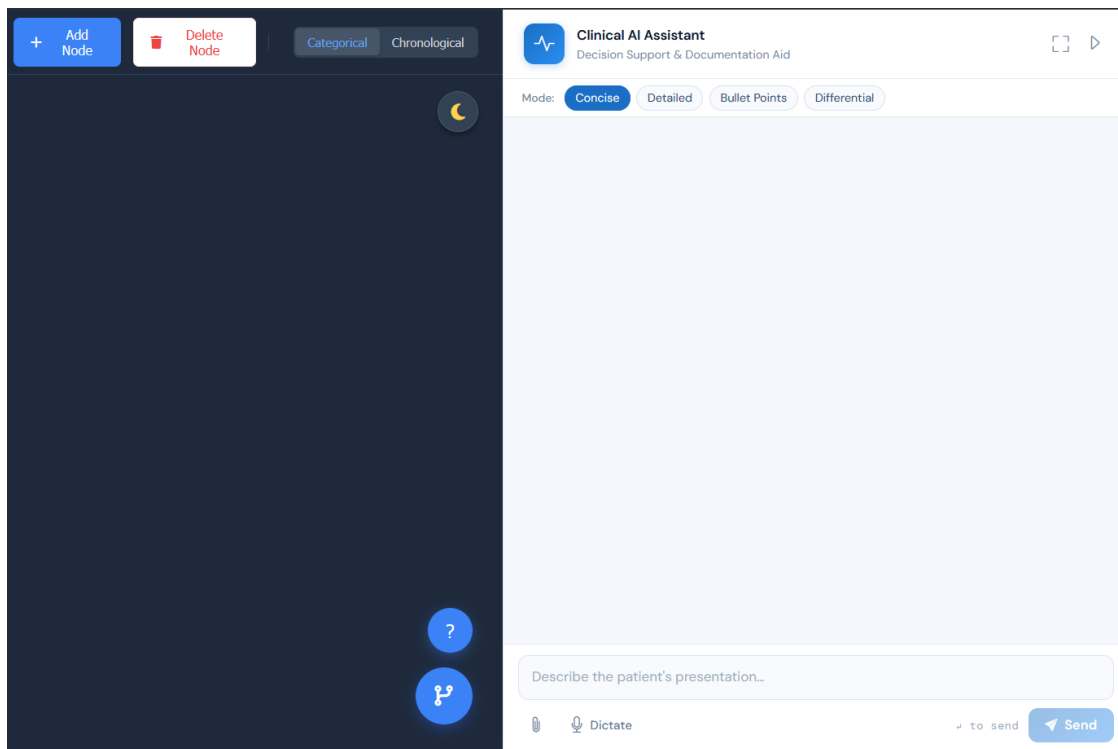


Figure 3.22: AI-assisted clinical chat in its compact panel view, rendered alongside the Patient Journey Dashboard. The session list, message history, response mode selector, and composer are all visible within the panel.

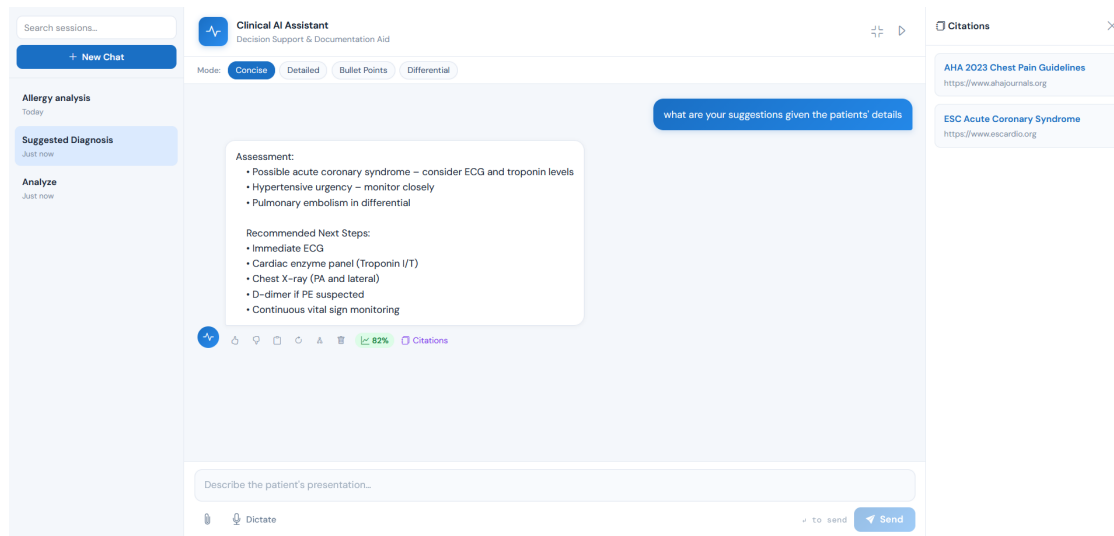


Figure 3.23: AI-assisted clinical chat in maximised mode, expanding to fill the full viewport. This mode is intended for extended clinical reasoning sessions and is also the default view for conversations opened via the Fork action.

3.5.13 Doctor Profile and Schedule Management

The `DoctorProfileComponent`, shown in Figure 3.24, provides each practitioner with a dedicated profile and availability management interface, structured as a two-panel layout.

Profile Panel

The left panel displays the practitioner’s initials avatar, name, title, specialty, contact details (phone and address), affiliated hospitals, and an “Active & Verified” status badge. An “Edit Profile” button at the bottom of the panel opens a modal dialog pre-populated with the current profile values, allowing inline editing of all fields. Hospital affiliations can be added and removed individually within the modal. On save, the component performs parallel FHIR updates to both the `Practitioner` resource and the `PractitionerRole` resource, with the role update preserving all existing FHIR metadata.

Schedule Manager

The right panel hosts the Schedule Manager, which presents schedules and slots in two separate tabular sections. A “Today’s Summary” sidebar on the far right provides an at-a-glance count of total slots broken down by status. A Glossary section beneath the summary defines the three slot states (Free, Busy, Unavailable) in plain language, reducing the need for external documentation.

Schedules represent planning horizons (date ranges during which the practitioner is available). New schedules are created via a collapsible form, and existing schedules can be edited in-place via an inline edit row or deleted with a confirmation guard. Each

schedule creation validates that the start date precedes the end date, surfacing inline error messages on failure.

Slots are bookable time units within a schedule. The slot creation form validates that the selected time range falls within the bounds of the chosen schedule, preventing orphaned slot creation. Slot statuses (Free, Busy, Unavailable) can be updated individually via an inline dropdown that persists the change to the backend immediately. A set of filter buttons (All / Free / Busy / Unavailable) controls which slots are displayed in the table, with counters for each status category visible in the summary panel.

The screenshot displays the 'Doctor Profile' page for Dr. Youssef, a Senior Cardiologist. The left sidebar contains contact details (phone: +20 1103686808, address: Cairo, Building C - Floor 3) and specialty (Interventional Cardiology). The main area is the 'Schedule Manager', which includes a 'Schedules' table with two entries (SCH-001 and SCH-002) and a 'Slots' table with three entries (SLT-001, SLT-002, SLT-003). The 'Slots' table shows status filters (All, Free, Busy, Unavailable) and a 'Create Slot' button. A 'Today's Summary' sidebar on the right shows 3 total slots (2 Free, 1 Busy, 0 Unavailable) and 2 schedules.

ID	ACTIVE	START	END
SCH-001	Yes	01 Apr. 08:00	30 Apr. 18:00
SCH-002	Yes	15 Apr. 09:00	20 Apr. 17:00

ID	SCHEDULE	STATUS	START	END
SLT-001	SCH-001	Free	25 Apr. 09:00	25 Apr. 09:30
SLT-002	SCH-001	Busy	25 Apr. 09:30	25 Apr. 10:00
SLT-003	SCH-002	Free	25 Apr. 10:00	25 Apr. 10:30

Figure 3.24: Doctor Profile page showing the practitioner information panel on the left and the Schedule Manager on the right, with slot creation form, status filters, and a today's summary sidebar.

3.5.14 Domain Models and State Services

Shared domain concepts are defined in the `models` directory. The `patient.model.ts` file formalises the patient entity, covering identifiers, metadata, episodes, encounters, and associated medical events, and provides all FHIR-to-DTO transformation functions as pure, stateless utilities.

Application-wide state is managed via injectable Angular services:

- **PatientApiService:** Responsible for all patient-related API communication, including FHIR resource retrieval, graph node operations, and binary resource resolution for lab PDF viewing.
- **SelectedPatientService:** Maintains the currently active patient context as a BehaviourSubject, enabling any component in the tree to subscribe to patient selection events without tight coupling.
- **HandshakeService:** Encapsulates the OTP verification and grant status polling API calls.

- **AppointmentService**: Manages all schedule and slot CRUD operations.
- **AuthService**: Wraps the Keycloak authentication status check used by both the auth guard and the doctor profile loader.

By centralising patient selection and API communication in services, multiple components can synchronise reactively without direct dependencies, reducing tight coupling and improving testability [48].

3.5.15 Error Handling and Resilience

The frontend implements a layered error-handling strategy. At the route level, a dedicated **GatewayErrorComponent** handles arbitrary HTTP error codes received as route parameters, rendering a contextual error page without exposing raw stack traces.

At the component level, all API subscriptions include **error** handlers that set typed error state variables rendered as user-facing messages. The MedGraph’s optimistic update pattern provides full rollback for all three node operation types: added nodes with temporary IDs are spliced from the data array on failure; edited nodes are restored from a **pendingEdits** snapshot map; deleted node trees are fully restored from a **pendingDeletes** collection. This ensures the visual state of the graph remains consistent with the backend at all times, even under intermittent network conditions.

3.5.16 Sequence Diagram

Figure 3.25 illustrates the complete message-passing sequence for MedGraph node operations, encompassing the iframe initialisation handshake, optimistic add/edit/delete operations, backend confirmation and rollback paths, and mode switching between categorical and chronological views.

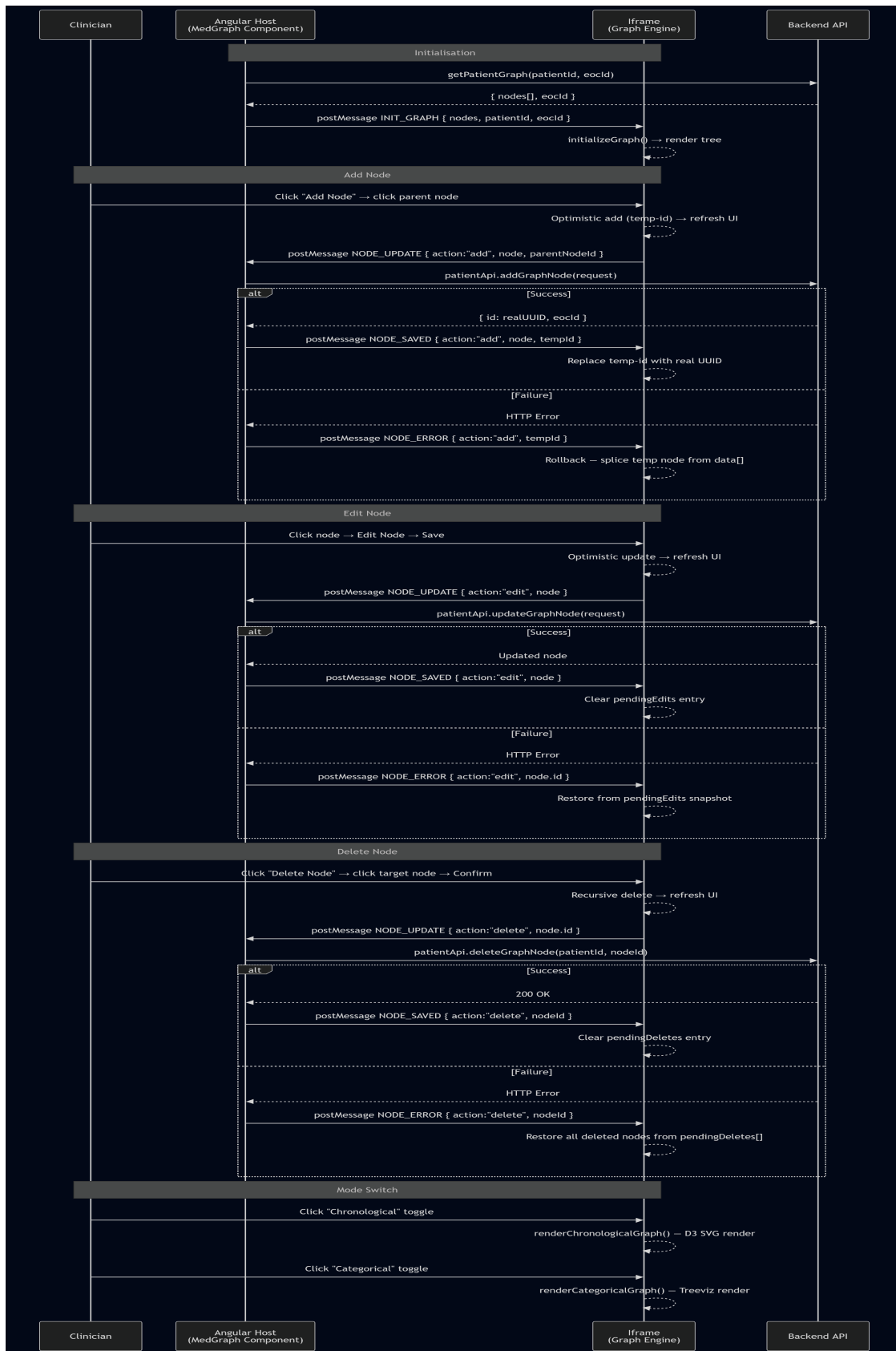


Figure 3.25: Sequence diagram illustrating the full MedGraph interaction lifecycle: iframe initialisation, postMessage-based node operations, backend confirmation, optimistic rollback on failure, and stateful mode switching.

3.5.17 Component Diagram

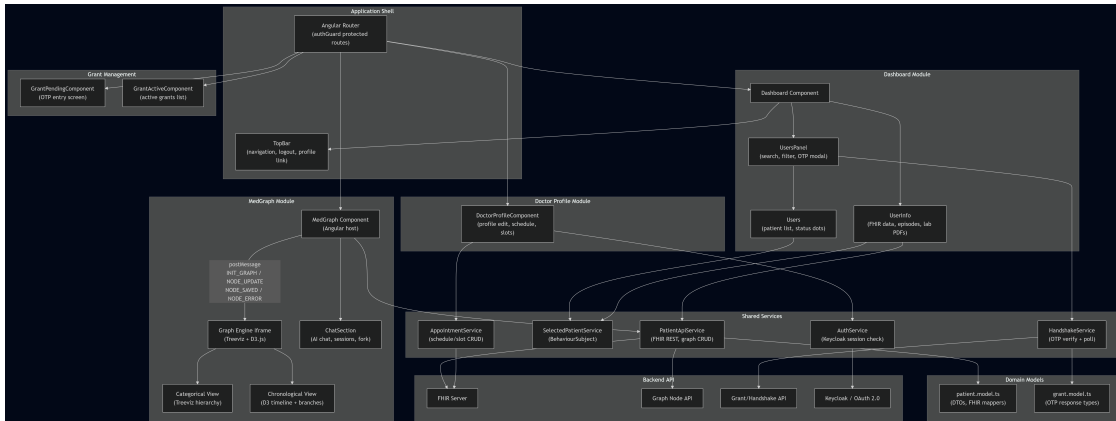


Figure 3.26: Component diagram illustrating the architecture of the dashboard, Med-Graph iframe boundary, AI chat module, application services, and backend integration points.

3.5.18 Data Flow Diagram

Figure 3.27 illustrates the complete data flow for a node CRUD operation, tracing the path from a user interaction inside the graph engine, through the `postMessage` boundary, into the Angular service layer, out to the FHIR backend, and back through the confirmation and rollback paths. This diagram complements the sequence diagram by focusing on data movement and state transitions rather than timing.

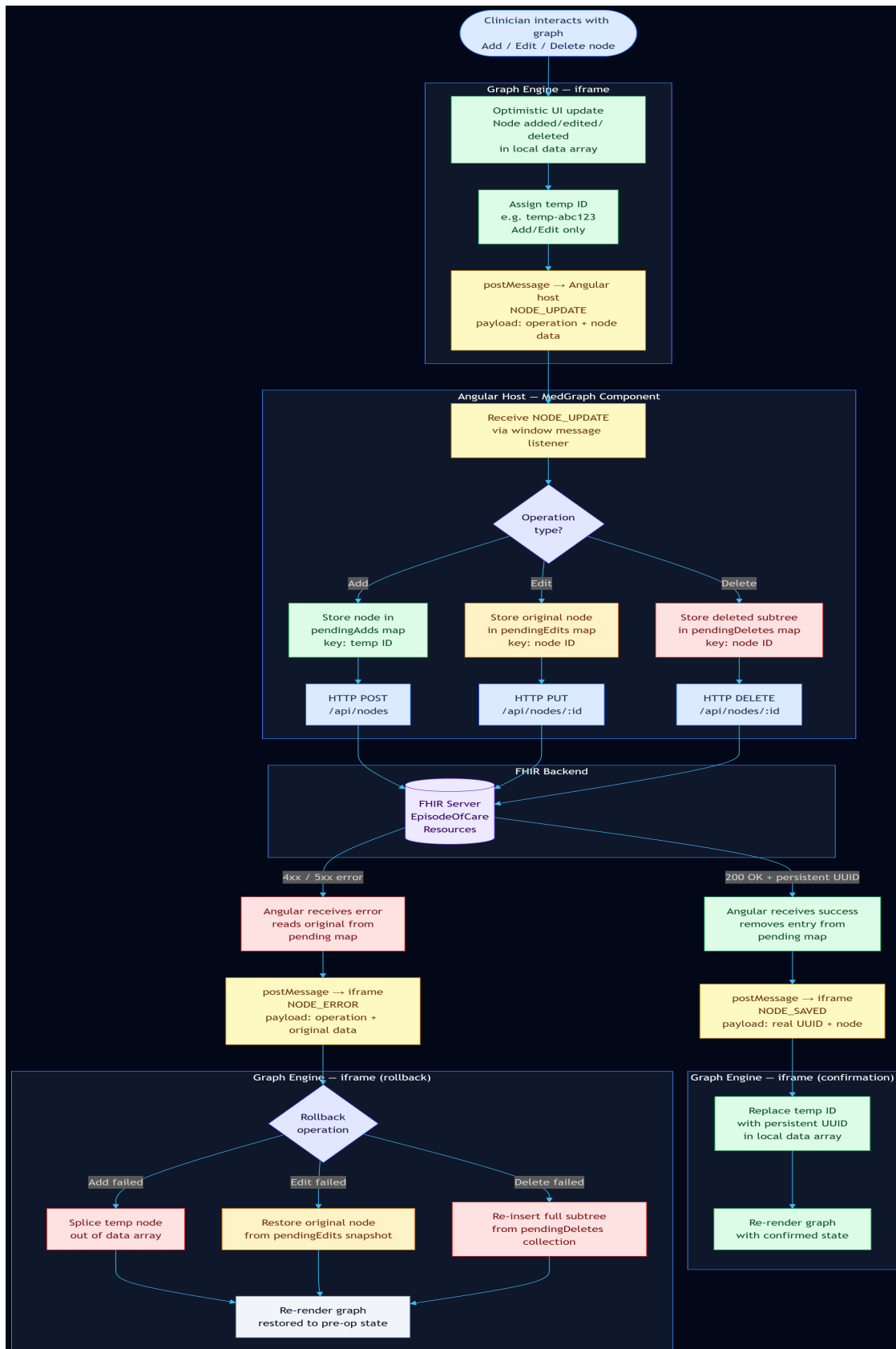


Figure 3.27: Data flow diagram for a MedGraph node CRUD operation. The flow begins with a user interaction in the graph engine (iframe), passes through the postMessage boundary into the Angular host, is forwarded to the FHIR backend, and returns via a confirmation or error path. On success, the temporary node ID is replaced with the persistent UUID. On failure, the pending operation is rolled back from the corresponding state map.

3.5.19 Architectural Rationale

The architectural decisions underlying the CFI-Care frontend were driven by four primary constraints:

1. **Visualisation Complexity:** Medical journey graphs require custom SVG layouts, zoom behaviours, and stateful interaction patterns that are not supported by standard Angular UI libraries.
2. **Performance:** D3.js performs intensive DOM mutations that would trigger excessive Angular change-detection cycles if executed within the component tree.
3. **Maintainability:** Clinical logic, routing logic, FHIR transformation logic, and graph rendering logic must evolve independently without cross-cutting refactoring.
4. **Data Integrity:** Optimistic updates require a principled rollback strategy at every operation type to prevent UI state from diverging from persisted backend state.

The iframe isolation boundary directly addresses constraints 1 and 2. The service layer and domain model separation address constraint 3. The `pendingEdits` and `pendingDeletes` maps address constraint 4. Together, these decisions produce a system that is both clinically capable and structurally sound for continued development [92].

3.5.20 Graph Logic Test Suite

To validate the correctness and robustness of the graph engine’s JavaScript logic, a dedicated browser-based test suite was developed for the CFI-Care patient journey graph. The suite targets the pure JavaScript functions that govern the graph’s data model and rendering pipeline, testing them directly in isolation from the graph’s visual layer. This approach ensures that the core clinical logic, including node hierarchy management, branch state transitions, chronological sorting, filter evaluation, and recursive tree operations, is verified independently and reproducibly.

Test Architecture

Rather than loading the full graph interface during testing, the suite reconstructs a controlled mock environment in JavaScript that mirrors the graph’s internal data structures and pure functions exactly. This allows every test to run deterministically in the browser without network dependencies, iframe loading times, or DOM rendering variability. The mock environment reproduces the twelve-node baseline dataset used throughout the system, covering all nine clinical categories, all three priority levels, all three normality values, and a representative branch with in-progress state.

Test Suites and Coverage

The suite is organised into five suites totalling 62 test cases, all of which pass with zero failures and zero warnings, completing in 22ms total. The five suites and their scope are as follows.

Functional Tests (21 cases) validate the core data model and node operations. Tests verify that the dataset maintains a single root node with a `null` father, that all non-root nodes reference existing parents, that no circular parent references exist, and that all required fields are present and valid. Node operations are tested end-to-end: adding a node confirms the correct parent-child relationship is established; deleting a node via `deleteRecursive` confirms the target is removed and all descendants are removed recursively, while siblings are preserved. Branch logic tests confirm that `isNodeInRejectedBranch` and `isNodeInCompletedBranch` correctly traverse the ancestor chain for both discontinued and completed branch states, and that linker node detection operates on both the `category` field and the `_linkedBranchId` flag.

Chronological View Tests (15 cases) validate the `getChronologicalData` function that drives the D3.js timeline. Tests confirm that the full dataset passes through with default filters, that output nodes are sorted in non-decreasing date order, that main-timeline nodes receive `laneId = 0` and branch nodes receive `laneId > 0`, and that all members of a branch share the correct `branchStartId`. Filter correctness is verified across all three dimensions (category, priority, normality) individually, as well as date-range filtering and `isDiagnosis` suppression. Mutation tests confirm that newly added nodes appear in output and that deleted nodes are absent. A multi-branch test confirms that two independent diagnosis branches receive distinct lane identifiers.

Categorical View Tests (7 cases) validate tree structure invariants required by the Treviz rendering layer. Tests confirm that exactly one root node exists, that node depth is computed correctly (node 10 sits at depth 3), that sibling detection correctly identifies all five children of the root, that the `MAX_EXPANDED = 2` concurrency limit evicts the oldest expanded branch when a third is activated, that linker nodes are excluded from the categorical view, that a virtual root is correctly inserted when multiple roots are present, and that the recursive collapse function removes all descendants from the visible set.

Boundary and Validation Tests (12 cases) probe edge conditions and guard logic. Tests cover single-node and empty datasets, 500-character node titles, epoch-dated and far-future nodes (sorting to the correct ends of the timeline), deletion of the root node (removing all 12 nodes), case-sensitivity rejection of a malformed category value, leaf-node collection, and both guard-logic scenarios in which attempting to add a child to a node inside a discontinued or completed branch is correctly blocked.

Performance Tests (7 cases) set explicit time budgets for all computationally intensive operations and warn if any budget is exceeded. `getChronologicalData` must complete in under 5ms averaged over 100 iterations on the 12-node dataset, and under 30ms on a synthetically generated 500-node dataset. `collectNodesRecursive` must average under 2ms over 200 iterations. `isNodeInRejectedBranch` must average under 1ms over 500 iterations on a 50-node deep chain. `deleteRecursive` on the full 12-node tree must average under 1ms over 100 iterations. The triple-filter pipeline (category,

priority, normality) on 500 nodes must average under 3ms over 50 iterations. A memory integrity test confirms that all read-only operations leave the original data array length unchanged across 50 iterations, detecting any inadvertent side effects.

Test Runner Interface

The test runner is implemented as a self-contained HTML application providing a live dashboard for executing and reviewing results, shown in Figure 3.28. The interface includes a scoreboard displaying total, passed, failed, warned, and skipped counts alongside total execution time; a progress bar that fills as tests complete; a collapsible suite-by-suite result view with per-test status icons, descriptions, assertion messages, and individual execution times; a performance bar chart plotting each measured function against its budget threshold; and a scrollable log console with colour-coded pass, fail, warn, and info entries. An export button generates a Markdown report containing the full results table and log.

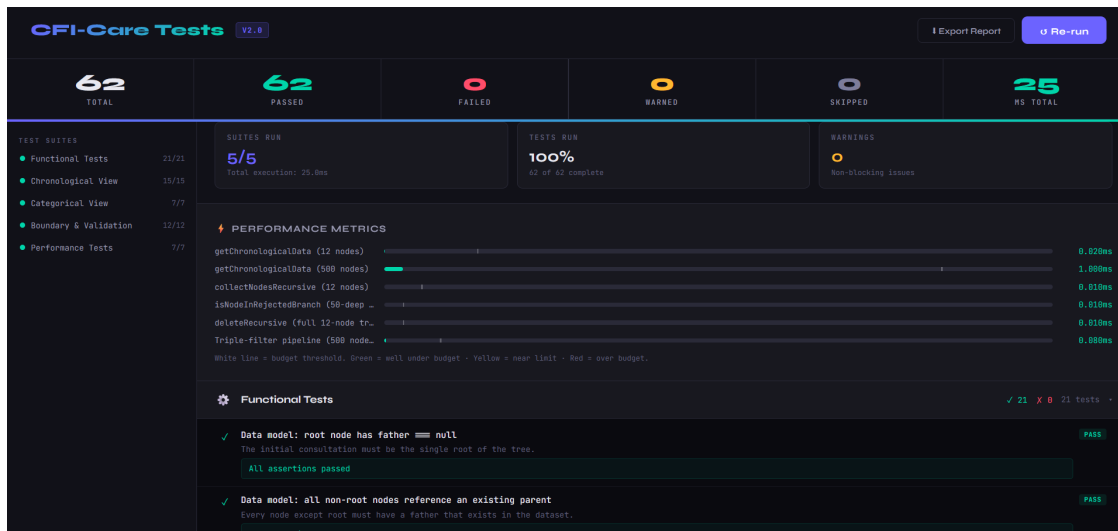


Figure 3.28: CFI-Care Graph Logic Test Suite dashboard after a full run. All 62 tests across five suites pass with zero failures and zero warnings in 22ms total. The scoreboard, per-suite result panels, performance bar chart, and log console are visible.

3.5.21 Summary

The CFI-Care frontend successfully transforms fragmented clinical data into a coherent, interactive medical information system. Through a carefully layered Angular architecture, a semantically rich visualisation engine combining Treeviz and D3.js, an OTP-based patient access workflow, a full AI-assisted clinical chat interface, and a practitioner scheduling system, the frontend addresses the complete spectrum of clinical interaction requirements. The dual-view Patient Journey Dashboard, with its categorical tree and chronological timeline, provides clinicians with both structural and temporal analytical perspectives from a single, seamlessly navigable interface. The built-in tutorial system, optimistic update strategy, dark mode support, and branch state management together

reflect a commitment to usability, resilience, and clinical safety that underpins every design decision made during this phase of development.

3.5.22 Mobile

Mobile Application Objectives & UI

The primary objective of developing the proposed mobile application is to provide a secure, efficient, and patient-centered platform for managing personal health information within the digital medical ecosystem integrated with the FHIR-compliant backend.

Authentication Flow & Account Security Authentication in CFI-Care is delegated entirely to Keycloak, an open-source Identity and Access Management server that implements the OpenID Connect (OIDC) protocol on top of OAuth 2.0. This approach means the mobile app never handles or stores user credentials, it only deals with tokens issued by Keycloak after the user authenticates.

1. Login and Register

The Login and Register flow uses the Authorization Code Flow with **PKCE** (Proof Key for Code Exchange), implemented via the `flutter_appauth` package[94].

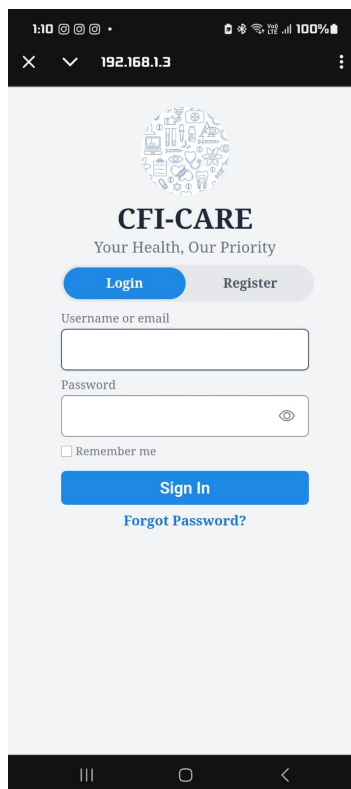


Figure 3.29: Login with KeyCloak

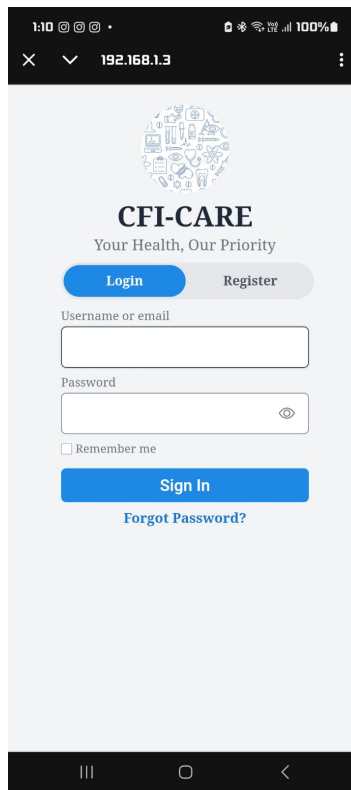


Figure 3.30: Register with KeyCloak

2. Email Verification Code

During the email verification process, a unique six-digit code is generated and saved within the Keycloak authentication session. This code is then delivered to the user's email address through Keycloak's email service using a customized HTML template. The user is presented with a verification page where the received code can be entered. Upon submission, the entered code is compared with the code stored in the session. If the codes match, the user's email address is successfully verified and the registration process proceeds. Otherwise, an error message is displayed, allowing the user to request a new verification code and try again.

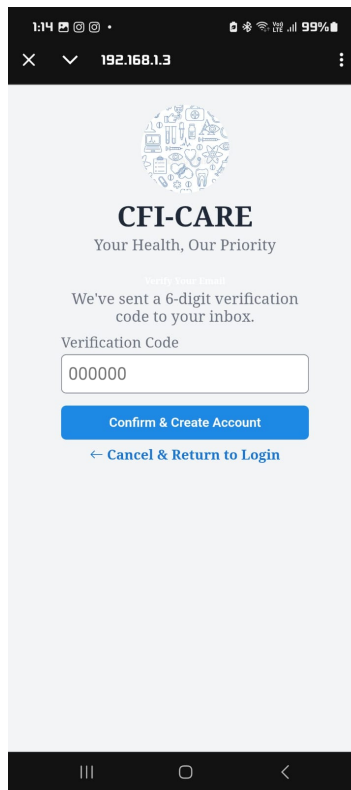


Figure 3.31: Verification Code

3. Recovery Codes

After completing registration, Keycloak presents the user with backup recovery codes. These are Keycloak's built-in recovery codes, displayed in a XXXX-XXXX-XXXX format in a list.

The page provides three options to save the codes:

- **Copy** : copies all codes to the clipboard
- **Save** : downloads them as a cfi-care-recovery-codes.txt file
- **Print** : opens a print dialog with a clean formatted view

The user must check a confirmation checkbox ("I have stored these backup recovery codes safely") before the submit button becomes enabled. The codes are then stored server-side in Keycloak and can be used at any future login as an alternative to the OTP authenticator if the user loses access to their device.

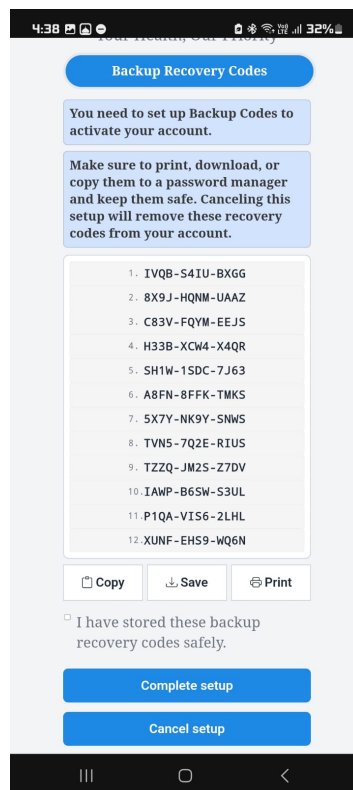


Figure 3.32: Recovery Codes

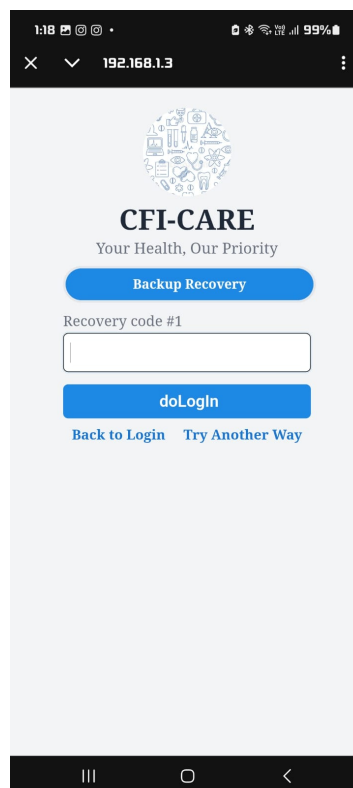


Figure 3.33: Enter Recovery Code #1

4. Authenticator Setup (TOTP)

Setting up a Time-based One-Time Password (TOTP) through three steps:

- (a) **Install an authenticator app** : the page lists supported apps (Google Authenticator, FreeOTP, etc.).
- (b) **Scan the QR code** : Keycloak generates a totpSecret and renders it as a base64-encoded QR code image. Users who cannot scan can switch to manual entry mode, which shows the raw secret key along with the algorithm (TOTP, HMAC-SHA1), digit count (6), and time interval (30 seconds).
- (c) **Enter a test code** : the user enters the 6-digit code from their authenticator app to prove the setup worked, and optionally gives the device a name (e.g., "My Phone").

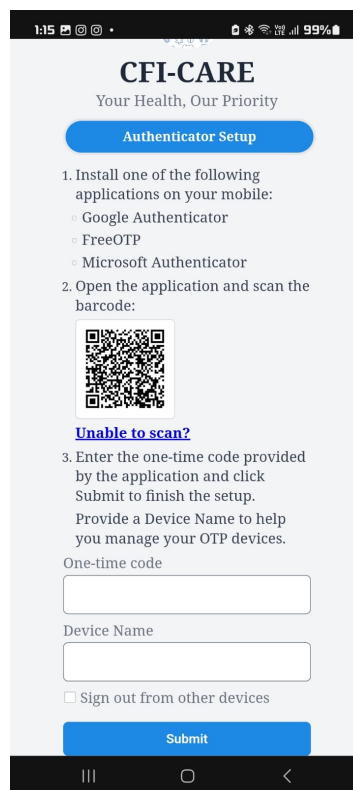


Figure 3.34: Authenticator Setup

5. Reset Password

(a) Unauthenticated Reset (Forgot Password)

On the login page(`login.ftl`), a "Forgot Password" link is rendered. Clicking it navigates to `login-reset-password.ftl`, which presents a simple form asking for the user's username or email.

On submission, Keycloak sends a password reset email to the user's registered address containing a time-limited link. Clicking the link in the email takes the user directly to `login-update-password.ftl` where they set a new password.

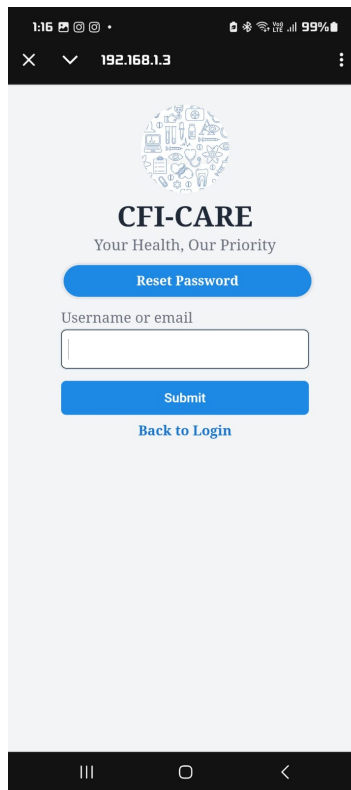
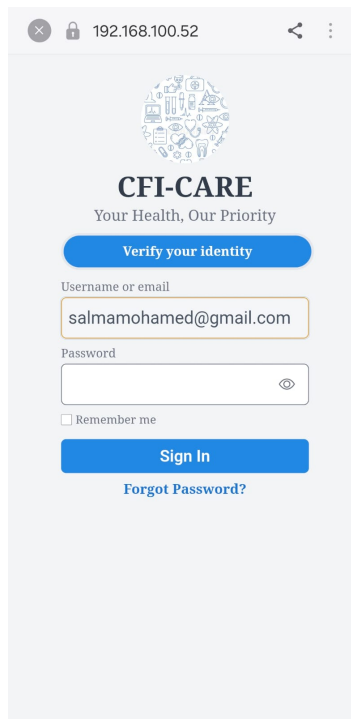


Figure 3.35: Unauthenticated Reset Password

(b) **Authenticated Reset (Change Password from App)**

A logged-in user can change their password from the Account & Security section of their profile. Tapping "Change Password" redirects to "Verify your identity" page, and the username field is pre-filled with the user's email and set to read-only. This prevents the user from changing identity mid-action.



The image shows a mobile application interface for a service named "CFI-CARE". At the top, there is a status bar with a close button, a lock icon, the IP address "192.168.100.52", and navigation icons. Below this is a circular logo composed of various medical and healthcare icons. The text "CFI-CARE" is prominently displayed, followed by the tagline "Your Health, Our Priority". A blue button labeled "Verify your identity" is positioned below the tagline. Underneath, there is a label "Username or email" above a text input field containing the email address "salmamohamed@gmail.com". Below the email field is a label "Password" above a password input field with a toggle eye icon. A checkbox labeled "Remember me" is located below the password field. A blue button labeled "Sign In" is positioned below the checkbox. At the bottom, there is a link labeled "Forgot Password?".

Figure 3.36: Verify your Identity

After re-verifying credentials, Keycloak presents **login-update-password.ftl**, which shows a new password field, a confirm password field, and "Log out other sessions" checkbox, allowing the user to invalidate all other active sessions simultaneously. On successful submission, Keycloak returns a fresh token set and the app session remains active, the user does not need to log in again.

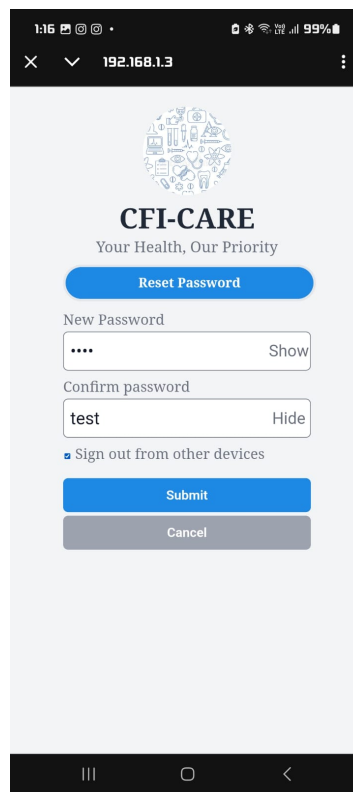


Figure 3.37: Enter & Confirm New Password

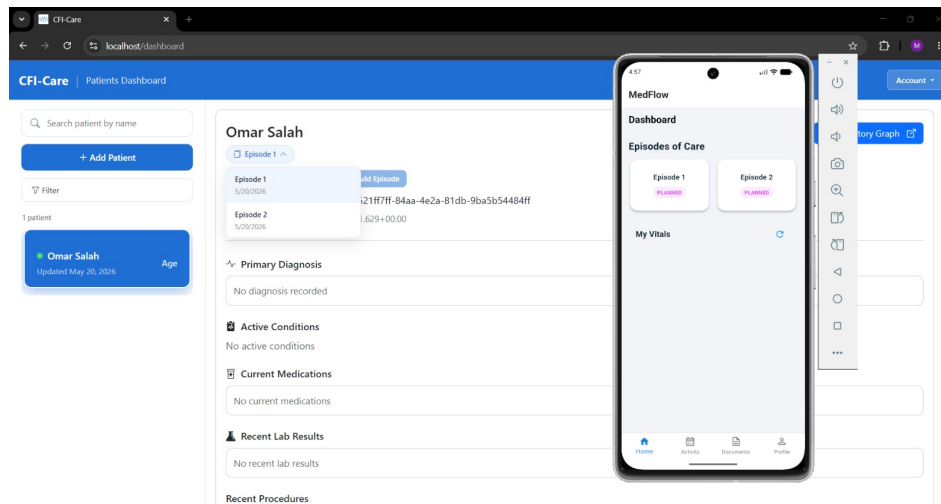


Figure 3.38: Episode of Care

Episode of Care

1. **View Episode of Care (Dashboard):** The entry point where the patient views high-level summaries of their active medical contexts (e.g., Cardiac Evaluation).
2. **View Encounter Details:** Selecting a specific node allows the user to inspect the full clinical details of that visit.

3. **View Attached Documents:** Within the details view, the user can optionally retrieve and view specific medical files (PDFs/Images) associated with that encounter.

Digital Document Management & Elimination of Physical Records The application enables patients to digitally capture, upload, and store medical reports, diagnostic scans, and other relevant health documents using their mobile devices. These documents are maintained within the application's local storage and synchronized with the backend system when required, thereby reducing reliance on physical medical records.

1. Document List

It displays all uploaded medical documents as a scrollable list, with a custom search header at the top for filtering by title and a blue **Floating Action Button** with a + icon anchored to the bottom-right corner. Tapping the FAB opens the Add Document bottom sheet. Each document is rendered as a card with:

- A type icon, red PDF icon or blue image icon, color-coded by file type.
- A one-line summary below it, and two tag chips showing the document's type (e.g. LAB, XRAY) and speciality (e.g. CARDIOLOGY, GENERAL)
- A time label on the right
- **A cloud sync indicator** green cloud_done if synced to the server, light blue cloud_off if pending, and grey if out of sync.
- When a document is added, it is immediately inserted into the local list (`_documents.add(newDoc)`) so it appears in the UI instantly, and then a sync is attempted. The `isSynced` flag on each `DocumentModel` tracks whether the backend has received the file, reflected visually by the cloud icon on each card.
- Documents support swipe-to-delete via Flutter's `Dismissible` widget [97], swiping left reveals a red delete background with a trash icon.
- Tapping a document opens it using `OpenFilex` [98], which launches the device's default app for PDFs or images. If the file no longer exists, a toast error is shown.

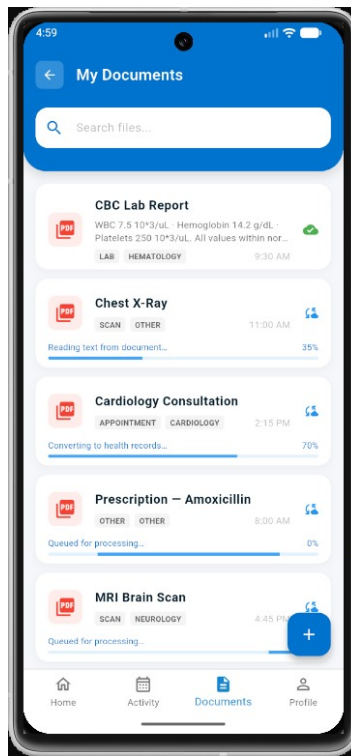


Figure 3.39: Documents Screen

2. Add Document Bottom Sheet

Tapping the Floating Action Button opens a modal bottom sheet (**DocumentAddSheet**) that slides up from the bottom as it can be seen in figure 3.40. The form contains:

- **Title** required
- **Summary** one-line description
- **Details** multi-line notes
- **Time picker** tapping opens a time picker dialog
- **Two dropdowns side by side:** Type (Lab, Xray, Prescription, etc.) and Speciality (Cardiology, Neurology, General, etc.)
- **Save button** is disabled unless both a title and a file are provided (isValid check).

Figure 3.40: Add Document Form

3. File Attachments

The bottom sheet offers three ways to attach a file:

- (a) **PDF Picker:** opens the system file picker filtered to .pdf files only. The selected file is copied into the app's documents directory with a timestamp-prefixed filename to avoid collisions.
- (b) **Gallery:** opens the image gallery via `image_picker`[99]. After selection, the image is copied to the app directory and an automatic blur check is run immediately.
- (c) **Scan:** navigates to the MultiPageScanner screen. The scanner returns a path to a PDF of the scanned pages, which is then copied to the app directory.

4. Image Quality Detection — Laplacian Variance

After any image is picked from the gallery or camera, `ImageQualityService.computeBlurScore()` runs automatically. The algorithm to compute if the image or the scanned photo is blurry or not.

- (a) Convert to grayscale to reduce each pixel to a single value and removes colour noise that could interfere with the edge detection.
- (b) Computes the variance of all Laplacian responses. A high variance means many sharp edges (a clear image). A low variance means smooth, uniform regions (a blurry image).
- (c) The threshold is set at 80.0: any score below this triggers an orange warning banner in the UI: "Image looks blurry. Try retaking or enhance it."

5. Magic Filter

If the image is flagged as blurry (or the user simply wants better quality), the Magic Filter button applies a 6-step document enhancement pipeline:

Table 3.4: Image Preprocessing Pipeline

Step	Operation	Purpose
1	Grayscale	Removes colour noise and reduces the processing space.
2	Percentile histogram stretch (2%–98%)	Corrects uneven lighting while preserving image details without binarization.
3	Unsharp mask (radius 1, amount 2.5)	Enhances text edges while maintaining gradient information.
4	8-connected Laplacian convolution ([-1,-1,-1,-1,9,-1,-1,-1,-1])	Sharpens both horizontal, vertical, and diagonal text strokes.
5	S-curve contrast boost (factor 1.5)	Increases contrast by pushing the paper background toward white and the ink toward black.
6	Auto-invert check	If more than 50% of pixels are dark, the image is inverted to ensure black text on a white background.

The enhanced image is saved as a new file (enhanced_FileName) and the blur score is re-computed on the result so the warning clears if enhancement succeeded.

6. Spirit Level

One of the most common problems with phone-based document scanning is perspective distortion, when the phone is held at an angle over the document, the resulting image is trapezoid-shaped rather than rectangular, making text harder to read and OCR less accurate. To address this, the CFI-Care scanner includes a real-time spirit level built using the device’s accelerometer.

How It Works

The `sensors_plus` [100] package provides a continuous stream of accelerometer events. The scanner subscribes to this stream in `_initSensors()`.

- The accelerometer reports gravitational force in m/s^2 along three axes. When the phone is held perfectly flat and parallel to a surface, both x and y approach 0 and only z carries the full gravitational value (9.8). The threshold of 0.7 on both axes was chosen experimentally to give a comfortable tolerance — the phone does not need to be perfectly flat, just reasonably aligned.
- The bubble’s position is a direct mapping of the accelerometer’s x and y values. When the phone tilts right, the bubble moves right. When it tilts forward, it moves down, exactly like a physical spirit level. The bubble and its containing ring turn green when the phone is level and red when it is not.

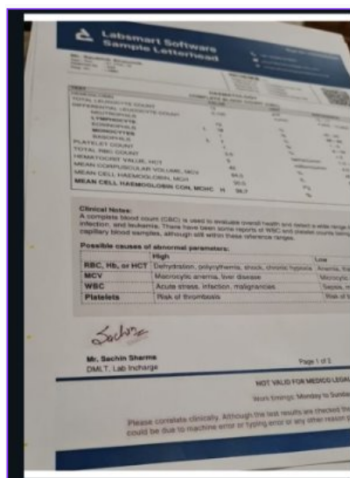


Figure 3.41: trapezoid-shaped Image

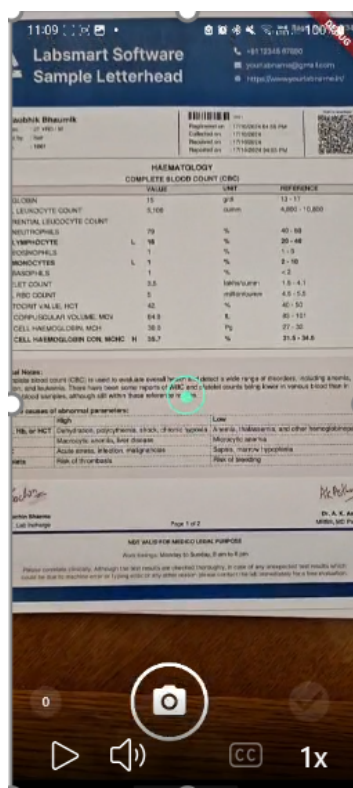


Figure 3.42: Green Spirit Level because parallel to the surface

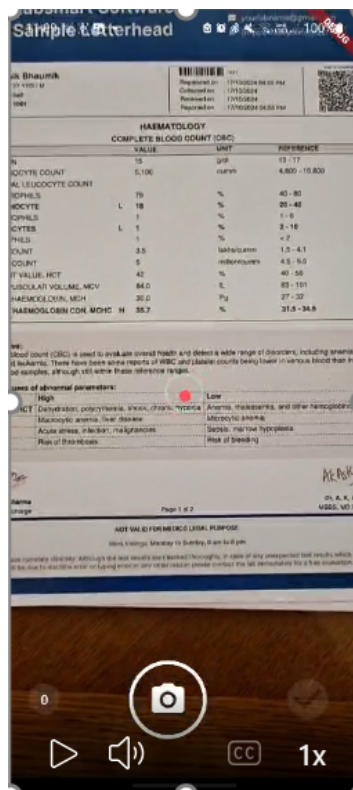


Figure 3.43: Red Spirit Level because tilted to the surface

7. Document Details & OCR Pipeline

Clicking on any document in the list shown in Figure 3.39 navigates the user to the Document Information screen. This screen displays the document details along with the status of the text extraction process, indicating whether extraction was successful, is still being processed, or has failed. Providing this information allows patients to verify whether the system was able to correctly interpret the uploaded document and identify cases where poor image quality or severe distortion prevented successful text extraction.

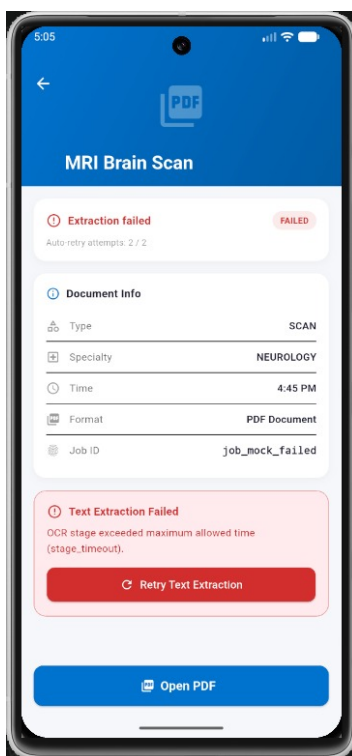


Figure 3.44: Text Extraction Failed

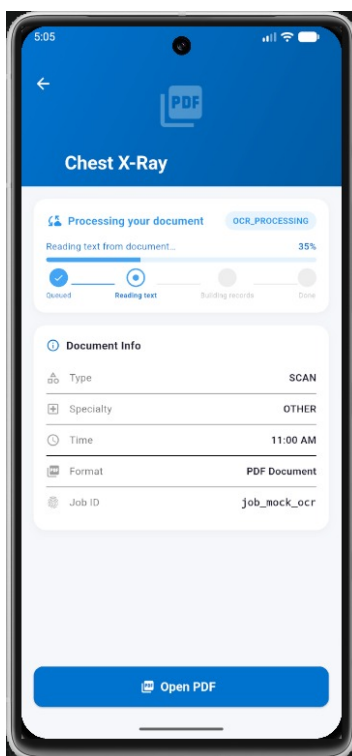


Figure 3.45: OCR processing

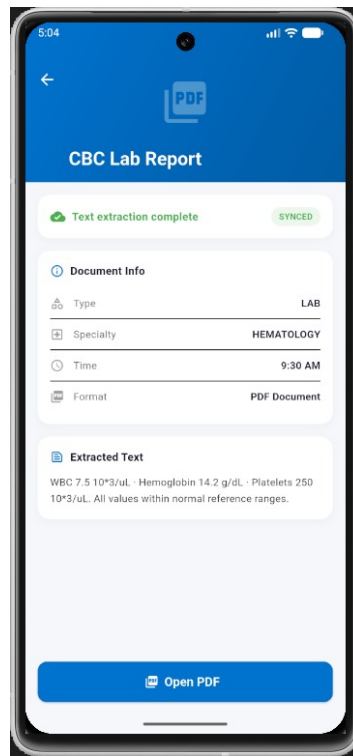


Figure 3.46: Text Extract successfully and synced with backend

Doctor-Patient Data Sharing A core objective of the system is to support controlled and consent-based data sharing. Doctors may submit requests to access a patient’s medical data, which the patient can explicitly approve or reject or revoke the access permission later. Upon approval, patients are able to define granular access permissions, such as read-only or read-write access, as well as specify a time-bound duration for which the access remains valid. This approach ensures patient data privacy while enabling physicians to effectively review and update medical records when authorized.

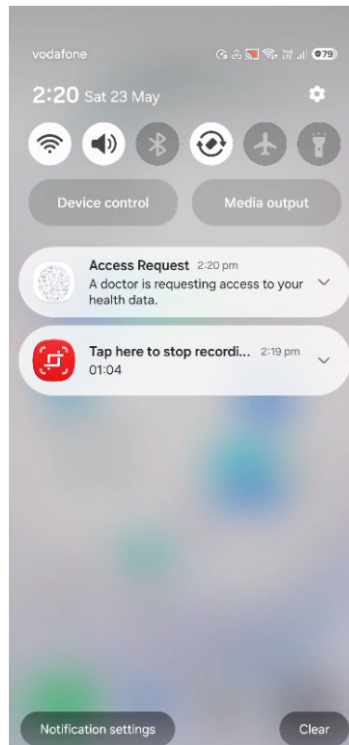


Figure 3.47: Notification with doctor requesting access to your data

Share Access Code with Doctor is a code for the doctor to enter. The patient decides who they want to give the code.

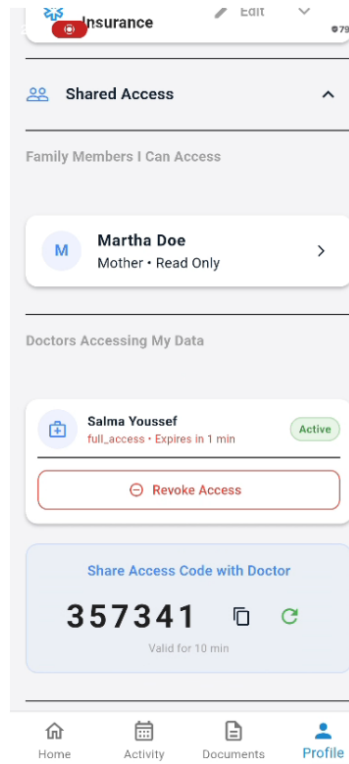


Figure 3.48: Doctor appearing in Doctors that can access your data list and user can revoke access

Caregiver and Family Involvement In addition to doctor access, the application supports caregiver and family member involvement. Patients may grant designated caregivers permission to monitor their health status, subject to explicit consent.

1. Caregiver Access Flow

- (a) Patient generates a code

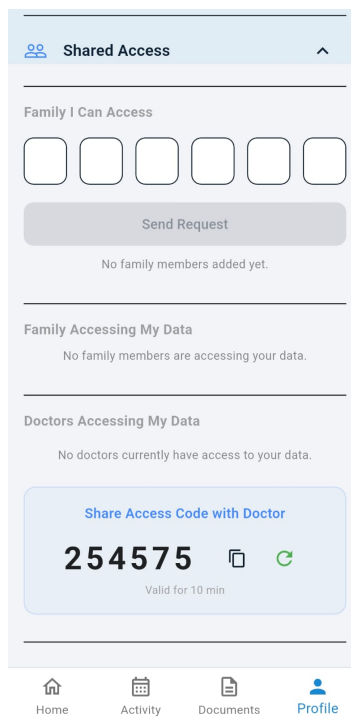


Figure 3.49: Patient Generating Code

(b) Caregiver enters the code

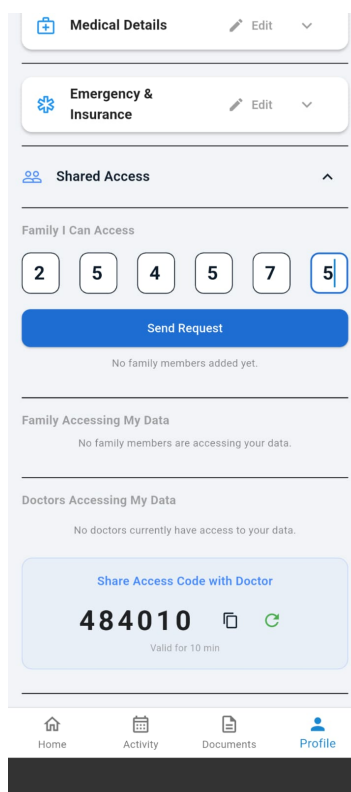


Figure 3.50: Caregiver entering Patient's code

(c) Patient receives notification and approves/denies

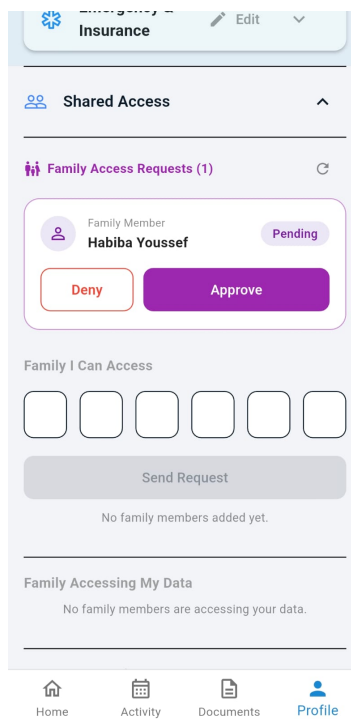


Figure 3.51: Caregiver request access (Patient view)

(d) Caregiver is notified and their list updates

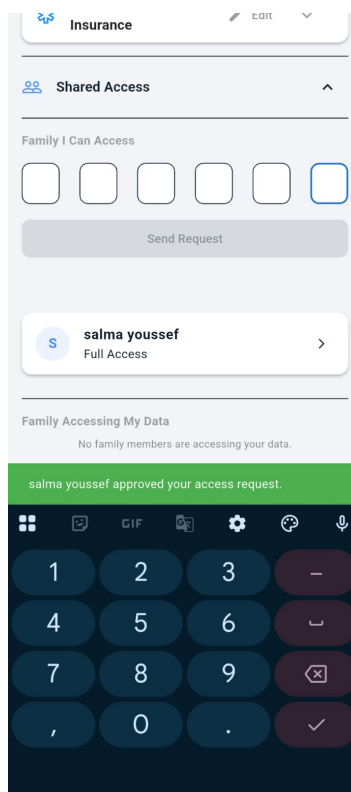


Figure 3.52: Caregiver is notified and their list updates

(e) Patient sees Caregiver in their family accessors list

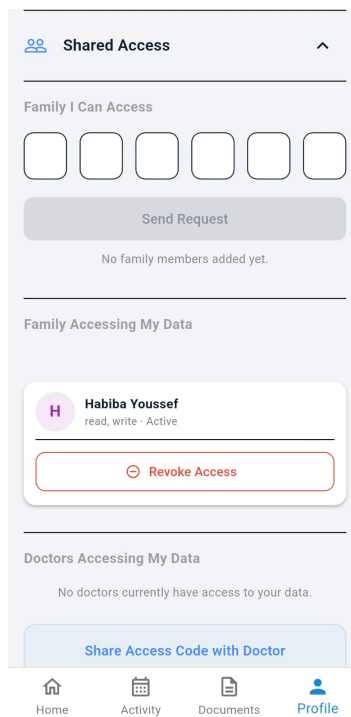


Figure 3.53: Patient sees Caregiver in their family accessors list and ability to revoke access

2. Proxy View (Caregiver viewing Patient's data)

Caregiver taps Patient's name in their "Family I Can Access" list → `ProxySessionProvider.switchTo(Patient.patientId, Patient.name)`.

What changes immediately across the whole app:

- (a) A purple banner appears at the top of every screen: "Viewing (Patient name)'s profile"
- (b) The home screen detects the proxy change, and loads Patient's episodes of care instead of Caregiver's own data.
- (c) In the Profile screen, all Shared Access sub-sections (pending requests, doctors, family lists, share code generator) are hidden — Caregiver only sees Patient's profile data.
- (d) Caregiver taps "Switch Back to My Profile" → everything reverts to Caregiver's own data.

Appointment Management The application further facilitates appointment management by allowing patients to schedule medical appointments directly through the mobile interface. During the booking process, patients may optionally attach relevant medical documents to provide physicians with preliminary information prior to consultation.

1. Updating Data

- If caregiver updates patient data, patient is notified, and data is updated for both.

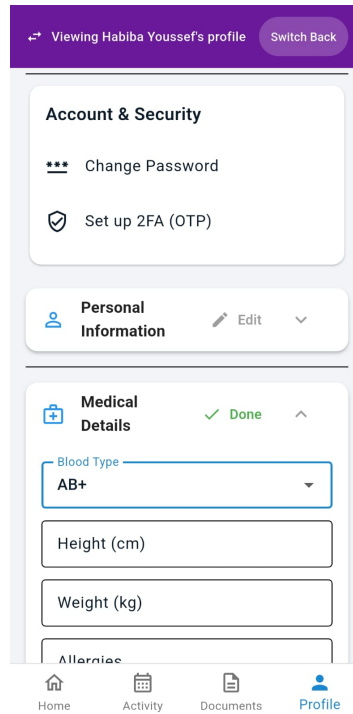


Figure 3.54: Caregiver updating Patient data

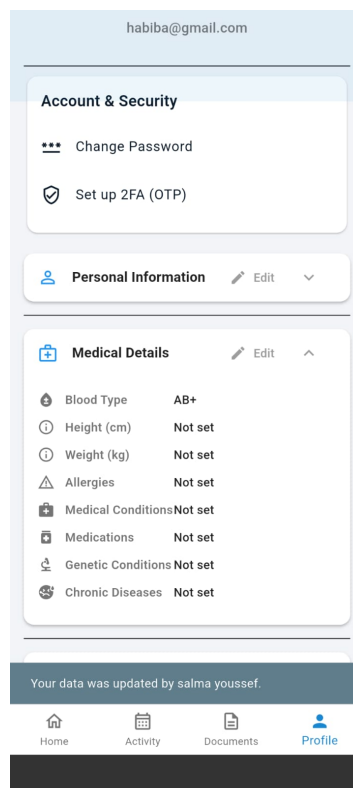


Figure 3.55: Patient receiving notification that Caregiver updated Patient data

- If patient updates their own data, caregiver is notified, and data is updated for both.

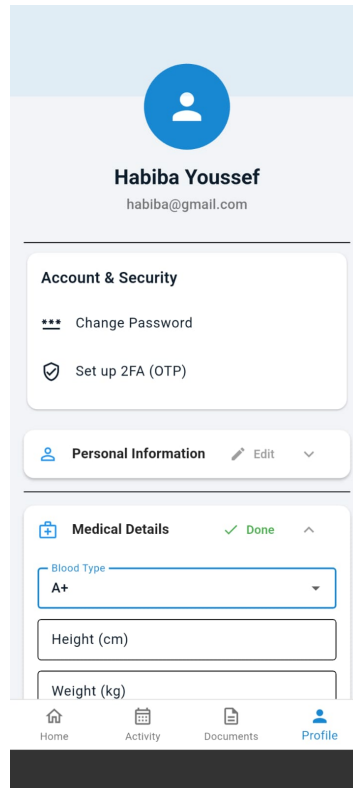


Figure 3.56: Patient update their own data

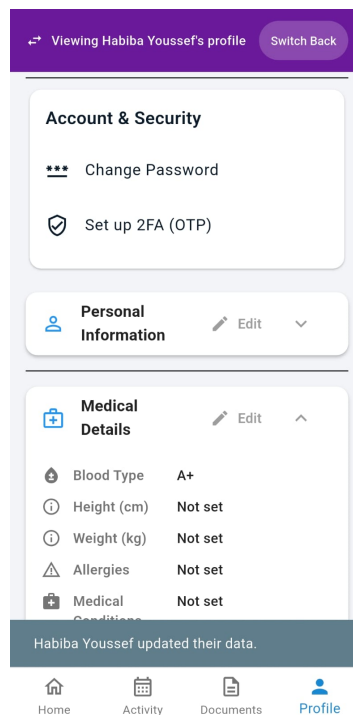


Figure 3.57: Caregiver receiving notification that Patient updated their own data

2. Booking Appointment Flow

(a) Search Doctor Specialty

- Patient sees a grid of medical specialties (Cardiology, Dermatology, Psychiatry, etc.), and selects one speciality based on their need → navigates to Doctor List.

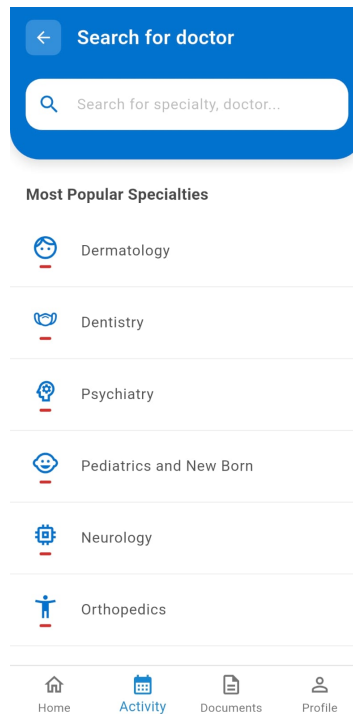


Figure 3.58: List of doctor specialities

(b) Doctor List

- Load list of doctors with the speciality chosen in **Search Doctor Specialty**
- Displays cards with name, rating, fees, waiting time.
- Patient taps a doctor card → Doctor Profile

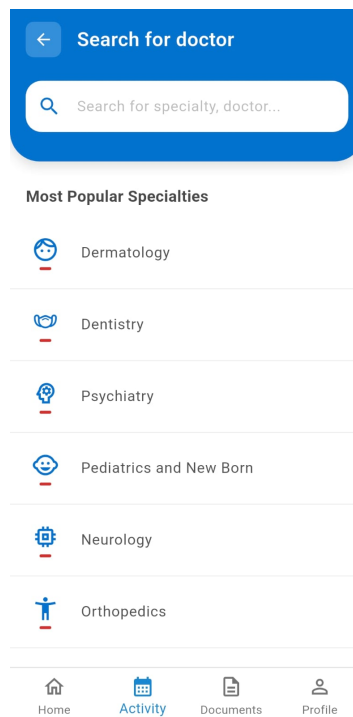


Figure 3.59: List of doctors with the speciality chosen (in this case Dermatology)

(c) **Doctor Profile**

- Shows full doctor details (about, reviews, fees)
- Displays expandable schedules with available time slots
- Patient taps a "Book" button on a slot → Confirmation Screen

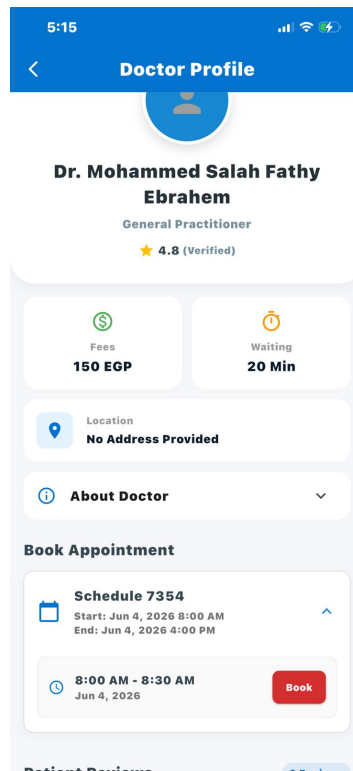


Figure 3.60: Doctor Profile with slots available

(d) **Confirmation**

- Summary card: doctor info, date/time, location
- Patient form: name (pre-filled), phone number, optional "booking for someone else"
- Checkbox "Confirm Booking"

(e) **Thank You Screen**

- Shows confirmation with appointment ID, doctor, date/time, fees
- Optional: patient can add notes/symptoms
- Optional: attach documents
- Back to Home → resets all selections

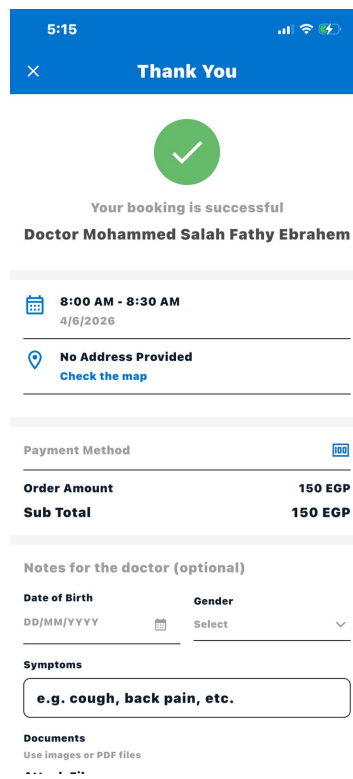


Figure 3.61: Thank You Screen

Wearable Device Integration Finally, the system is designed to support integration with wearable and smart health devices, such as smartwatches, to collect physiological data including heart rate and other vital signs Using Google Health_Connect[71].

1. What is Health_Connect

Health Connect is a database that's stored on your device. This means that Google doesn't use the cloud to store data that's sent to Health Connect by connected applications.

Health Connect facilitates interoperability among Android health applications by providing a centralized platform for sharing wellness and fitness data without requiring direct integrations between applications. The platform offers APIs for both storing and retrieving medical records, while also providing users with granular control over data access permissions and a dedicated interface for viewing their medical information.

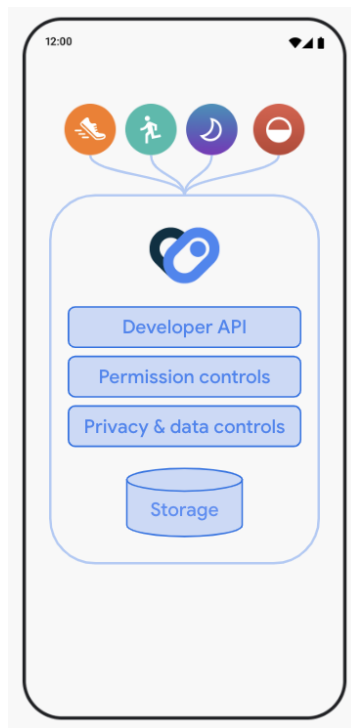


Figure 3.62: Health_Connect Diagram

2. How to handle Health Connect with several recent versions of Android

- Starting **Android 14** (API Level 34), Health Connect is part of the Android Framework. This version of Health Connect is a framework module. With that, there's no setup necessary.

Go to Settings > Security and Privacy > Privacy Controls > Health Connect, or search for Health Connect in Settings.

- **On Android 13 (API Level 33) and lower** versions, Health Connect is not part of the Android Framework. With that, you need to install the Health Connect app from the Google Play Store.

Go to Settings > Apps > Health Connect, or add Health Connect to your Quick Settings menu.

3. Health Connect Granular Permissions

One of the key benefits of Health Connect is its support for granular permissions. Instead of granting applications unrestricted access to all health information, users can authorize access to individual data categories. This fine-grained permission model strengthens privacy and security while allowing applications to access only the data necessary for their functionality.

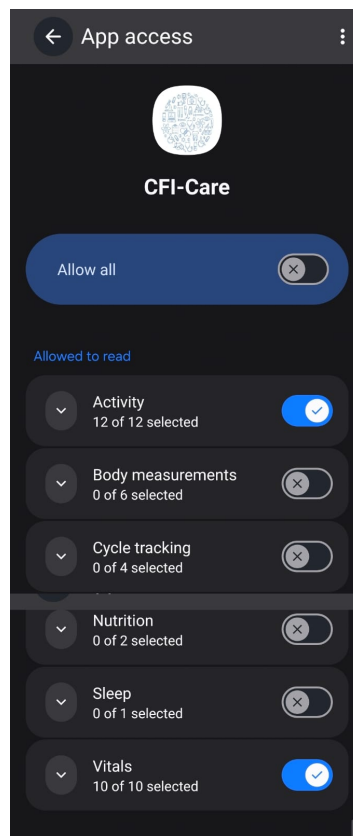


Figure 3.63: Granular Permissions

4. Data Sources & Priority

- **Data Sources**

Health Connect acts as a centralized repository that receives health data from different applications and wearable ecosystems, such as:

- CFI-Care
- Samsung Health
- OMRON Connect
- Withings
- Other Health Connect-compatible applications

Each record stored in Health Connect contains metadata identifying the source application that created it.

- **Data Priority**

Because multiple applications may contribute the same health metric (for example, step counts from both Samsung Health and Fitbit), Health Connect allows users to configure data source priority.

The priority setting determines which application's data should be preferred when conflicts or overlapping records occur. This helps avoid duplicate counting and improves data consistency.

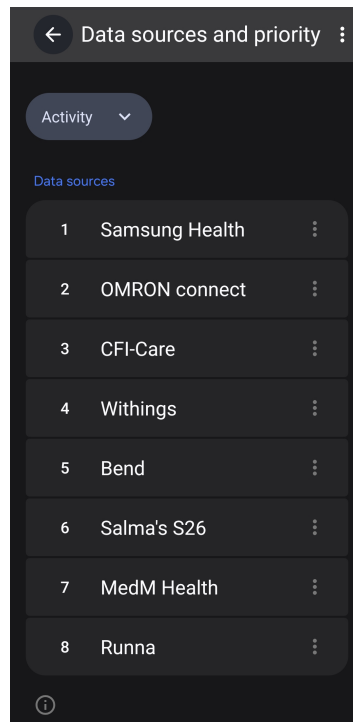


Figure 3.64: Data Sources & Priority

5. Collecting Medical Data from Various Medical Devices

By integrating with Health Connect, the application can access health and fitness data aggregated from a wide range of compatible wearable devices and health platforms. This interoperability eliminates the need for separate integrations with individual device vendors, allowing the system to obtain user health metrics from multiple sources through a unified interface.

(a) Galaxy Watch:

- Both the smartphone and Android Smartphone have Samsung Health[93].
- Samsung Health sends data to Health Connect.
- CFI-Care then asks for data from Health Connect.

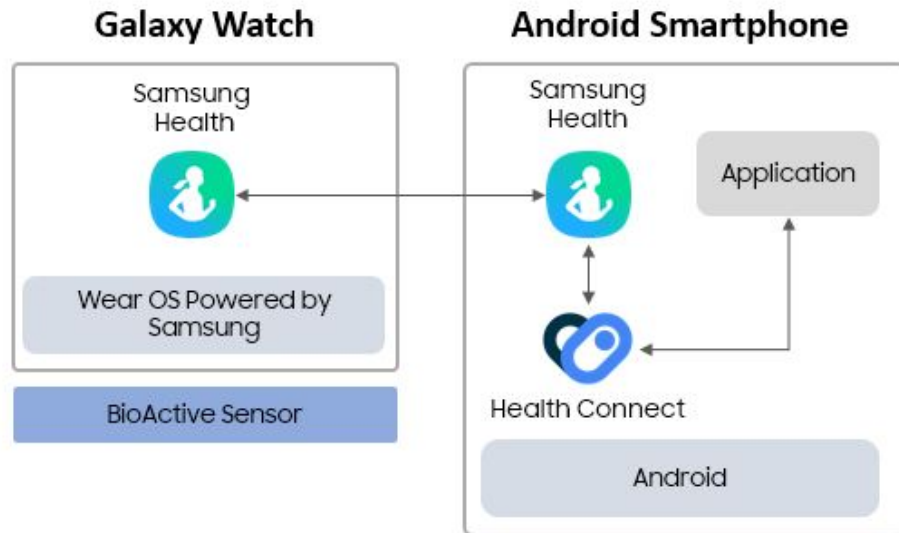


Figure 3.65: Health_Connect with GalaxyWatch & AndroidSmartphone

(b) **OMRON Connect**

- User installs OMRON Connect on their smartphone.
- OMRON Connect gets data from one of OMRON medical devices (e.g. Arm Blood Pressure).
- OMRON asks for permission to read and write data on Samsung Health.
- Samsung Health sends data to Health Connect.
- CFI-Care then asks for data from Health Connect.

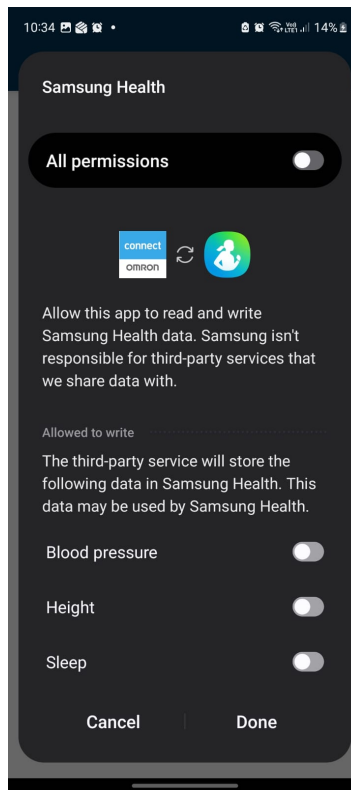


Figure 3.66: OMRON Connect requesting to read & write Samsung Health data

(c) **Withings App**

- Withings asks for permission to read and write data directly to Health Connect.
- CFI-Care then asks for data from Health Connect.

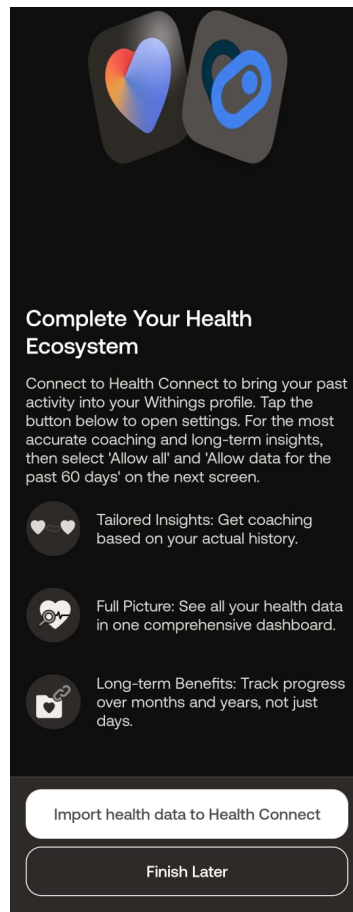


Figure 3.67: Withings requesting access to Health Connect

Flutter and Dart

Clean Architecture in the Mobile Application To ensure a scalable, maintainable, and testable codebase for the patient mobile application, this project adopts principles of Clean Architecture.

Clean Architecture is a layered software design paradigm that promotes clear separation of concerns, dependency management, and modularization of application logic. The fundamental goal of this approach is to isolate core business rules from implementation details and platform-specific frameworks, thereby improving long-term maintainability and facilitating unit testing [44].

According to the Flutter documentation on application architecture, well-structured applications organize code into logical layers that separate the user interface, application logic, and data handling. The documentation emphasizes the importance of isolating state management, dependency injection, and data access concerns to support growth and complexity in larger applications [43].

As illustrated in Figure 3.68, the application is structured into three principal layers: the presentation layer, the domain layer, and the data layer. Each layer has a distinct responsibility and communicates with adjacent layers through abstract

interfaces, ensuring that dependencies always point inward toward business logic rather than outward toward infrastructure or frameworks [44].

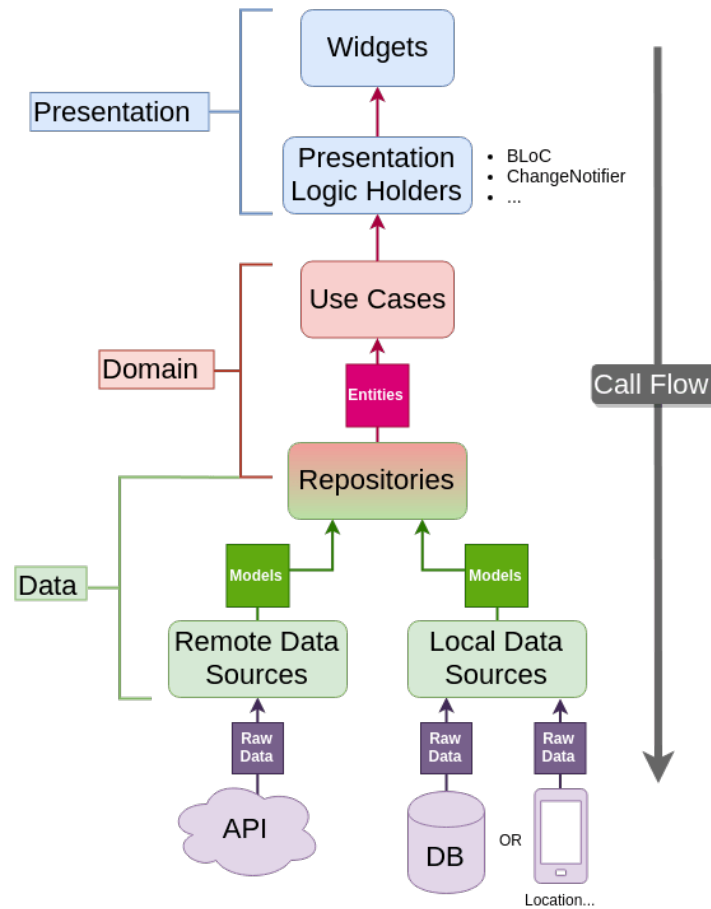


Figure 3.68: Layered Clean Architecture adopted in the mobile application

Layered Structure

1. Presentation Layer

This outermost layer contains code that directly interacts with the user interface. In the context of this Flutter application, it includes widgets, screens, routing logic, and Riverpod providers to manage application state when implemented. The presentation layer orchestrates the flow of data from use cases in the domain layer to the UI and captures user interactions for processing. Presentation logic is kept distinct from business rules and data access to avoid tightly coupling UI changes with core system logic [44].

2. Domain Layer

The domain layer encapsulates the core business logic and entities of the system. It is independent of Flutter or any external dependencies. This layer defines use cases that represent application-specific operations, such as requesting document access or scheduling appointments, and serves as the central coordinator of business rules. The domain layer's independence from external libraries and frameworks enhances testability and ensures that business logic can be validated in isolation [44].

3. Data Layer

The data layer is responsible for integrating with external systems, including APIs, local storage, and the backend FHIR server. It provides implementations of repository interfaces defined in the domain layer and manages data transformation between network responses, local models, and domain entities. The layered separation ensures that external dependencies do not leak into the domain or presentation layers [44].

Centralized Runtime Permission Handling To ensure a secure and seamless interaction with device hardware, the application implements a centralized asynchronous mechanism for managing runtime permissions. This approach abstracts the complexity of the `permission_handler` library and follows established patterns for robust permission management [46]. The function `handlePermission` provides a unified interface for requesting access to sensitive resources such as the camera, storage, or microphone.

The function operates as a `Future<bool>`, returning a boolean value to indicate the success or failure of the authorization process. Upon invocation, the function executes the following logic flow:

1. **Asynchronous Request:** It initiates a request to the underlying operating system using `permission.request()`. The execution yields until the user interacts with the system dialog or the operating system returns the current status.
2. **Status Evaluation:** The returned `PermissionStatus` is evaluated against standard authorization states:
 - **Granted:** If the user approves the request (`isGranted`), the function immediately returns `true`, allowing the calling process to proceed.
 - **Permanently Denied:** If the permission is flagged as `isPermanentlyDenied` (a state where the operating system suppresses further prompts due to repeated denials), the system intervenes to prevent a silent failure. It displays a toast notification instructing the user to enable the permission manually and invokes `openAppSettings()` to redirect the user to the device's settings menu.
 - **Denied:** In cases of a standard denial, a feedback message is displayed via `Fluttertoast` to inform the user of the restriction, and the function returns `false`.

By encapsulating this logic, the system ensures that permission failures are handled gracefully, guiding users through recovery steps when necessary rather than causing application crashes or unresponsive features. The implementation of this logic is demonstrated in Listing 3.1.

Listing 3.1: Asynchronous Permission Handling Function

```

import 'package:permission_handler/permission_handler.dart';
import 'package:fluttertoast/fluttertoast.dart';

Future<bool> handlePermission(
  Permission permission,
  String name,
) async {
  final status = await permission.request();

  // Case 1: Permission Granted
  if (status.isGranted) {
    return true;
  }

  // Case 2: Permanently Denied (Requires Settings)
  if (status.isPermanentlyDenied) {
    Fluttertoast.showToast(
      msg: '$name␣permission␣permanently␣denied.␣Enable␣it␣in␣settings
        .',
    );
    openAppSettings();
    return false;
  }

  // Case 3: Standard Denial
  Fluttertoast.showToast(msg: '$name␣permission␣denied');
  return false;
}

```



Figure 3.69: Using handlePermission for Camera Access in code

1. Best Practices for handling Permissions in Flutter

- Contextual Permission Requests:** To avoid overwhelming the user and to establish context, the application rejects the traditional “up-front” permission model (where all permissions are requested at launch). Instead, a *Contextual Request* pattern is employed. Permissions are only requested at the specific moment a feature is invoked. For example, access to the **Camera** is requested solely when the user attempts to scan a medical report.
- Transparent Rationale and Trust Building:** In compliance with privacy best practices, the application explains the “Why” before the “How.” Prior to triggering the system permission dialog, the application presents a custom UI explanation detailing exactly why a specific permission is needed and how

it benefits the user. This transparency is critical in a healthcare context, increasing the likelihood of approval and reinforcing the patient’s understanding that their data is being used strictly for medical management.[72]

- **User Agency and Graceful Degradation:** The system is designed to respect user choices without compromising the core functionality of the application. If a user denies a non-critical permission, the app enters a state of *Graceful Degradation*. The application avoids repetitive prompting (“nagging”), ensuring a respectful user experience. [72]
- **Comprehensive State Handling:** The application logic accounts for the full lifecycle of permission states, ensuring stability across different scenarios[72][73]:
 - **Granted:** The feature proceeds immediately.
 - **Denied:** The feature is disabled, and the user is informed of the limitation.
 - **Permanently Denied:** In cases where the user has selected “Don’t ask again,” the application detects this state and provides a subtle option to guide the user to the system **App Settings** menu for manual enablement, should they choose to do so later.

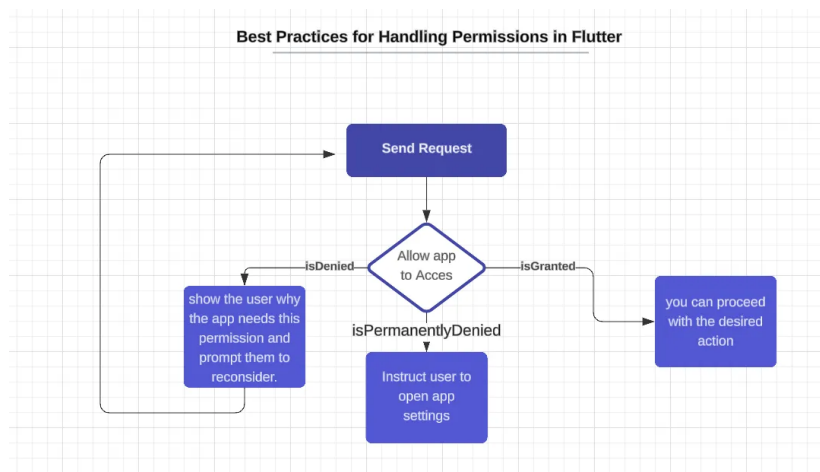


Figure 3.70: Best Practices for Handling Permissions in Flutter

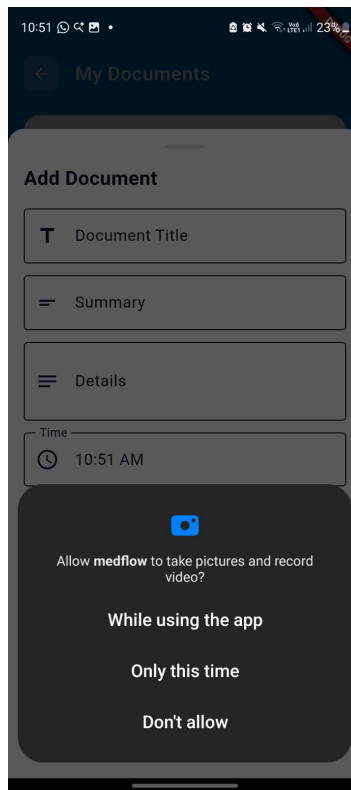


Figure 3.71: Dialog to allow the app to access the camera

FCM Push Notifications

The system uses Firebase Cloud Messaging (FCM) to deliver real-time push notifications from the Node.js backend to the Flutter mobile app. FCM acts as a broker: the backend never sends a message directly to a device — it sends a message to Google's FCM servers, which deliver it to the target device using its unique FCM token.

How It Works

1. Token Registration

- Before any notification can be sent, the backend must know the device's Firebase Cloud Messaging (FCM) token.
- On the Flutter side, the application calls `FirebaseMessaging.instance.getToken()` to obtain the device's unique FCM token.
- The token is then sent to the backend through:

```
POST /FCM/fcm-token
{
  "fcmToken": "abc123"
}
```

- Token rotation is handled automatically. Whenever Firebase generates a new token, the updated value is sent again to the same endpoint.

2. The Shared Sender Utility

All notifications go through one private function:

- Before sending a notification, the backend retrieves the recipient’s FCM token from Redis using the user’s identifier.
- If no token is found, the notification is skipped because the user does not have a registered device.
- The backend then sends a Firebase Cloud Messaging (FCM) message containing both notification and data payloads.
- Notifications are sent with high priority to ensure timely delivery.
- Each notification message consists of two components:
 - **Notification Payload:** Contains the user-visible content, including the notification title and body displayed in the operating system’s notification tray.
 - **Data Payload:** Contains structured key–value pairs processed by the Flutter application. The most important field is `type`, which identifies the notification category and determines the action that the application should perform upon receiving the message.

3. The Four Notification Types

The system defines four distinct event types, each triggering a different UI response:

Table 3.5: Notification Events and Actions

Event Type	Trigger	Recipient	Action
grant_request	Doctor submits patient’s OTP	Patient	Orange snackbar and refreshing doctor requests
family_request	Caregiver submits patient’s OTP	Patient	Purple snackbar and refreshing family requests
grant_approved	Patient approves any request	Requester	Green snackbar, refresh members, and navigate to tab
data_updated	Patient or caregiver edits health data	The other party	Blue-grey snackbar notification

4. Access Request Notifications (grant_request / family_request)

When a doctor or caregiver submits a patient’s OTP through the `/verify-practitioner-otp` or `/verify-caregiver-otp` endpoint, the backend first validates the OTP against Redis and retrieves the corresponding patient identifier. A pending handshake record is then created and an FCM notification is sent to the patient.

Depending on the requester type, the notification payload contains either the `grant_request` or `family_request` event type.

Upon receiving the notification, the Flutter application refreshes the appropriate provider and displays a visual notification to the user. Doctor requests trigger an orange snackbar and refresh the pending grants list, while caregiver requests trigger a purple snackbar and refresh the pending family requests list.

5. Approval Notification (`grant_approved`)

When a patient approves an access request through the `/create-grant` endpoint, the backend creates a grant record in Redis with a predefined time-to-live (TTL). The patient's display name is retrieved from the FHIR server and included in an approval notification sent to the requester.

The notification contains the event type `grant_approved`. Upon receipt, the Flutter application refreshes the accessible members list, navigates the requester to the profile tab, and displays a green snackbar indicating that access has been approved.

6. Data Update Notifications (`data_updated`)

Whenever a patient's health data is modified, the backend determines whether the update was performed by the patient or by a caregiver.

If a caregiver updates the patient's data, a notification is sent to the patient informing them of the change. Conversely, if the patient updates their own data, all active caregivers associated with that patient are notified.

This implementation follows a fan-out notification pattern, where a single patient update may generate notifications for multiple caregivers. The Flutter application displays an informational snackbar upon receiving a `data_updated` event.

7. Application State Handling

The notification subsystem supports three application states:

Table 3.6: Notification Handling by Application State

Application State	Handler	Purpose
Foreground	<code>FirebaseMessaging.onMessage.listen()</code>	Display snackbars and refresh providers
Background	<code>FirebaseMessaging.onMessageOpenedApp.listen()</code>	Handle notification tap events
Terminated	<code>getInitialMessage()</code>	Process notifications after application launch

Background and terminated notification flows share a common message handler responsible for refreshing application state after the user opens the notification.

Requirements Engineering

To ensure the delivery of a viable and effective application, the development lifecycle begins with a stakeholder analysis to establish the system context. This is followed by a

comprehensive definition of the functional, non-functional, and optional requirements. Synthesizing this information facilitates the creation of a domain model, which acts as the foundational blueprint for the subsequent database design.

Target Group and User Group Stakeholders are categorized into Internal Stakeholders, who are directly involved in the development and operation of the system, and External Stakeholders, who utilize the system's end products.

1. External Stakeholders

External stakeholders are the primary users of the system. Their interaction drives the application's core functionality.

(a) Patients (Primary Users)

Interaction:

- **Data Management:** Patients interact with the mobile interface to upload medical documents (lab results, scans) and view their historical data presented in a structured "Major Events" timeline.
- **Access Control:** They possess full authority over their data privacy. Patients receive requests from doctors for data access and can grant permissions (Read-Only or Read-Write) for a specific duration. Crucially, they retain the ability to revoke this access at any time.
- **Family Management:** Patients can authorize family members to view their health records for monitoring purposes.

Benefits:

- **Centralized History:** Eliminates the need for physical paperwork by consolidating all medical history into a single, organized mobile repository.
- **Data Ownership:** Empowers patients with absolute control over who views their medical information and for how long.
- **Continuity of Care:** Ensures that any new doctor can immediately access a complete medical background, reducing diagnostic errors.

(b) Family Members (Secondary Users)

Interaction:

- **Monitoring:** Through shared access granted by the patient, family members can view health trends and documents to assist in care.
- **Administrative Support:** Unlike doctors, family members have the permission to book appointments and change data on behalf of the patient, facilitating care for elderly or incapacitated users.

Benefits:

- **Remote Assurance:** Provides peace of mind by allowing real-time monitoring of a loved one's health status.
- **Care Coordination:** Simplifies the logistical burden of managing appointments and records for dependents.

(c) **Doctors (Service Providers)**

Interaction:

- **Session Initiation:** While doctors primarily use the Web Interface, their actions directly trigger updates on the mobile app. A doctor initiates a "New Encounter Node" in the patient's history tree during a visit.
- **Access Requests:** Doctors request permission to view a patient's historical records. If granted "Write" access, they can add new diagnoses and prescriptions to the encounter node.
- **Limitation:** Doctors strictly cannot book appointments; this function is reserved for patients and their families to prevent conflict of interest or scheduling errors.

Benefits:

- **Informed Decision Making:** Instant access to a comprehensive medical history allows for more accurate diagnoses.
- **Efficiency:** Reduces time spent interviewing patients for past medical details, allowing more focus on current treatment.

2. Internal Stakeholders

Internal stakeholders are responsible for the technical construction, maintenance, and security of the platform.

Chapter 4

Security

4.1 Introduction

Healthcare information systems are primary targets for security breaches due to the high commercial value of Protected Health Information (PHI). We addressed these risks by managing multi-layered security challenges, including web-based access, mobile authentication, sensitive patient consent delegation, and complex doctor-patient workflows. Furthermore, the system maintains audit trails and supports real-time session revocation.

Since traditional monolithic security models are insufficient for such a distributed system CFI-Care adopts a **Defense-in-Depth** strategy, leveraging industry standards such as OAuth 2.0 and OpenID Connect (OIDC) with JWT. Security is enforced through distributed validation across the system firewall and the Application Programming Interface (API) gateway (Nginx), and the BFF layer, ensuring multiple checkpoints before data access.

4.2 Architecture Overview

The security architecture follows a layered model where each component provides a specialized validation check. Figure 4.1 illustrates the interaction between edge clients, the identity provider, and backend resources.

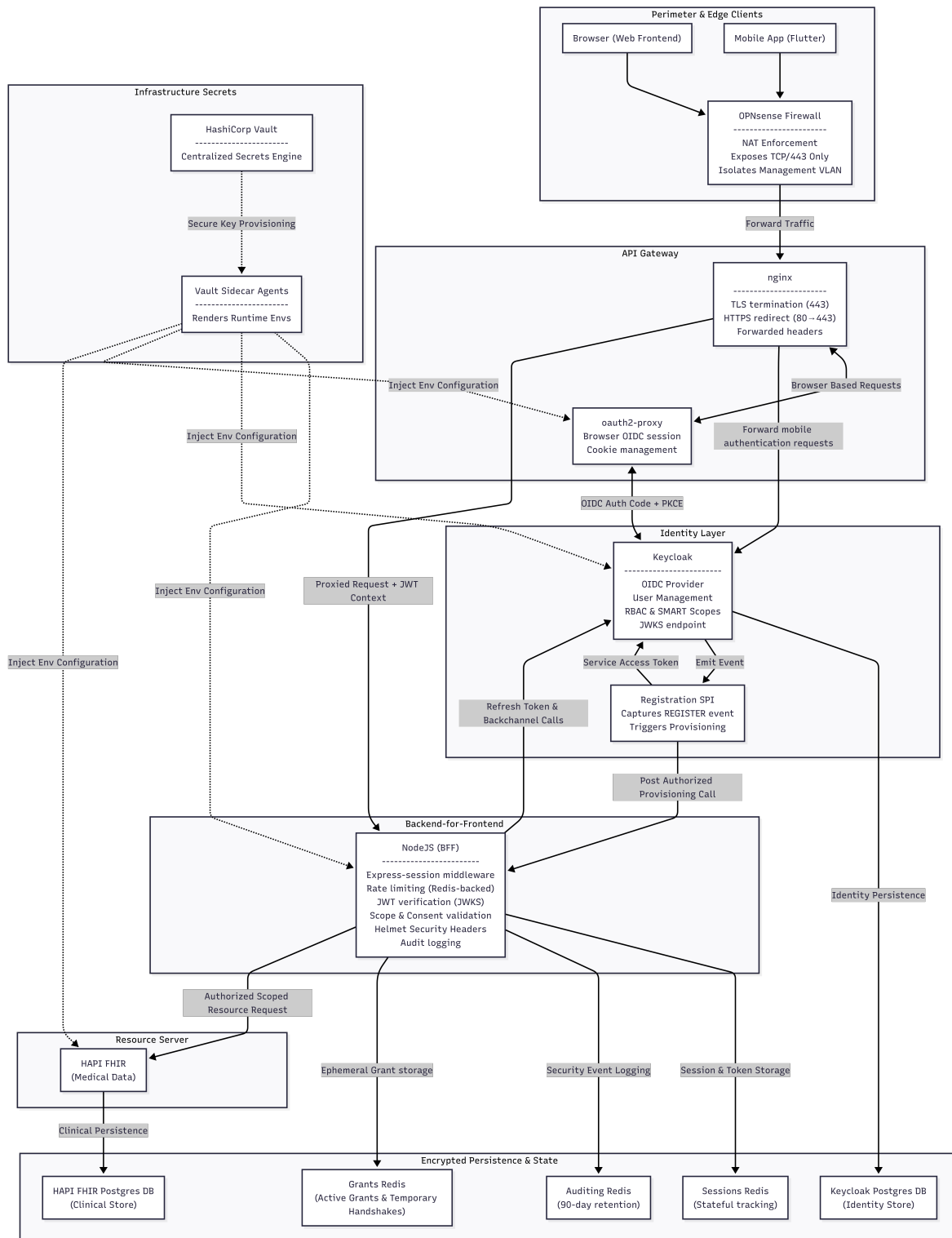


Figure 4.1: Security Architecture Components: Edge clients (Browser, Mobile), API Gateway (Nginx, OAuth2 proxy), Backend-for-Frontend (Node.js), Identity (Keycloak), Storage (Redis, Postgres), and Resource Server (HAPI FHIR).

The following pillars define the implementation:

- **Identity & Access Management:** Keycloak serves as the central Identity

Provider (IdP), issuing signed JWTs. Authentication pathways are structurally split by client type to optimize token security for both browser-based environments and native mobile deployments

- **Transport & Edge Security:** Nginx terminates TLS and enforces HTTPS-only communication. At the application layer, defensive browser headers and strict cookie policies are enforced at the BFF boundary to neutralize client-side vulnerability vectors.
- **Distributed Validation:** Token integrity, scope claims, and patient-specific bindings are validated at the BFF layer before requests reach the resource storage, ensuring that the principle of least privilege is maintained.

4.3 Identity and Lifecycle Management

The system relies on Keycloak as the central Identity Provider (IdP). A dedicated realm was configured to manage practitioners and patients, utilizing specialized clients and custom extensions to ensure a secure registration lifecycle.

4.3.1 Keycloak Configuration and Clients

Keycloak manages three primary OIDC clients: a confidential client used internally by the Backend (BFF) to validate tokens through its middleware, a confidential client for the oauth2 proxy that manages browser sessions, and a public client for mobile devices.

Both user-facing clients leverage the Authorization Code Flow with PKCE to prevent code interception and authorization injection attacks across all endpoints.

4.3.2 User Registration and Resource Provisioning

To maintain synchronization between the identity provider and the healthcare data layer, the system implements an automated provisioning workflow triggered by user registration.

Keycloak Event Listener

A custom Keycloak Event Listener is deployed to capture the `REGISTER` event. Upon execution, the listener performs the following sequence (see Figure 4.2):

1. Obtains a `client-credentials` access token to authenticate as a trusted service.
2. Invokes the BFF registration endpoint with the new user's context.
3. The BFF validates the incoming JWT and verifies the caller against a client allowlist stored as secure secrets.

4. Based on the originating Client ID, the system maps the user to a FHIR resource type: **Practitioner** for web-based signups or **Patient** for mobile registrations.

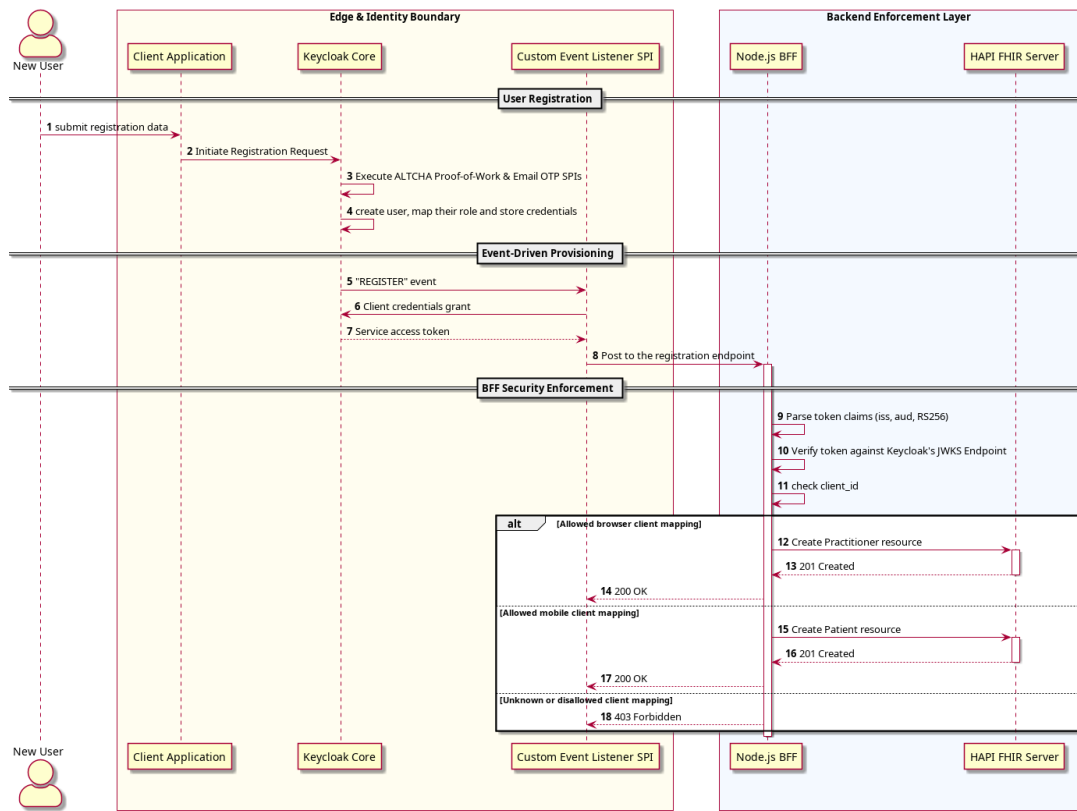


Figure 4.2: Registration Provisioning Sequence: Event-driven synchronization between Keycloak and the FHIR Resource Server.

4.3.3 Custom Security Extensions (SPIs)

To strengthen registration integrity, two custom Keycloak Service Provider Interfaces (SPIs) were developed to implement a robust OTP-based email verification mechanism, and support bot mitigation during the registration lifecycle.

Email OTP Verification (Authenticator SPI) This authenticator runs after the registration form has been completed and issues a 6-digit one-time password to the user's email address. The code is stored in the authentication session, the user must submit the same value to continue, and a successful match marks the account as email-verified before authentication completes.

Registration CAPTCHA (FormAction SPI) The ALTCHA registration extension is a required execution step in the registration flow. It generates a challenge from the Keycloak authenticator configuration, renders the challenge to the registration form, and validates the submitted solution before registration can proceed. This prevents automated account creation while keeping the CAPTCHA logic inside the Keycloak flow.

4.3.4 Persistence Layer

Identity data, including hashed credentials and role mappings, are persisted in a dedicated PostgreSQL database. This instance is isolated within a private network, accessible only by the Keycloak service.

4.4 Authentication Framework

CFI-Care employs a split authentication strategy tailored to the specific security profiles of web browsers and mobile applications. Both flows are alike in the application of OIDC and short-lived JWTs.

4.4.1 Web Browser Authentication

Browser-based authentication is enforced at the edge by the Nginx API Gateway using `oauth2-proxy` (with the `auth_request` module).

Gateway-mediated OIDC Flow When an unauthenticated user accesses the dashboard, the gateway redirects the browser to Keycloak via the Authorization Code Flow with PKCE. Upon successful authentication, `oauth2-proxy` establishes a session, issues secure HTTP-only cookies, and injects the JWT into the `Authorization: Bearer` header for all upstream requests to the BFF.

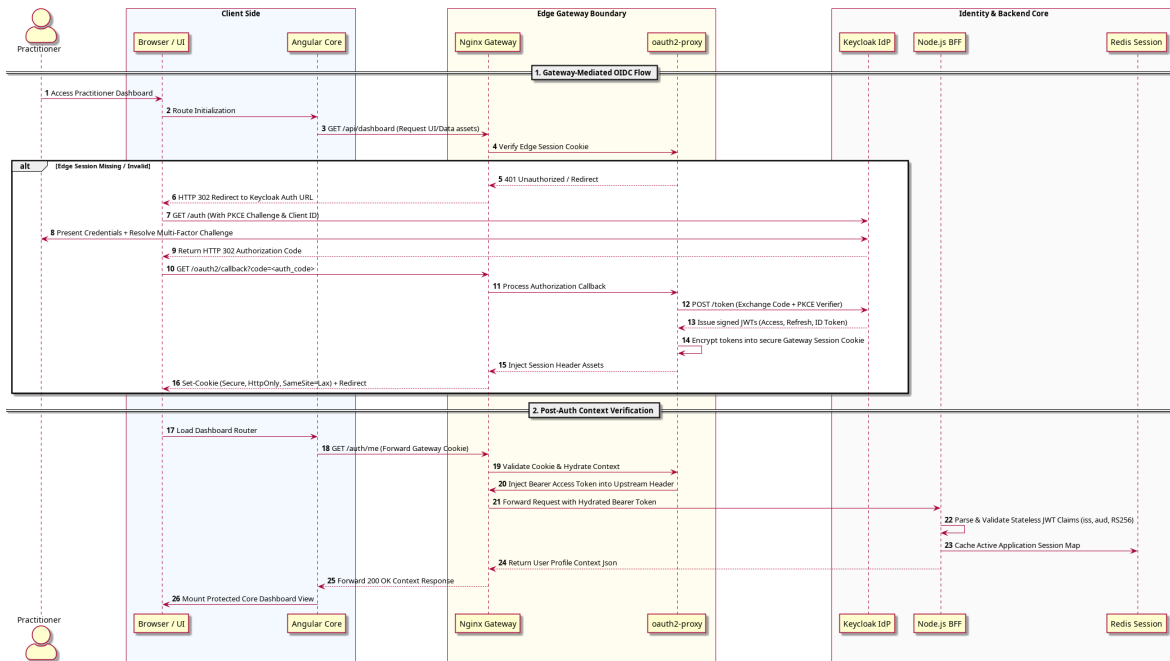


Figure 4.3: Browser Authentication Sequence: Gateway-mediated OIDC flow and session cookie management.

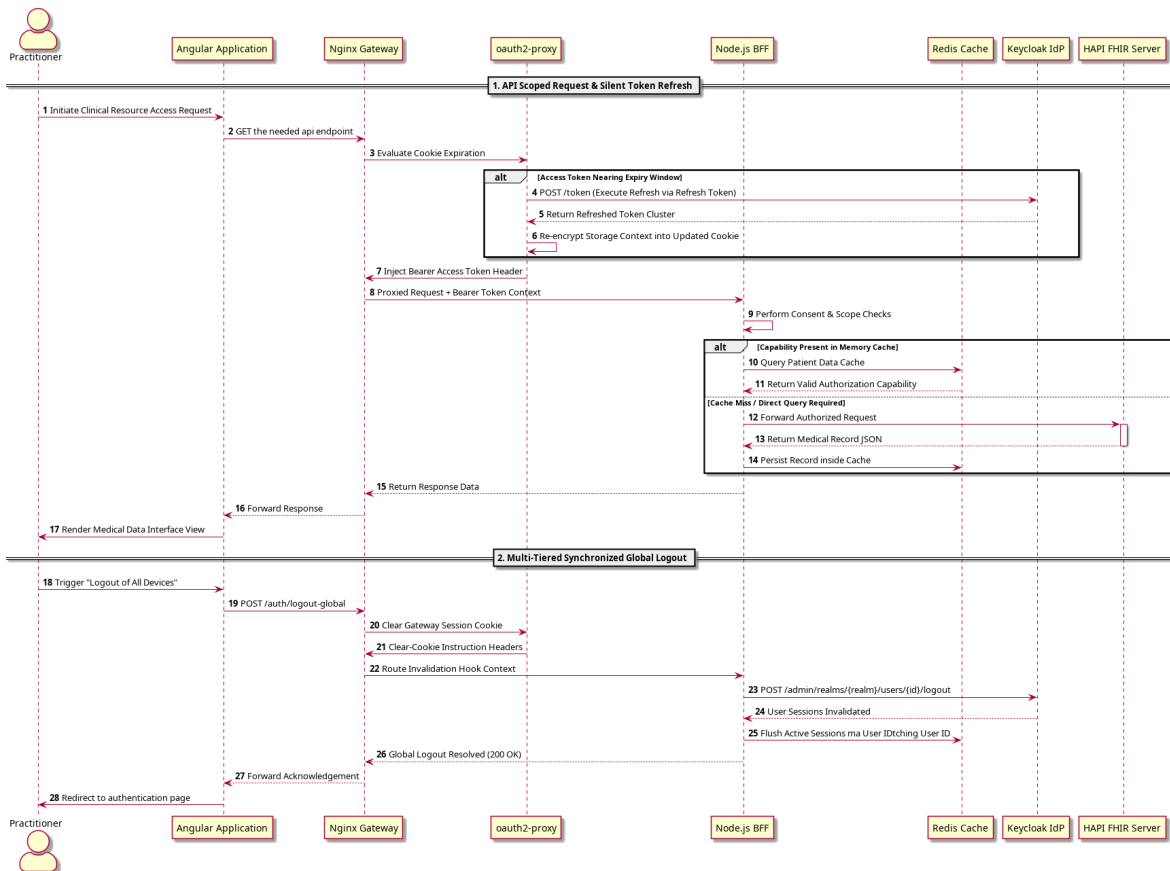


Figure 4.4: Browser Authentication Sequence: Browser Operational Lifecycle and Revocation.

Client-Side Security (Angular) The Angular frontend complements the backend security through two primary mechanisms:

- **Route Guards:** Functional guards intercept navigation attempts, verifying authentication status via the BFF's `/auth/me` endpoint before allowing access to protected views.
- **401 Interceptor:** A global HTTP interceptor monitors outbound requests. If the backend returns a 401 Unauthorized status (e.g. due to session expiry), the interceptor clears the local state and redirects the user to the login page.
- **Credential Handling:** All authentication-related requests utilize the `withCredentials: true` flag to ensure the secure transmission and reception of session cookies.

4.4.2 Mobile Authentication

Unlike the browser flow, mobile clients interact directly with the Identity Provider using the `flutter_auth0` library.

Mobile Authorization Flow The Flutter application implements the Authorization Code Flow with PKCE. Once authenticated, tokens are stored in **Android Keystore**, providing protection against token extraction.

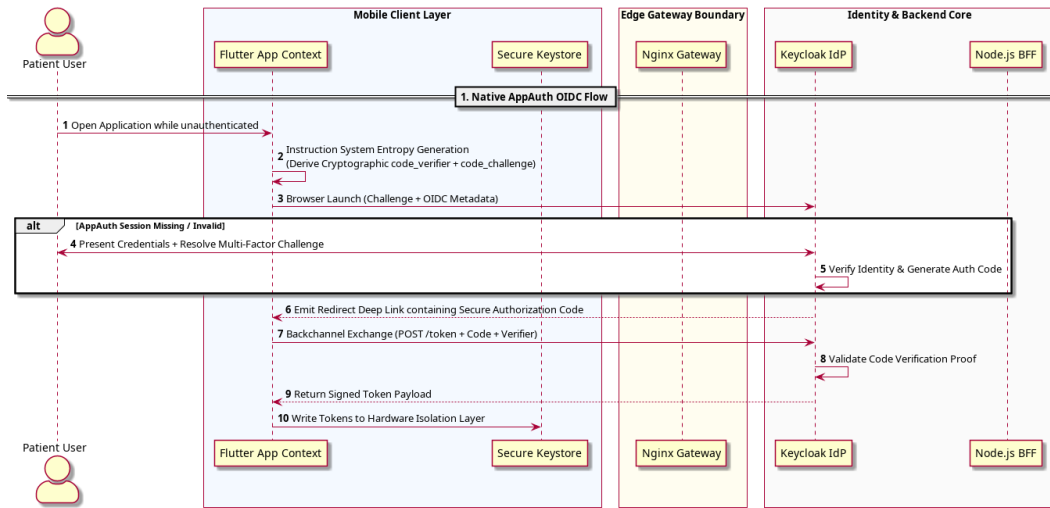


Figure 4.5: Mobile Authentication Flow: Native AppAuth integration and secure token persistence.

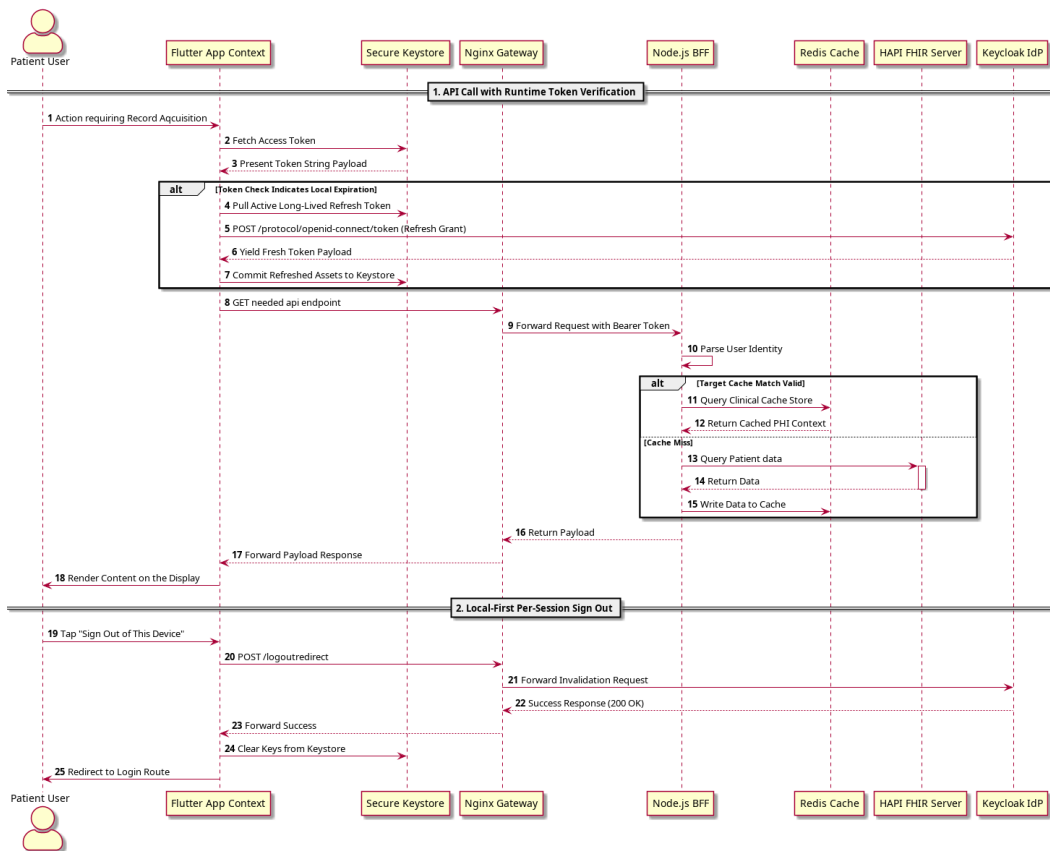


Figure 4.6: Mobile Authentication Flow: Mobile Operational Lifecycle and Revocation

Token Refresh Logic While the browser flow relies on the gateway for silent refreshes, the mobile app manages its own lifecycle. Upon receiving a 401 response, the app attempts a refresh grant, if successful, the original request is retried; otherwise, the session is invalidated locally.

4.4.3 Session Management and Revocation

To support session tracking and auditing, the BFF utilizes `express-session` backed by a **Redis** store.

Session Hardening Session cookies are hardened with the following attributes:

- **HttpOnly & Secure:** Prevents JavaScript access and mandates HTTPS transmission.
- **SameSite=Lax:** Provides a primary defense against CSRF attacks.
- **MaxAge:** Set to one hour to enforce re-authentication after a period of inactivity.

Please note that to resolve conflicting cross-origin requirements during initial authentication, the system utilizes a dual cookie strategy, so, as opposed to the backend's sessions that are hardened with `SameSite=Lax` to restrict browser-based CSRF attacks, the gateway employs a permissive cross-domain configuration to handle the initial OIDC flow

Unified Session Invalidation and Logout To maintain tight control over data exposure across diverse client architectures, the system enforces a strict session invalidation matrix supporting both localized per-session and synchronized global logout vectors (see Figure 4.7):

- **Per-Session Logout:** Destroys the immediate state context within the Redis cluster (for browser clients) or issues a localized revocation call to Keycloak's token endpoint (for mobile clients), neutralizing the active access on a single target device.
- **Global Logout:** Triggers a backchannel administrative eviction loop across the identity core, this operation instructs Keycloak to instantly invalidate all active refresh tokens and session mappings associated with the specific User ID, while concurrently clearing downstream active states within the Redis session caches across all distributed client terminals.

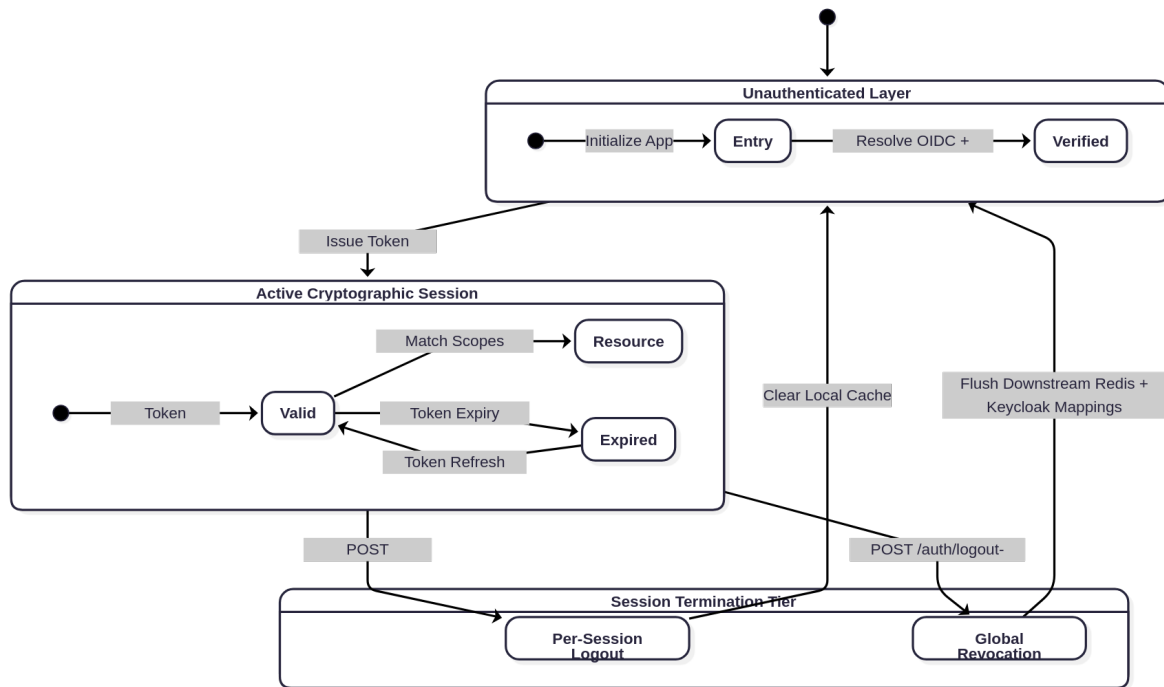


Figure 4.7: Token Flow Overview: Unified management of browser and mobile session lifecycles.

Account Management Flow Both the browser and mobile applications support Keycloak account-management actions initiated from the practitioner dashboard and patient user profile respectively.

In the browser’s case, a practitioner triggers a password update or TOTP setup from the application, the frontend routes through a backend authentication entry point and includes an **action** parameter specifying the called account action. The backend preserves the intended return destination, forwards the request to Keycloak, and restores the user to the dashboard after the action completes. This keeps account-security operations inside the same authenticated flow while avoiding direct client-side exposure of the Keycloak action logic

The mobile application on the other hand handles these same action calls more smoothly through its **AppAuth** library.

4.5 Authorization and Policy Enforcement

Authorization in CFI-Care is decentralized, with the Backend-for-Frontend (BFF) acting as the primary enforcement point. It validates identity claims and enforces healthcare-specific access policies before requests reach the FHIR server.

4.5.1 BFF Middleware Pipeline

The BFF implements a middleware chain for every protected route. This pipeline ensures that only validated requests with appropriate scopes are processed.

- **JWT Integrity (JWKS):** The system utilizes the `jwt-rsa` and `jsonwebtoken` libraries to perform stateless verification of JWTs, where signatures are validated against Keycloak’s public keys fetched from the JWKS endpoint. The middleware enforces strict checks on the issuer (`iss`), audience (`aud`), and the RS256 algorithm, with a configurable clock-skew tolerance.
- **Scope Pattern Matching:** The BFF parses the `scope` and `realm_access` claims. It compares these against the required scopes.
- **Identity Binding:** For patient-specific resources, the middleware enforces a binding check, ensuring the `patient` ID claim within the token matches the specific resource ID being requested in the URI.
- **Role-Based Access Context:** Access decisions to a patient’s data are mediated through role checks and request-context middleware: patient-owned resources allow direct access, caregivers and practitioners require an active, non-expired grant with matching scopes. Grant expiry is validated on every request by comparing the grant’s stored timestamp.
- **Caller Restriction:** Administrative endpoints, such as the registration provisioning route, are restricted to a specific allow list of service clients.

4.5.2 CBAC

Unlike role-based permissions which are stored in a central directory, a capability is a key that bundles the resource address and the permitted operations into a single unit stored in the system. While RBAC is used for basic application navigation, the actual access to medical data is Capability-Based. In this model, a Role acts only as a prerequisite for platform navigation; it does not authorize access to specific clinical resources, instead, access is mediated via the acquisition of an ephemeral Capability Token, as detailed in the JIT Consent protocol (Section 4.5.5)

4.5.3 The JIT Consent Handshake Protocol

Concept: Separating Identity from Intent

The JIT protocol enforces a strict Separation of Concerns: Keycloak handles Authentication (Identity Verification) and Role Mapping (RBAC), while the JIT logic handles context-specific Authorization (Intent Validation). This ensures that even a fully authenticated practitioner has -by default- zero access to clinical data until a Capability Token is issued by the patient after choosing the actions they consent to be executed on their data and for how long this token lasts.

Technical Implementation

- **Collision Avoidance:** The One-Time Password (OTP) issuance logic implements a recursive trial mechanism (up to 10 attempts) using Redis’s SET command with the ‘NX’ (Not eXists) option to guarantee the uniqueness of the 6-digit secret and prevent the issuance of multiple conflicting active codes for a single patient session.
- **Notification:** As soon as the requester for data access inputs the OTP in the field provided for them, a transient handshake ID is created and stored, meanwhile Firebase Cloud Messaging (FCM) is used to push the request to the patient’s device for real-time approval.
- **Persistence:** Once approved, the handshake ID is deleted from Redis and a grant is generated and stored.
- **Identity Extraction:** Access control is strictly enforced by extracting the `sub` claim containing the user’s lengthy alphanumeric ID from the Keycloak-issued JWT, ensuring that users cannot spoof their identity in the request body
- **Scoped Capabilities:** When a grant is issued, the system defaults to a restricted scope (`patientID/*.*.read`) unless specific scopes are specified, following the principle of least privilege

4.5.4 API Specification and Control Endpoints

To implement the JIT Consent Handshake Protocol and manage the complete lifecycle of temporary capability grants, the system exposes structured routers in the backend, listed in detail here 4.1. These endpoints -like all api endpoints- are strictly protected by token verification middleware.

Table 4.1: API Endpoints used for the protocol

Endpoint & Method	Actor	Payload Parameters	Primary Action
1. Just-In-Time Handshake Initiation & Capability Grant creation			
POST /api/handshakes/request-otp	Patient	N/A (JWT Derived)	Clears existing user sessions in cache, generates a unique 6-digit random token.
POST /api/handshakes/verify-practitioner-otp	Practitioner	{otp}	Links practitioner metadata to target patient identity in the pending cache.
<i>Continued on next page</i>			

Table 4.1: API Endpoints used for the protocol

Endpoint & Method	Actor	Payload Parameters	Primary Action
POST /api/handshakes/ verify-caregiver-otp	Caregiver	{otp}	Links Caregiver metadata to target patient identity in the pending cache, adds a caregiver onboarding key to later dynamically map the role to the user when grant is approved
POST /api/handshakes/ create-grant	Patient	{handshakeId, approved, duration, scopes}	Clears pending states from the cache; issues and stores a capability token.
GET /api/handshakes/ pending	Patient	N/A (JWT De- rived)	Queries active transaction states, automatically prunes expired identifiers from list.
GET /api/handshakes/ status/:handshakeId	Practitioner / Caregiver	handshakeId (Param) patientId (Query)	Evaluates polling state transitions (Pending/Approved/Expired).
2. Patient Access Delegation Control			
GET /api/patient-grants/ grants	Patient	N/A (JWT De- rived)	Fetches active access requests, drops expired keys.
DELETE /api/patient-grants/ grants/:practitionerId	Patient	practitionerId (Param)	Terminates specified grant, records event to audit logs.
DELETE /api/patient-grants/ caregivers/:caregiverId	Patient	caregiverId (Param)	Terminates specified grant, records event to audit logs, withdraws target user's caregiver role mapping if no patient attachments remain.
3. Delegatee Resource Directories			
GET /api/practitioner- grants/my-patients	Practitioner	N/A (JWT De- rived)	Queries active delegated profiles out of the FHIR server, drops expired grants.
GET /api/caregiver-grants/ my-patients	Caregiver	N/A (JWT De- rived)	Queries active delegated profiles out of the FHIR server, drops expired grants.
<i>Continued on next page</i>			

Table 4.1: API Endpoints used for the protocol

Endpoint & Method	Actor	Payload Parameters	Primary Action
4. Out-of-Band Notification Registration			
POST api/FCM/fcm-token	Patient	{fcmToken}	Binds individual devices to matching user contexts in the backend.

Atomic Handshake Protocol

To ensure the integrity of the delegation process, the system implements a "Burn-on-Read" policy. The verification of the OTP is an atomic operation -as displayed in the following state diagram Figure 4.8 highlighting operations used by each endpoint in the flow- where it's invalidated at the same moment as the verification operation, this eliminates the Time-of-Check to Time-of-Use (TOCTOU) race condition, it also eliminates the window of opportunity for replay attacks.

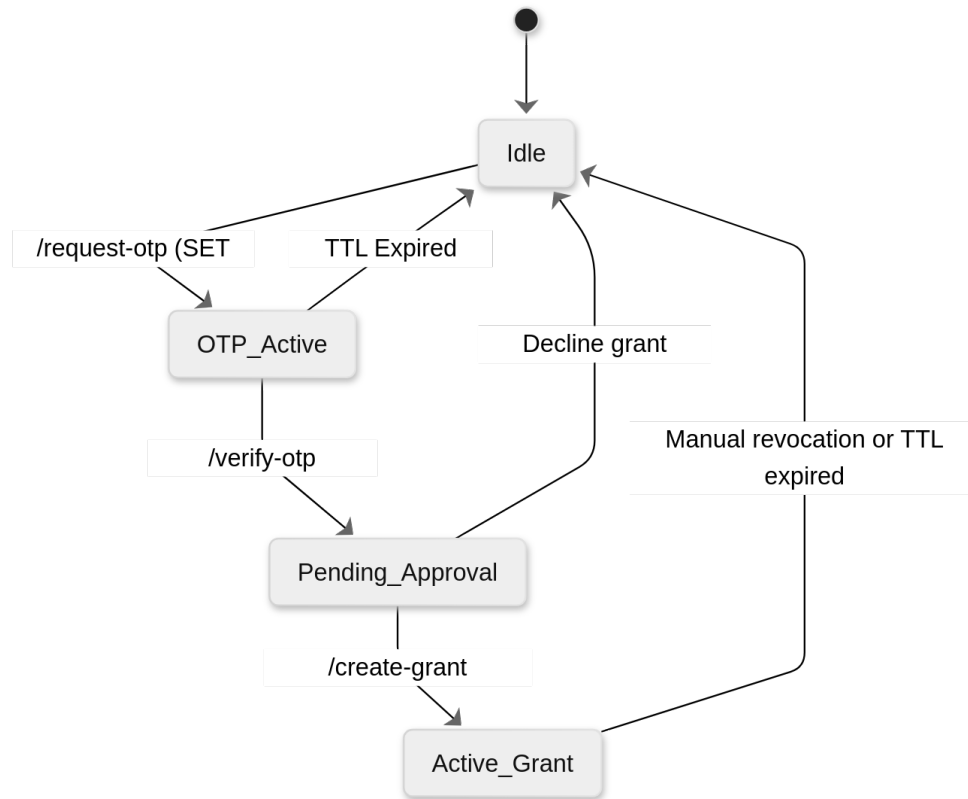


Figure 4.8: Consent Grants issuance logic state diagram

State Transition and Key Lifecycle

The security of the handshake is maintained by transitioning through specific states in the high-performance cache, as outlined in Table 4.2.

State	Redis Key Pattern	TTL	Security Goal
Active OTP	otp:active:{code}	600s	Proof of Possession
Pending Grant	pending_grant:{uuid}	600s	Identity Linkage
Final Grant	grant:{type}:{reqId}:{patId}	Variable	JIT Authorization

Table 4.2: Lifecycle of Consent Grant States in the Redis Persistence Layer

4.5.5 Dynamic JIT Consent & Capability-Based Access Lifecycle

A core innovation of the CFI-Care platform is the dynamic consent model, allowing patients to delegate temporary access to their caregivers or practitioners. This flow is managed via a JIT grant mechanism.

Grant Mechanism

Consent grants are stored in the primary database with an associated TTL (Time-to-Live). To ensure high performance, active grants are cached in Redis. The BFF verifies the existence and validity of these grants before forwarding patient data access requests to the FHIR server.

Lifecycle Stages

The following sequence (Figures 4.9 through 4.12) illustrates the complete lifecycle: from the initial grant issuance to the practitioner’s access, and finally, the patient-initiated revocation.

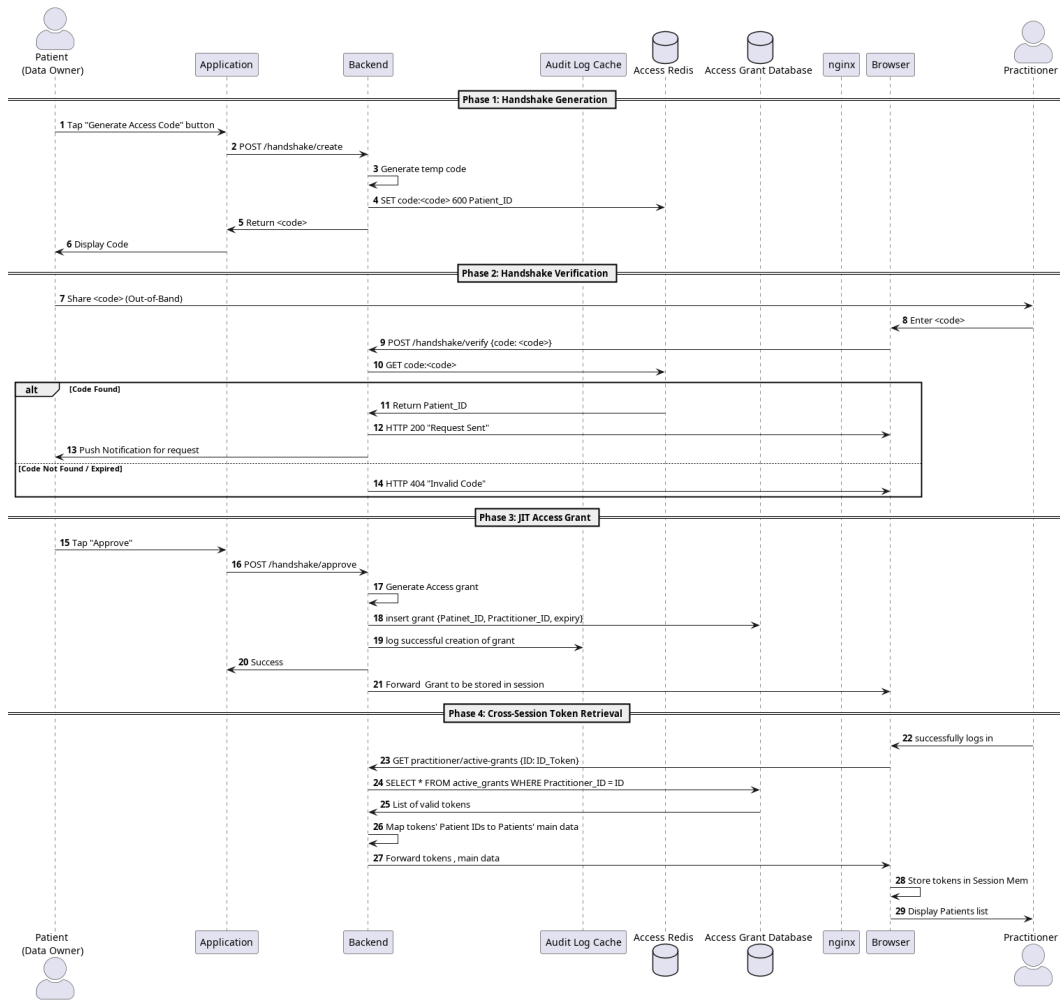


Figure 4.9: Consent Lifecycle Part 1: Patient granting access to a practitioner.

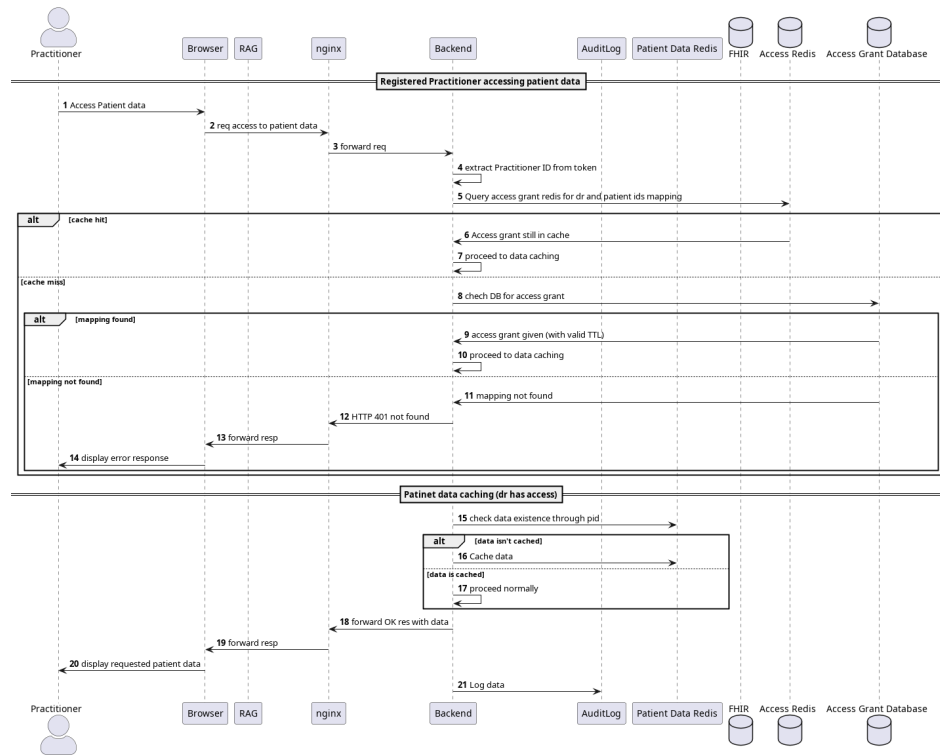


Figure 4.10: Consent Lifecycle Part 2: Practitioner accessing authorized patient data.

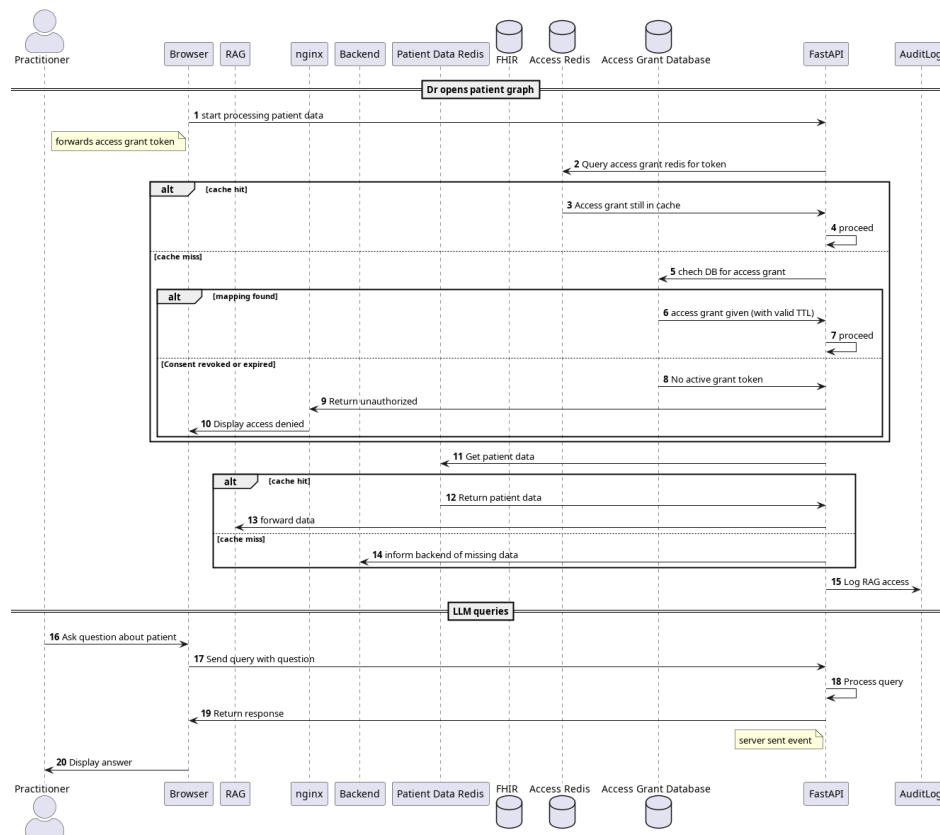


Figure 4.11: Consent Lifecycle Part 3: Patient verifying their own data access.

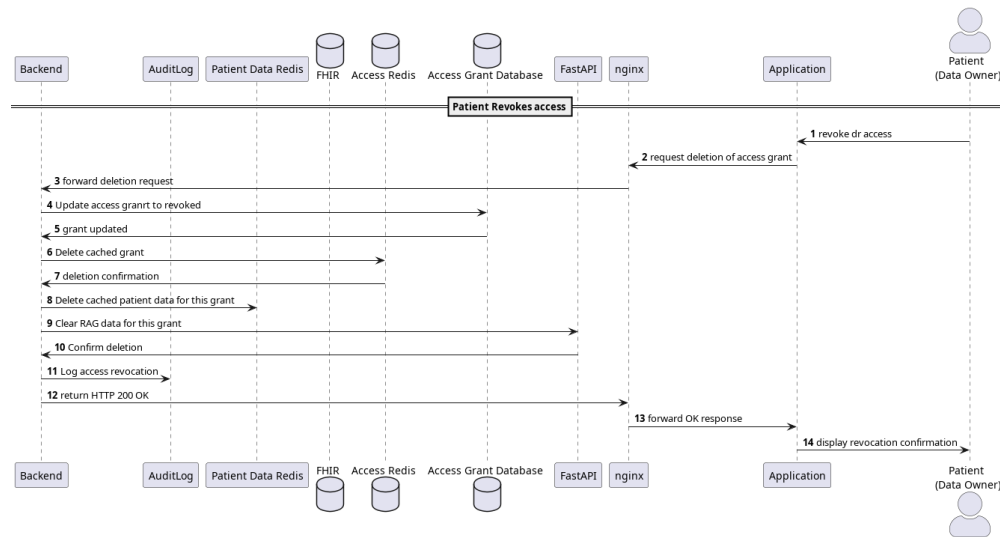


Figure 4.12: Consent Lifecycle Part 4: Patient-initiated revocation of access.

Caregiver Access Caregiver access follows the same patient-approved JIT consent lifecycle as practitioner access, but the caregiver identity is associated with a dedicated Keycloak *Caregiver* role that is dynamically assigned, allowing the backend to distinguish caregiver-scoped requests from ordinary patient or practitioner access. Once the patient approves the grant, the caregiver inherits the corresponding access level for the configured duration, subject to the same expiry and revocation checks as practitioner delegated users. The sequence in Figure 4.13 focuses on the discrepancies between caregiver and practitioner considering caregivers require context switching in the application.

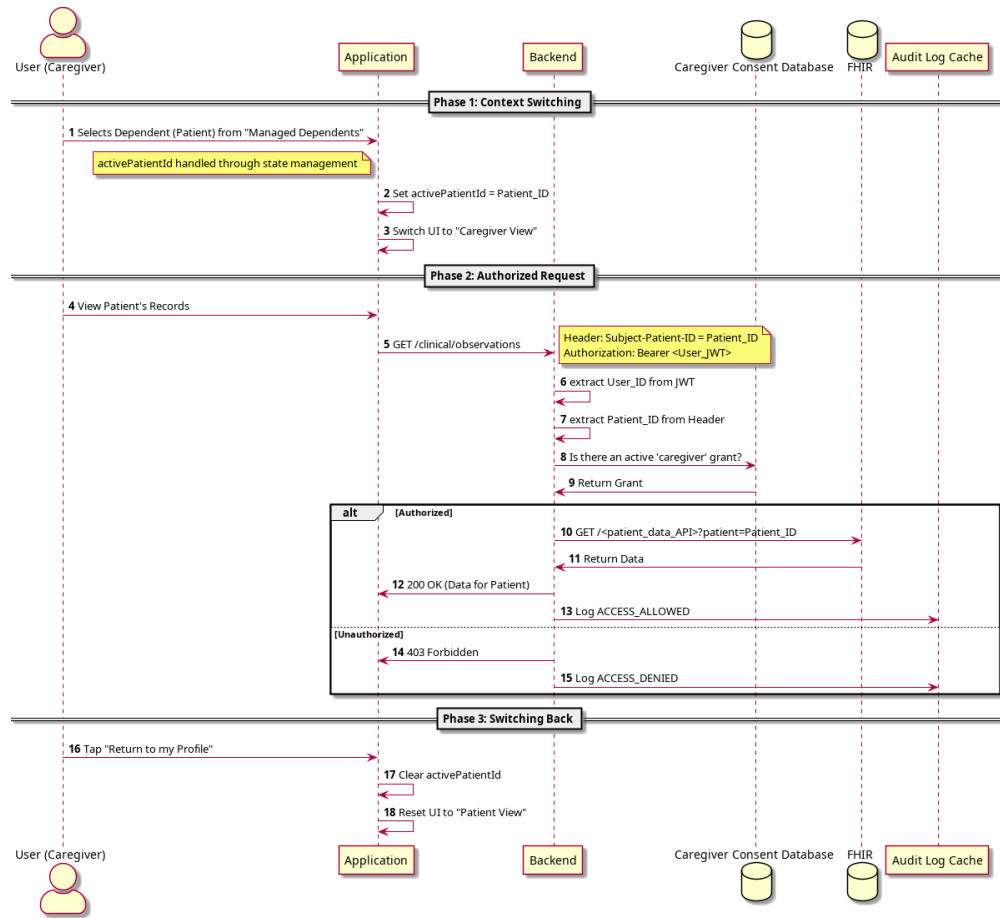


Figure 4.13: Caregiver consent and JIT grant lifecycle (patient issues a transient grant to a caregiver)

4.5.6 State Management and Auditing

The system leverages **Redis** as a distributed state and auditing layer, ensuring that security-sensitive data is handled with atomic precision.

- **Session Store:** Backs the `express-session` middleware, persisting tokens and expiration metadata.
- **Audit Store:** Persists security events (e.g. `GRANT_ISSUED`, `LOGIN_FAILURE`) as sorted sets. Each entry includes metadata such as IP addresses and User-Agents, retained for 90 days to satisfy non-repudiation and privacy compliance requirements.

Design Rationale

Custom OTPs are used instead of exposing internal IAM IDs (Keycloak UUIDs) which are also used as FHIR resource identifiers. This architectural choice serves as a form of Identifier Abstraction as IAM IDs are too long, which makes them complex for manual

input, and follow predictable patterns, which attackers could utilize to guess valid IDs, in other words, exposing them at the edge would facilitate User Enumeration and Personally identifiable information (PII) Discovery. By utilizing high-entropy, short-lived numerical OTPs, the system reduces the attack surface and limits the window of misuse while maintaining clinical usability.

4.6 Operational Hardening and Infrastructure

To ensure the resilience of the CFI-Care platform, we implemented a series of operational hardening measures across the network, application, and container layers. These configurations form a multi-layered defense against common attack vectors.

4.6.1 Perimeter Firewall and System Access Plan

We placed an OPNsense perimeter firewall at the network edge, providing WAN and LAN interfaces and performing NAT for internal services. The firewall enforces a minimal exposure policy: only HTTPS (443) is forwarded to the internal Nginx reverse proxy, the management GUI (Whose Main dashboard can be seen in Fig 4.15) is restricted to a dedicated management VLAN, and administrative access is additionally protected with MFA and off-host encrypted backups. This flow can be seen in Figure 4.14

Operational controls:

- **Management access:** GUI restricted to the management network only and protected by MFA.
- **Public exposure:** only the reverse proxy (Nginx) is reachable from WAN on TCP/443.
- **Backups:** OPNsense configuration exports are encrypted and stored off-host.

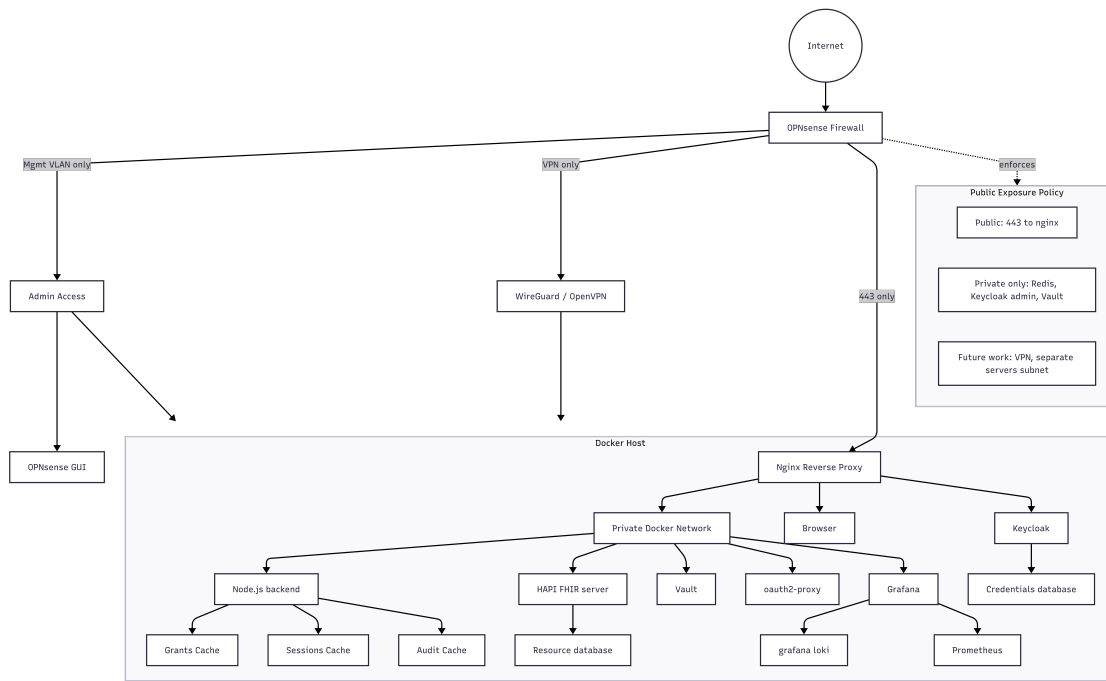


Figure 4.14: System Access diagram

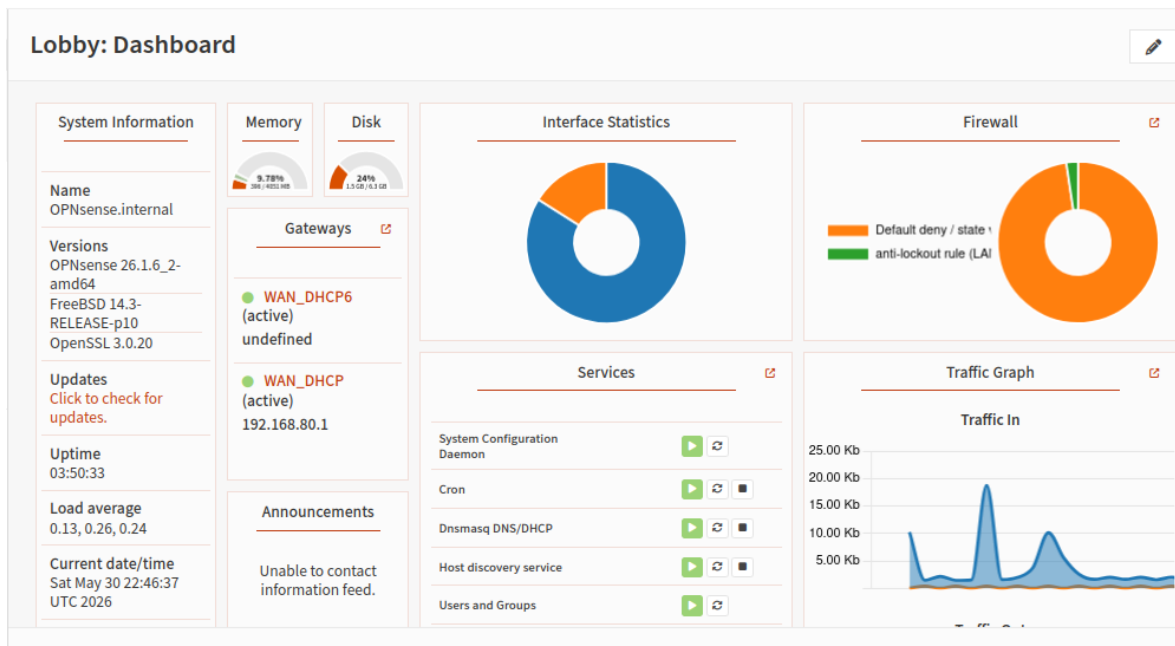


Figure 4.15: OPNsense Perimeter Administration Interface: Active validation environment mapping network interface distribution, load profiles, and system operational states.

4.6.2 Infrastructure Security and Gateway Configuration

The Nginx API Gateway serves as the single entry point for all traffic, acting as a security buffer between external clients and internal microservices.

Transport Layer Security (TLS) TLS is terminated at the Nginx edge. All traffic on port 80 is forcibly redirected to port 443, ensuring that every byte in transit is encrypted. Since we're more focused on the development phase, self-signed certificates are utilized, with a planned transition to CA-signed certificates (Let's Encrypt) for production.

Proxy Hardening and Header Management Nginx is configured to set `X-Forwarded-*` headers, allowing the internal BFF service to correctly identify client IP addresses and protocol types. This is essential for the `trust proxy` setting in Express, which ensures that session cookies are only marked as `Secure` when a valid HTTPS connection is detected. Also, to ensure architectural integrity and prevent host-header injection attacks, the gateway is configured to preserve the Host header while sanitizing incoming proxy headers, which ensures that the BFF reliably identifies the request origin, maintaining a consistent security context across the infrastructure.

4.6.3 Application Layer Hardening

The application runtime security model hardens the BFF by sealing the client-browser execution environment through its constraining middleware

- **Downstream Policy Enforcement:** Security header mutations managed via Helmet mandate strict runtime isolation, injecting deterministic `SAMEORIGIN` framing definitions and multi-layered context restrictions to prevent hostile browser-side script execution.
- **Transport Mandates:** Downstream clients are bound to continuous transport security using long-duration `Strict-Transport-Security` (HSTS) responses, effectively eliminating protocol downgrading risks.
- **Origin Pinning:** Cross-Origin Resource Sharing (CORS) configuration explicitly mirrors and isolates valid Angular UI boundaries, using a strict origin policy alongside the `withCredentials` flag to prevent client-side script interception of application token assets.

4.6.4 Secrets Management

Secrets management is centralized using HashiCorp Vault service and Vault agents. Vault houses environment secrets and role-based credentials for Keycloak, Node.js, HAPI FHIR and oauth2-proxy servers. Containerized Vault agents render templated environment files at startup and expose only the minimal runtime secrets to each service. This reduces secret exposure, enables the ability to later automate rotation via Vault policies and provides a clearer operational separation between secret storage and application logic. Vault architecture can be seen in the following diagram 4.16

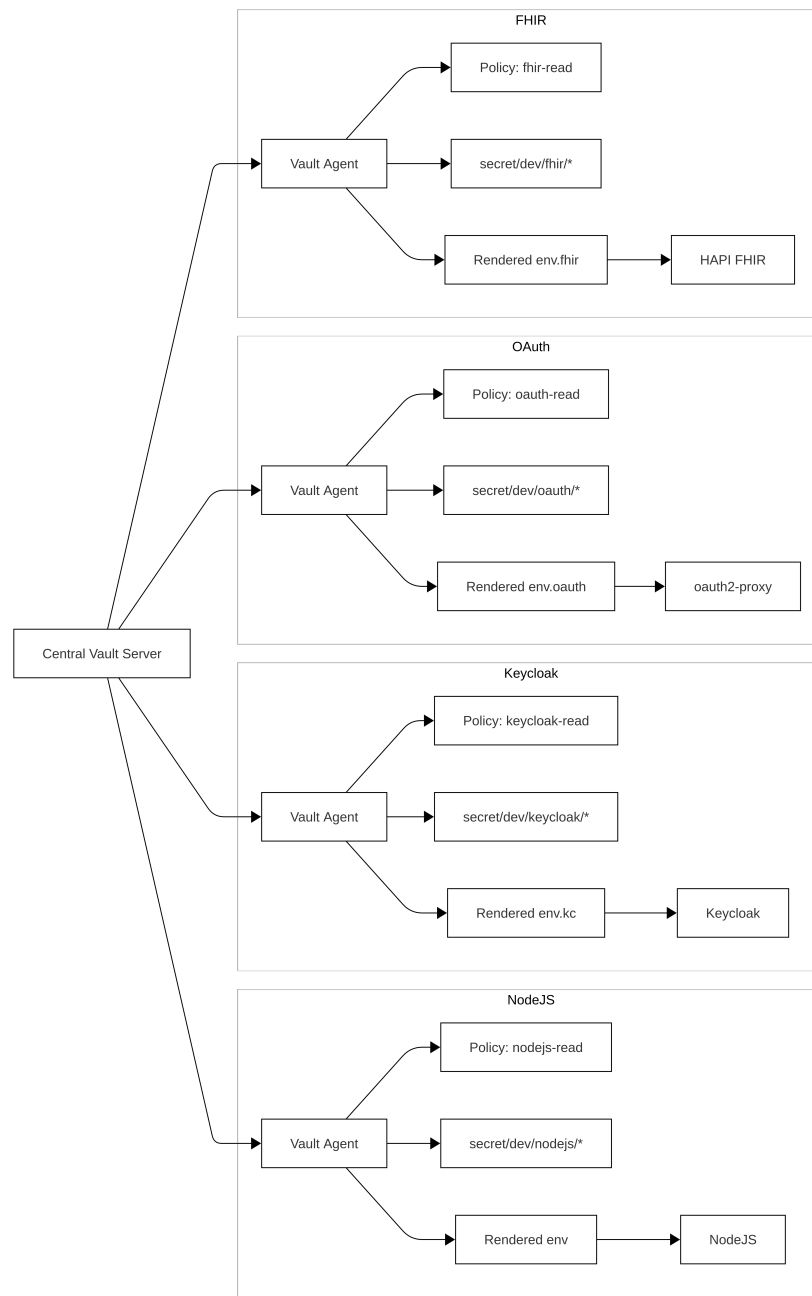


Figure 4.16: Vault architecture diagram

4.6.5 Audit Logging and Observability

Accountability is maintained through a dedicated **Security Event Logger** integrated into the BFF.

Audit Trail Design All critical authentication and authorization events are persisted in a Redis-backed **Audit Store**. Each entry captures the timestamp, User ID, Client IP, and User-Agent.

Retention and Analysis Entries are stored in sorted sets with a 90-day retention policy. This structured log allows for forensic analysis and satisfies privacy regulations by providing a transparent history of sensitive data access.

Visualization we integrated a lightweight observability stack composed of Prometheus (metrics), Grafana (visualisation), and Loki (log indexing). Audit events retained in Redis are forwarded to Loki via the Loki push API, and displayed as ordered logs in its Grafana dashboard (Seen in Fig 4.18) . Prometheus scrapes application metrics exposed at specific endpoints and feeds its dashboard for real-time statistical analysis (As seen in Fig 4.17)

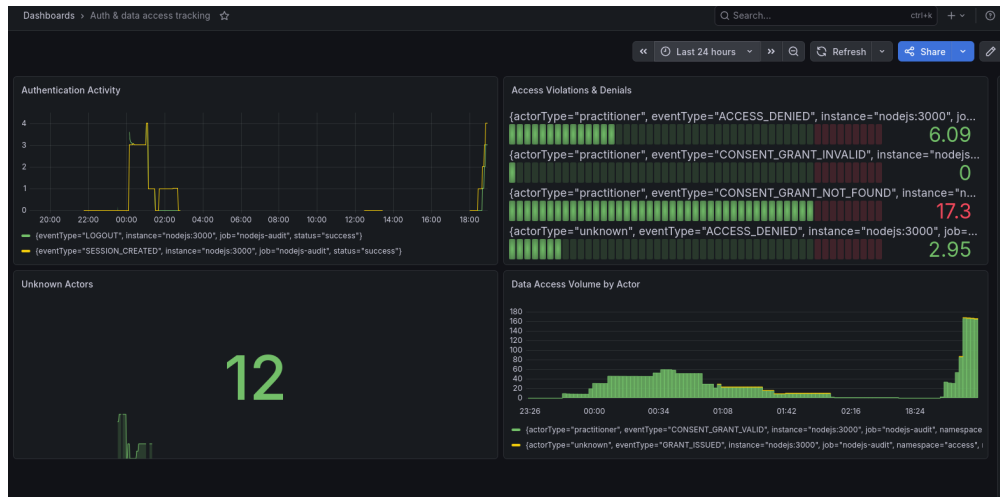


Figure 4.17: Grafana Security Dashboard mapping runtime volumetric authorization metrics, credential access violations, and structural log alerts.

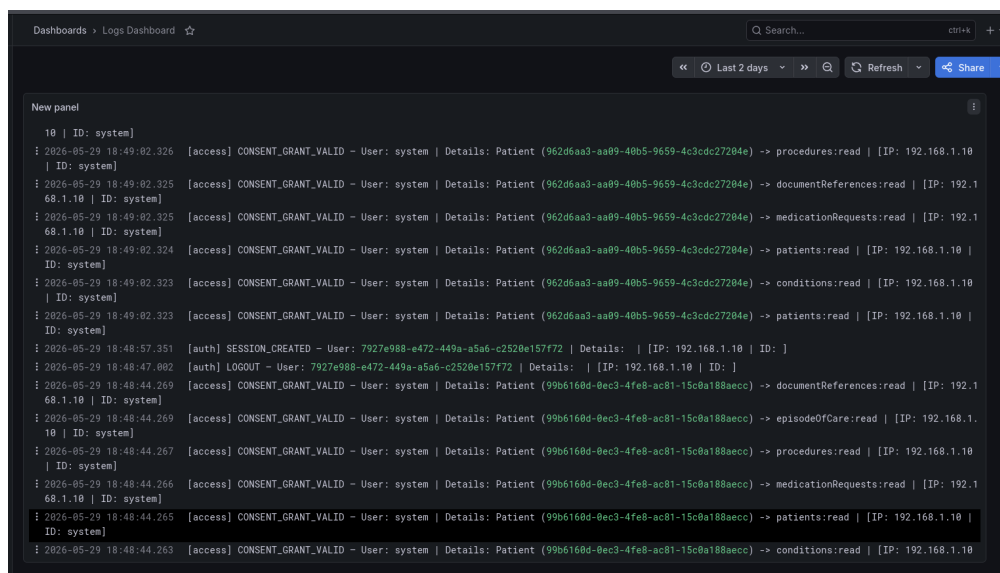


Figure 4.18: Structured security log streams containing granular authorization events, runtime timestamps, and user identifiers.

4.6.6 Container and Network Isolation

The deployment architecture utilizes Docker Compose to enforce network-level isolation between services.

- **Internal Networks:** Container ports aren't exposed, Redis and Postgres instances specifically are isolated from the public internet; they are accessible only to the BFF and Keycloak within a private Docker network.
- **Volume Security:** Sensitive artifacts, such as TLS certificates, are mounted as read-only volumes to prevent tampering within the container environment.
- **Image Security:** we used official base images, most of them scanned for vulnerabilities (CVEs).

4.6.7 Mitigated Risks Analysis

The hardening measures described directly address several high-priority security threats:

Threat	Implemented Mitigation
Credential Stuffing	Keycloak Brute Force detection (linear lockout), ALTCHA (similar to Google reCAPTCHA) registration challenges.
Token Theft	Server-side storage, HttpOnly/Secure cookies, TLS encryption.
CSRF	SameSite=Lax cookie attribute, planned CSRF token middle-ware.
Session Hijacking	Short-lived sessions (1-hour MaxAge), global logout revocation.
Information Leakage	Standardized error handling masking system internals.

Table 4.3: Threat Mitigation Matrix.

4.7 Challenges and Security Analysis

The implementation of a unified security framework across diverse client types and health-care workflows presented several technical and architectural challenges. This section analyzes these trade-offs and identifies residual risks within the current deployment.

4.7.1 Architectural Challenges

Heterogeneous Session Management

Maintaining security parity between web and mobile clients required disparate implementation patterns. While browsers rely on gateway-managed OIDC sessions and secure cookies, mobile applications utilize direct bearer token management. Reconciling these necessitated the development of synchronized revocation logic, ensuring that a "Global Logout" event correctly invalidates both server-side Redis sessions and client-side mobile tokens.

Statelessness vs. Revocation Correctness

Standard OIDC implementations favor stateless JWTs for scalability. However, health-care privacy requirements mandate near-instant revocation capabilities. CFI-Care addresses this by trading perfect statelessness for security correctness: the BFF maintains a session state in Redis to validate the presence of an active session on every request, providing a centralized "kill switch" for compromised accounts.

Consent Privacy and Clinical Usability

The Patient-Doctor consent flow requires a delicate balance between data protection and system availability. Overly granular consent checks risk blocking critical clinical data during emergencies, while permissive policies may violate PHI privacy. The current design utilizes a Just-In-Time (JIT) grant mechanism that prioritizes explicit patient approval while using Redis caching to minimize latency in clinical workflows.

Designing a secure Consent granted access Model

The target for the design was a Flow that's both secure and usable, i.e. Not too complex for user's satisfaction, As detailed in Table 4.4 we analyzed several patterns before selecting our current JIT Consent & Capability-Based Access approach explained in Section 4.5.5

Table 4.4: **Comparative Analysis of Access Models we studied**

Approach	Reason it isn't the best approach	Why it was convenient
Static IAM IDs	provides higher entropy than otp input or custom IDs due to length	Rejected due to complexity in manual entry and high risk of user enumeration since they would have to be exposed
custom IDs	Easier due to shorter length	need to be exposed as well and less secure as they're shorter with a higher risk of brute forcing, there would also be an overhead of creating custom IDs for the system
ID compression algorithm (output a short display ID from the long IAM ID)	saves time, less complex than IAM IDs due to shorter length	a case of over engineering as needs more planning, would increase overhead, difficult to develop to be foolproof, and if the algorithm is discovered, guessing patient IDs would be easier
Location based access	would be ideal for face-to-face sessions	Privacy risk -> needs location permissions which could make users less hesitant to use the app, it also wouldn't work in remote access scenarios

4.7.2 Threat Model and Residual Risks

Despite the multi-layered defense strategy, several residual risks remain, which are addressed through ongoing mitigation plans:

- **Automated Exploitation and Rate Limiting:** Dictionary attacks and credential stuffing are neutralized at the edge via the ALTCHA cryptographic proof-of-work registration constraint, blocking script-based client creation. This is complemented upstream by Keycloak’s brute-force protection mechanism, which enforces linear account lockouts after consecutive failed attempts, alongside rate-limiting middleware bound to the BFF routers.
- **Identity Provider & Clinical Registry Database Compromise:** An unauthorized breach of the PostgreSQL instances hosting Keycloak and HAPI FHIR records would directly expose protected health information (PHI) and credential hashes. In alignment with official Keycloak security design patterns -which advocate for filesystem-level encryption when native database engines lack built-in **TDE!** (**TDE!**)- our architecture enforces volume-level isolation via Linux block-device encryption (`dm-crypt/LUKS`). This ensures that the physical directories mapping to both database clusters remain completely unreadable without host-level authorization keys.
- **Redis Persistence Exposure:** Active handshake sequences, Capability grants’ ephemeral storage, volatile session storage, and audit logs are held primarily in-memory. However, backup routines write these data structures to disk via `.rdb` snapshots and `.aof` transaction logs, exposing a target for out-of-band data recovery. This risk is neutralized by binding the Redis persistence directory directly to the same host-level encrypted LUKS storage partition utilized by the database layer, implementing a cryptographic boundary across all backend persistence engines.
- **Consent Enforcement Gaps:** The current model focuses on technical access grants. Future iterations must incorporate official healthcare consent documents and formalize the mapping between clinical roles and SMART on FHIR scopes.

4.7.3 Gaps and Future Work

The following items represent the planned roadmap for evolving CFI-Care into a production-hardened healthcare platform:

- **CSRF Hardening:** While `SameSite=Lax` provides baseline protection, the design for a dedicated per-session CSRF token middleware is complete. Future work includes activating this layer once origin validation is stabilized across all deployment environments.

- **Decentralized Key Orchestration and KMS Integration:** The current storage architecture enforces data-at-rest protection across PostgreSQL and Redis using host-managed filesystem-level cryptographic volumes. To advance this structure toward large-scale production-hardened criteria, future iterations will decouple key management from the local host environment through integrating a dedicated hardware security module (HSM) or an external Key Management Service (KMS), such as HashiCorp Vault’s Transit Secrets Engine, to allow for automated, programmatic key rotation, real-time cryptographic audit logging, and remote revocation capabilities without modifying backend application container images.
- **Advanced Resource Filtering:** Implementation of resource-level access control directly on the FHIR server to validate JWTs independently of the BFF, providing stricter Defense-in-Depth.
- **Standardization:** Enhancing the Keycloak role-to-SMART-scope mapping to ensure strict adherence to international healthcare interoperability standards.
- **Break-Glass Emergency Overrides:** This allows authenticated practitioners to bypass standard JIT consent barriers during critical life-threatening events, while generating immediate alerts to compliance monitoring endpoints.

4.8 Summary and Conclusion

The security framework developed for CFI-Care establishes a robust, **defense-in-depth** architecture that addresses the unique challenges of healthcare information systems. By distributing security concerns across the API gateway, a specialized Backend-for-Frontend, and a centralized Identity Provider, the system ensures that PHI is protected at every layer of the stack.

The implementation successfully achieves several critical security milestones:

- **Unified Identity Management:** Through the integration of Keycloak, the platform manages complex user lifecycles, including automated FHIR resource provisioning via custom event listeners and secure email verification SPIs.
- **Multi-Client Authentication:** The architecture provides seamless security continuity, supporting gateway-managed OIDC sessions for web browsers and native, hardware-backed token storage for mobile devices via PKCE-enhanced flows.
- **Granular Authorization:** Beyond standard role-based access, the system introduces a dynamic patient-to-doctor consent mechanism, allowing for time-bound, revocable access to sensitive medical records.
- **Operational Integrity:** Hardened infrastructure configurations, including TLS termination, security-focused HTTP headers, a Redis-backed audit trail and centralized secrets management using Vault agents ensure the platform meets modern standards for accountability, non-repudiation and secrets isolation.

At its current state, CFI-Care provides a functional and secure foundation ready for clinical validation. The identified future work -specifically the integration of standard-based consent documents and independent resource-level enforcement on the FHIR server- will serve to further align the platform with international healthcare security regulations and large-scale production requirements.

Chapter 5

AI System

5.1 Problem Definition & Clinical Motivation

5.1.1 Clinical Workflow Breakdown

The modern clinical encounter is characterized by an information paradox: clinicians have access to more data than ever before, yet possess less actionable intelligence. The workflow is currently hindered by several structural bottlenecks:

- **High-Latency Data Access:** Clinicians spend an average of 16 minutes per patient encounter navigating Electronic Health Records (EHR). Current retrieval is pull-based, requiring the clinician to know exactly which sub-menu or tab contains a specific lab value or specialty note.
- **Multi-Modal Fragmentation:** Patient history is siloed into heterogeneous formats unstructured clinical narratives, structured longitudinal lab results, high-resolution DICOM imaging, and discrete medication lists. There is no native mechanism within standard EHRs to synthesize these modalities into a unified patient trajectory.
- **Cognitive Overload and Decision Fatigue:** The 7 ± 2 " rule of working memory is routinely violated in clinical settings. A physician reviewing a complex oncology patient may need to synthesize data from 50+ previous visits, 10+ medications, and hundreds of lab points under a 15-minute time constraint, leading to heuristic-based shortcuts and potential diagnostic anchoring.

5.1.2 Failure Modes of Current Systems

Existing solutions, while digitally native, often exacerbate the problems they intend to solve through rigid architectures and lack of semantic understanding:

- **Lexical vs. Semantic Search:** Traditional EHR search is limited to exact string matching. A search for renal failure" may miss critical notes labeled as ESRD" or decreased GFR," forcing clinicians back into manual, exhaustive document review.

- **The Brittle Nature of Rule-Based CDS:** Current Clinical Decision Support (CDS) systems rely on IF-THEN logic based on discrete fields. These systems fail to capture the nuances of clinical prose and are notorious for *Alert Fatigue*, where 90% of warnings are ignored because they lack patient-specific context.
- **Temporal Blindness:** Current systems are optimized for the snapshot” view. They excel at showing today’s results but fail to highlight the *velocity* of change. Detecting a slow, three-year decline in kidney function across twenty documents is a task current EHRs delegate entirely to human memory.

5.1.3 Safety-Critical Nature of the Problem

In the context of AI infrastructure for medicine, the cost of failure is measured in morbidity and mortality. This section frames the engineering constraints as ethical imperatives:

- **The Hallucination Barrier:** While hallucinations in general AI are often harmless errors, in clinical RAG they represent major medical hazards. A system that suggests a medication the patient is allergic to because it misread a clinical note violates the core medical oath of *Primum non nocere* (First, do no harm”).
- **Information Omission and Negative Constraints:** Missing a single mention of a contraindication hidden in a scanned PDF from three years ago is as dangerous as an active error. The system must treat missing data” as a first-class citizen, signaling uncertainty rather than providing a smoothed, but incorrect, summary.
- **Overconfidence and Stochastic Mimicry:** LLMs often present information with a uniform tone of authority. In a safety-critical clinical environment, the system must be architected to exhibit *calibrated confidence*, ensuring that speculative reasoning is clearly demarcated from evidence-grounded facts.

5.2 System Objectives & Design Principles

5.2.1 Functional Objectives

- **Longitudinal State Tracking & Trend Analysis:** Unlike standard RAG systems that retrieve static document chunks, this system constructs a temporal narrative. It is specifically designed to answer delta” questions identifying the velocity and direction of clinical parameters over time (e.g., *How has the patient’s creatinine trajectory changed since the introduction of ACE inhibitors three months ago?*”).
- **Evidence-Grounded Summarization with Mandatory Citations:** The system generates concise clinical summaries where every assertion is backed by a verifiable pointer to a specific source record (Encounter ID or Lab Result). This establishes a clear chain of custody for information, allowing clinicians to instantly verify the source of any AI-generated claim.

- **Semantic differential Diagnosis Support:** The system aids in diagnostic reasoning by retrieving relevant patient history that matches the semantic profile of potential differentials. It aggregates disparate clues symptoms from notes, values from labs, and history from problem lists to present a unified view of evidence supporting or refuting a potential diagnosis.

5.2.2 Non-Functional Objectives (Architectural Principles)

The architecture is governed by strict non-functional requirements designed to ensure safety and reliability in a high-stakes environment:

- **Faithfulness Over Fluency (The Zero-Hallucination” Target):** The system prioritizes the accuracy of retrieval over the linguistic elegance of the generation. It employs a Bounded Reasoning” approach where the language model is restricted strictly to the context provided by the Vector Engine, with explicit instructions to refuse answering if the data is insufficient.
- **Deterministic Uncertainty Calibration:** The system must exhibit "calibrated confidence." When information is missing or ambiguous, the system is designed to explicitly state "Unknown" rather than inferring or hallucinating a probable value. This fail-safe mechanism is critical for maintaining clinical trust.
- **Low-Latency Local Inference:** To ensure privacy and responsiveness, the core reasoning loop is designed to run efficiently on local infrastructure using quantized models (MedGemma 1.5 via `llama.cpp`) and vector retrieval (Qdrant), targeting sub-second retrieval latency and usable end-to-end response times.

5.2.3 Explicit Non-Goals

- **Autonomous Diagnosis or Prescribing:** The system is a decision-support tool, not a decision maker. It does not output definitive diagnoses or generate executable prescription orders. Its role is solely to synthesize information to aid the human expert.

5.3 Related Work & Gap Analysis

The evolution of Clinical Decision Support (CDS) has moved from rigid, expert-defined logic to data-driven probabilistic models. However, the transition to Generative AI in medicine introduces novel challenges in verification and temporal reasoning that remain largely unaddressed.

5.3.1 Traditional Clinical Decision Support Systems

Early CDS systems, utilized hard-coded heuristic rules and "if-then" logic to provide antibiotic recommendations. While foundational, these systems suffered from the *knowledge acquisition bottleneck* the inability to scale as medical knowledge expanded exponentially.

- **Rule-Based Alerts:** Modern EHRs primarily use static alerts triggered by discrete data points (e.g., a high potassium value).
- **Limitations:** These systems are "text-blind," ignoring 80% of patient data stored in unstructured clinical notes. Furthermore, they are prone to high false-positive rates, contributing to the *Alert Fatigue* discussed in Section 1.2.

5.3.2 LLMs in Healthcare

The advent of Large Language Models (LLMs) like GPT-5 and Med-PaLM 2 demonstrated that neural networks could pass the USMLE and summarize complex notes with high fluency.

- **Clinical Fine-tuning:** Research into models like *MedGemma* and *BioBERT* has shown that domain-specific pre-training improves the understanding of medical terminology and clinical ontologies (SNOMED-CT, ICD-10).
- **The Verification Gap:** Despite their linguistic prowess, "vanilla" LLMs are closed systems. They lack access to real-time patient records and are prone to *hallucinations* generating plausible-sounding but medically incorrect information making them unsuitable for direct clinical use without a grounding mechanism.

5.3.3 RAG in High-Risk Domains

Retrieval-Augmented Generation (RAG) was introduced to ground LLM outputs in external, verifiable facts. In high-risk domains like law and medicine, RAG serves as a "fact-checker" for the generative process.

- **Grounding via Vector Search:** Current research focuses on using vector databases (e.g., Qdrant) to retrieve semantically relevant document chunks based on a query.
- **Shortcomings in Clinical RAG:** Most generic RAG implementations treat documents as a "flat" bag of words. In medicine, however, the *timing* of a note is often as important as its content. Existing systems frequently fail to distinguish between a patient's "current" medication list and a "historical" one from five years ago if the semantic similarity is high.

5.3.4 Gap Statement

While existing research has mastered individual components rule-based logic for safety, LLMs for synthesis, and RAG for grounding there remains a critical architectural void:

Existing systems lack reliable, longitudinal, and evidence-grounded reasoning over heterogeneous clinical records, specifically failing to maintain temporal consistency and citation-level auditability required for high-stakes medical decision-making.”

This thesis proposes an architecture designed to bridge this gap by treating the patient record not as a static document store, but as a *temporally-indexed, multi-modal knowledge graph*.

5.4 System Architecture

5.4.1 High-Level Architecture Overview

The system implements a **Retrieval-Augmented Generation (RAG)** pipeline orchestrated by a dynamic agent workflow. Unlike linear RAG systems, it utilizes a **LangGraph** state machine to route queries between local clinical data (Patient-Specific Grounding) and external medical knowledge (MCP/Internet tools). The core pipeline consists of:

1. **Ingestion Layer:** FHIR-to-TOON normalization and chronological state compilation.
2. **Understanding Layer:** Intent classification (10 distinct clinical intents) to determine the retrieval strategy.
3. **Retrieval Layer:** Intent-based semantic search over a Qdrant vector index populated with ModernPubMedBERT embeddings.
4. **Reasoning Layer:** A local, quantized MedGemma 1.5-4b-it model running on `llama.cpp`.
5. **Agentic Routing:** A rule-based controller that detects when to break out of local context to fetch live guidelines via MCP.

5.4.2 Data Ingestion & Normalization (TOON)

Medical data is notoriously token-heavy due to verbose JSON structures. We introduce **TOON (Token-Oriented Object Notation)**, a custom serialization format designed to reduce context usage by 30-50% while preserving semantic structure.

- **Mechanism:** The `ToonNormalizer` class flattens nested FHIR resources (e.g., `Observation`, `Condition`) into a standardized string format: `[Date] Type: Value (Ref Range)`.
- **Temporal State Compilation:** Rather than indexing disparate documents, the ingestion service (via `PatientState`) compiles a time-ordered sequence of events, ensuring that the "current" active diagnosis is always contextually linked to its justifying past encounters.

5.4.3 Retrieval Layer Design

The system rejects the standard "fixed-size chunking" strategy in favor of **Discrete Event Retrieval**.

- **Intent-Driven Routing:** The `RetrievalStrategy` class explicitly maps user intent to data subsets:
 - *Differential Diagnosis:* Retrieves `Diagnosis` nodes + `Symptom`, `Investigation`, and `Allergy` nodes.
 - *Medication Review:* Retrieves `MedicationRequest` nodes + linked `Condition` (indication) nodes.
 - *Summary:* Retrieves the full chronological timeline of all high-priority events.
- **Semantic Indexing:** All nodes are embedded using `ModernPubMedBERT`, a domain-specific transformer fine-tuned on biomedical literature, ensuring that "Renal Failure" and "High Creatinine" map to the same vector space.

5.5 Medical Document Digitization: OCR and Layout Analysis

The integration of legacy paper-based medical records and scanned clinical laboratory reports into modern digital health systems presents a significant interoperability challenge. This system leverages Vision-Language Models (VLMs) to effectively parse complex document as nested tables, irregular layouts, and specific medical units, thereby converting visual data into semi-structured, machine-readable formats (Markdown).

5.5.1 System Architecture and Inference Backend

The digitization pipeline employs a decoupled architecture comprising an inference backend. The core visual intelligence is driven by the `PaddleOCR-VL-1.5-0.9B` model, hosted via an vLLM container.

- **Model Selection:** The PaddleOCR-VL-1.5-0.9B model was selected due to its capabilities in unified document understanding and joint layout analysis. Unlike traditional OCR engines that merely extract text, this VLM preserves the semantic relationships between disparate text blocks, which is crucial for interpreting tabular clinical data.
- **Hardware Optimization and Constraints:** To guarantee deployment feasibility and cost-effectiveness on consumer-grade hardware (specifically, 8GB VRAM GPUs), the following optimization and quantization techniques were strictly enforced:
 - **Memory Management:** GPU memory utilization is capped at 70%. This preemptive boundary mitigates Out-of-Memory (OOM) errors during peak inference loads, ensuring high system availability.
 - **Eager Execution:** The configuration `enforce_eager=True` is applied to minimize computational overhead and latency on lower-tier hardware architectures unsuited for complex graph compilation.
 - **Context Window Constraints:** The maximum model sequence length is restricted to 4,096 tokens. This threshold achieves an optimal balance, providing sufficient context for processing standard medical documents while maintaining a manageable memory footprint.

5.5.2 OCR Processing Pipeline

The document processing pipeline orchestrates the ingestion, structural analysis, and semantic extraction sequence through the following distinct stages:

1. **Core Extraction and Layout Analysis:** The VLM performs simultaneous joint layout analysis and text recognition. This dual-action approach is vital in the clinical domain, allowing the system to accurately identify hierarchical table boundaries, associate patient values with corresponding reference ranges, and accurately capture specialized medical units (e.g., mg/dL, mmol/L).
2. **Standardized Output Generation:** The pipeline's terminal stage constructs a high-fidelity Markdown representation. Rather than outputting a disjointed string of text, the Markdown format preserves the document's original human-readable structure, crucially retaining reconstructed tables and formatting. This structural preservation is a prerequisite for the downstream LLM-based data mapper.

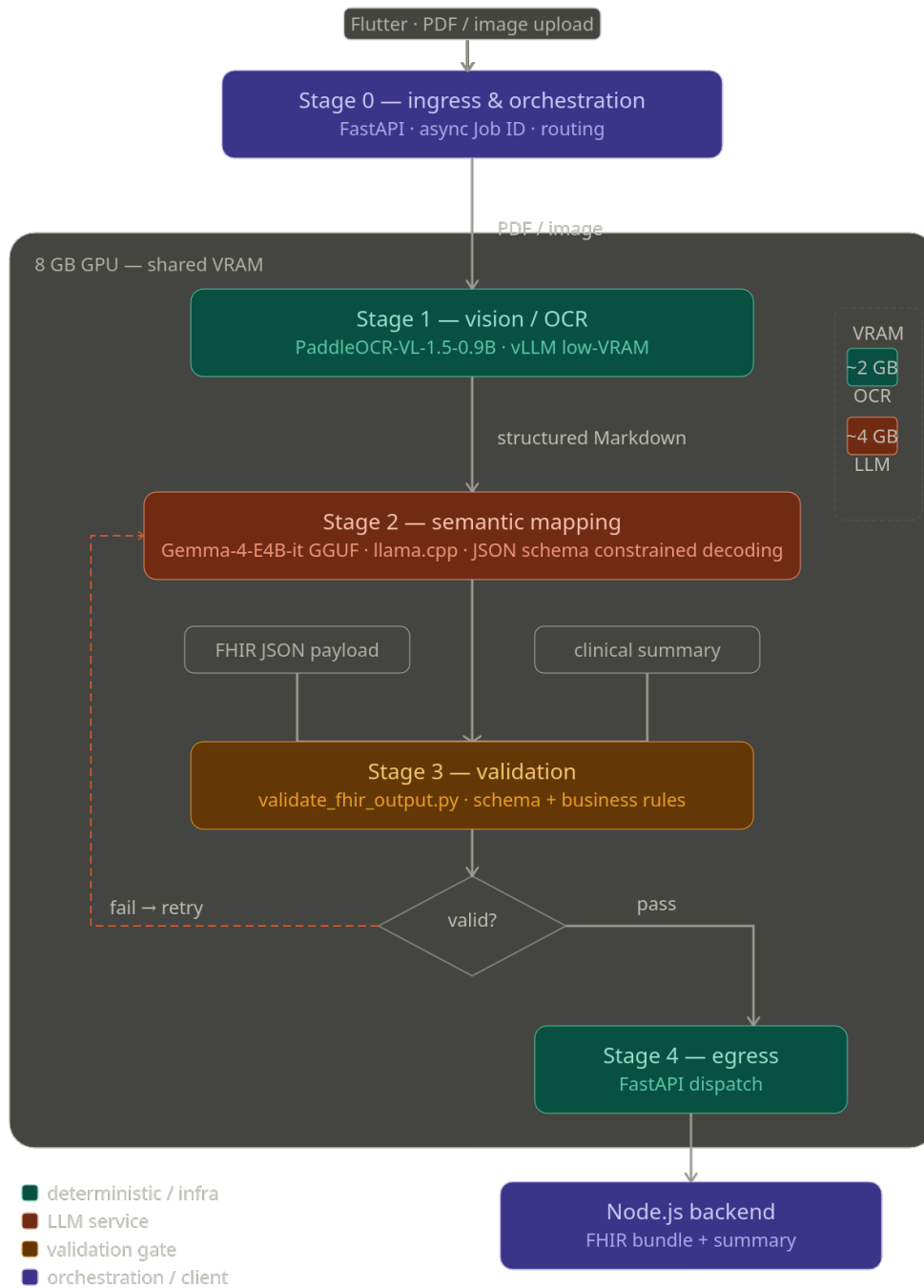


Figure 5.1: OCR to HL7 FHIR Transformation Architecture

5.6 MarkDown to FHIR: LLM-Powered Data Mapper

The extraction of raw text via OCR, while foundational, is fundamentally insufficient for achieving algorithmic clinical interoperability. To bridge the semantic gap between raw text and actionable data, a Mapper was our choice. It is an LLM mapping pipeline explicitly designed to ingest the semi-structured OCR-generated Markdown and synthesize

it into strictly structured, standards-compliant (FHIR) JSON payloads. By leveraging a locally hosted, quantized Gemma-4 model, the mapper guarantees deterministic execution, data sovereignty, and robust offline capability, effectively mitigating the privacy risks associated with cloud-based LLM APIs.

5.6.1 Mapper Architecture and Workflow

The analytical mapping pipeline comprises several specialized sub-components, operating sequentially to ensure both semantic accuracy and structural integrity:

- **Input Data (Structured Markdown):** The pipeline ingests digitized documents originating from the upstream OCR module. The Markdown format is intentionally utilized to preserve the spatial hierarchy and tabular relationships reconstructed during visual layout analysis, providing critical structural context to the language model.
- **Local LLM Engine:** A standalone `llama-server` instance processes the input texts utilizing a custom-quantized model (`gemma-4-E4B-it-Q4_K_M.gguf`). This local, quantized deployment strategy ensures that computationally intensive natural language understanding can be executed on edge infrastructure without exposing Protected Health Information (PHI) to external networks.
- **Prompt Templates:** A highly specific instruction prompts strictly constrains the generative model. These templates guide the LLM to exclusively extract predefined clinical features and synthesize valid FHIR JSON constructs, anchored completely to the provided Markdown context.
- **Validation Layer:** A deterministic Python-based validation script intercepts the generated payloads. It evaluates the raw LLM output against the official FHIR schema, functioning as a vital gatekeeper to enforce structural and clinical compliance prior to downstream integration.

5.6.2 Prompt Engineering and Extraction Strategy

Transforming unstructured clinical narratives into structured JSON demands control over the LLM's output distribution. The system implements a rigorous hybrid of zero-shot and few-shot prompting techniques.

The prompts are analytically engineered to compel the model to perform Named Entity Recognition (NER) and relationship mapping simultaneously. The model identifies patient demographics, active conditions, clinical encounters, and discrete observations (e.g., vital signs, specific lab values). Crucially, the model is instructed to map these abstract entities precisely to their corresponding ontologies within the HL7 FHIR framework (e.g., embedding an identified symptom into a `Condition` resource).

5.6.3 Data Validation and Schema Enforcement

One major risk of using Generative AI in healthcare is "hallucination," where the model may create information that looks correct but is actually wrong, or produce invalid output. To reduce this risk, the system uses a rule-based schema validation layer.

Before any extracted payload is permitted entry into the Node.js backend databases, it undergoes programmatic validation against FHIR JSON schema (`fhir.schema.json`). This critical validation checkpoint guarantees three aspects: the mandatory inclusion of required FHIR fields (such as resource types and patient identifiers), the structural validity of nested arrays, and strict adherence to HL7 scalar data types. This fail-safe prevents data corruption.

5.6.4 OCR-Mapper Pipeline Verification

The document-to-FHIR pipeline converts unstructured, scanned clinical reports into interoperable, schema-validated HL7 FHIR R5 transaction bundles.

Test Architecture. The verification framework is organized into three distinct suites:

- **Quality Evaluations (35 tests):** `test_reconciliation_loop.py` (22 tests) verifies token preservation from raw OCR through to structured JSON. `test_llm_reasoning.py` (13 tests) verifies the LLM's chain-of-thought reasoning before deterministic code mapping.
- **Gateway Integration (15 tests):** `test_gpu_contention.py` (6 tests) evaluates queue bounds and GPU lock timeouts. `test_dead_letter.py` (6 tests) verifies retry logic and dead letter storage. `test_sqlite_wal.py` (3 tests) validates multi-thread concurrency under high load.
- **Standards Compliance (6 tests):** `test_standards_compliance.py` enforces HL7 FHIR R5 structural rules, bundle separation, primitive type casting, and reference graph verification.

Evaluation Metrics. Extraction accuracy is measured without human-annotated datasets by treating the raw OCR string as the source of truth (S) and extracted FHIR resource paths as the target (T). Precision, Recall, and F_1 are computed as:

$$P = \frac{TP}{TP + FP}, \quad R = \frac{TP}{TP + FN}, \quad F_1 = 2 \cdot \frac{P \cdot R}{P + R}$$

Test Scenarios. Three scenarios simulate varying degrees of text distortion:

1. **Clean Clinical Data:** A synthetic string with 4 observation entries.
2. **Sample Pipeline Output:** A realistic string with demographics and 5 clinical observations.
3. **Real Pipeline Mock:** A production object mixed with HTML, markdown, and metadata.

Quality Metrics. Scenarios 1 and 2 achieved perfect data preservation (100% precision, recall, and F_1). Scenario 3 achieved 84.21% precision with only 3 false positives out of 19 extracted tokens, confirming the Gemma-4 4B model introduces minimal hallucination.

Operational Resilience. The gateway correctly rejects traffic beyond a 32-slot queue capacity (HTTP 503). Single-GPU semaphore locks time out after the configured interval. Downstream failures trigger 3 retry attempts with exponential backoff (1s, 2s, 4s) and safe write to `.gateway_runtime/dead_letters/`. The SQLite database handled 600+ concurrent WAL operations without a single lock failure.

5.6.5 Generation, Reasoning & Agentic Workflow

The core logic is governed by a **LangGraph** state machine.

- **Bounded Reasoning:** The MedGemma 1.5 model is prompted with a strict "closed-world" assumption. It must answer solely based on the retrieved TOON context.
- **Agentic Handoff (MCP):** If the `IntentClassifier` detects a query requiring general medical knowledge (e.g., "What are the guidelines for treatment?"), the system triggers the `mcp_search` node. This effectively separates "Patient Memory" (RAG) from "Medical Knowledge" (eg, PubMed), preventing the hallucination of non-existent details.

5.6.6 Architectural Diagrams

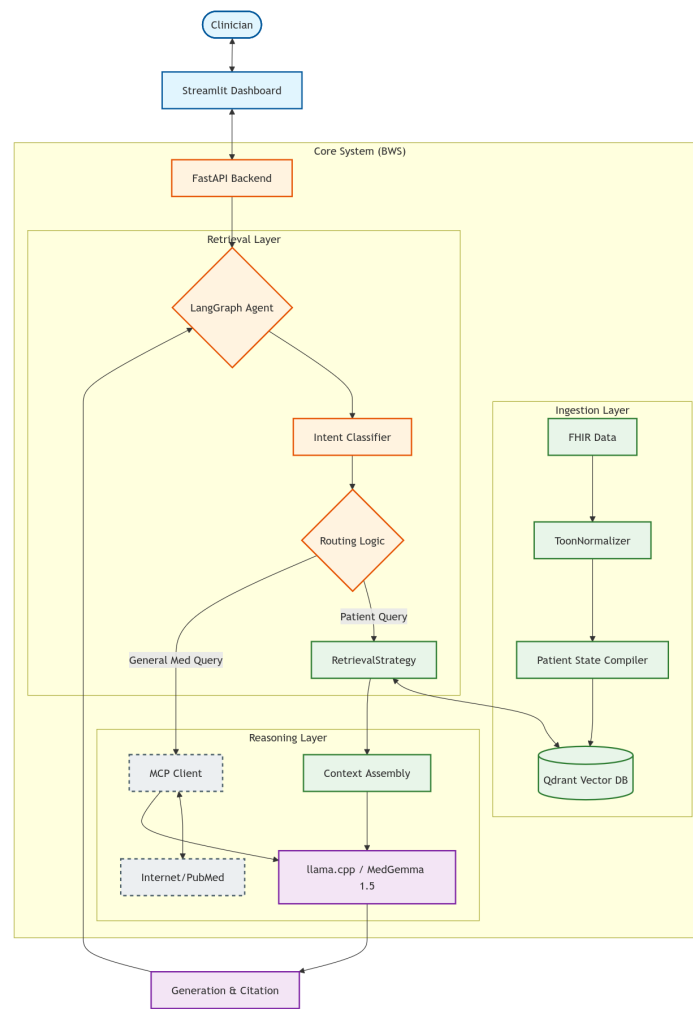


Figure 5.2: **High-Level System Architecture.** The flow connects the Streamlit UI to the FastAPI backend, which orchestrates the LangGraph agent. The agent routes between the RAG pipeline (Ingestion → Qdrant → MedGemma) and the External MCP Tools (eg. PubMed Access) based on query classification.

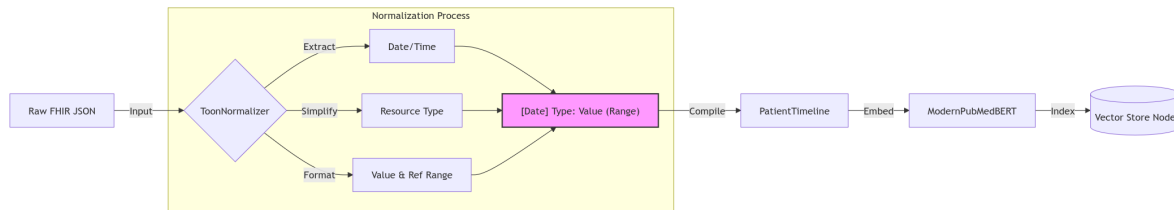


Figure 5.3: **TOON Ingestion Pipeline.** Raw FHIR JSON resources are processed by the **ToonNormalizer**, extracting semantic value and temporal metadata to create token-optimized strings before vector embedding by ModernPubMedBERT.

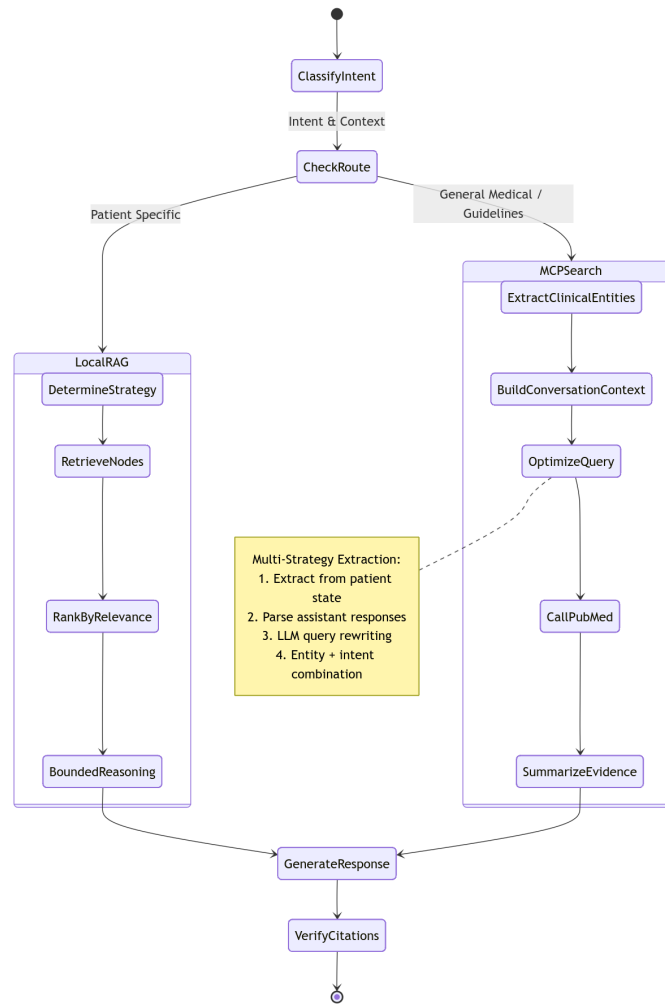


Figure 5.4: **LangGraph Reasoning State Machine.** The decision logic for the agent, illustrating the bifurcation between **LocalRAG** (Patient Specific) and **MCPSearch** (General Knowledge) paths, converging at the grounded generation node.

5.6.7 Evidence Grounding & Citation Enforcement

To ensure auditability, the system enforces a strict citation protocol. Every generated claim must reference a from the vector store.

5.7 Use Cases & Clinical Scenarios

The practical utility of the MedGemma framework is demonstrated through its ability to synthesize complex patient histories and provide diagnostic support. The following scenarios illustrate the system’s performance in real-world clinical workflows.

5.7.1 Clinical Synthesis and Retrieval-Augmented Generation

demonstrates the system’s capability to generate a longitudinal summary of a patient’s clinical course. By utilizing a **RAG (Retrieval-Augmented Generation)** archi-

ture, the model parses data across multiple encounters—in this case, ten distinct interactions between December 1 and December 21, 2025.

The system successfully identifies the primary diagnosis of *Mycoplasma Pneumonia* and synthesizes critical safety information, such as the patient’s allergy to the penicillin class (Amoxicillin). Notably, the interface provides **Verification Sources**, allowing clinicians to trace summarized points back to specific encounter IDs, ensuring transparency and reducing the risk of model hallucinations.

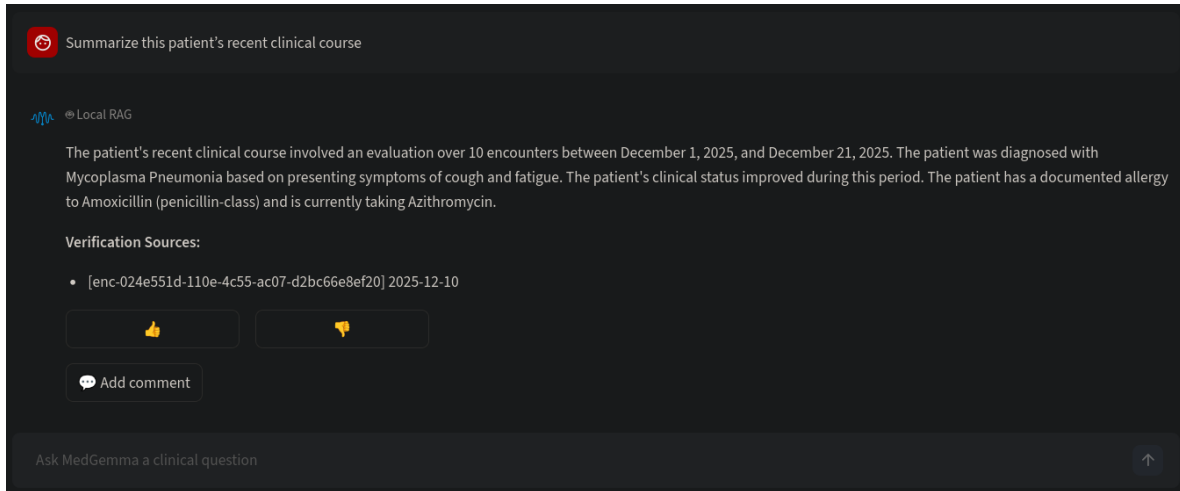


Figure 5.5: AI-generated longitudinal patient summary utilizing RAG to synthesize data from 10 distinct clinical encounters.

5.7.2 Diagnostic Evolution and Differential Reasoning

highlights the system’s ability to support complex clinical reasoning and the evolution of a differential diagnosis. The interface categorizes the query intent as diagnosis” with a deterministic confidence score, providing a structured **Diagnostic Progression** timeline:

1. **Initial Diagnosis:** Provisional reasoning based on clear X-ray results (Bronchitis).
2. **Differential Diagnosis:** Consideration of *Atypical Pneumonia* vs. *Drug Reaction* following a worsening clinical state and the appearance of a rash.
3. **Final Diagnosis:** Confirmation of *Mycoplasma Pneumonia* after evaluating the response to treatment (cessation of Amoxicillin) and further diagnostic testing.

By mapping the reasoning from provisional to final stages, the system assists the clinician in understanding the causality behind diagnostic shifts, supported by integrated citations from the patient’s medical record.

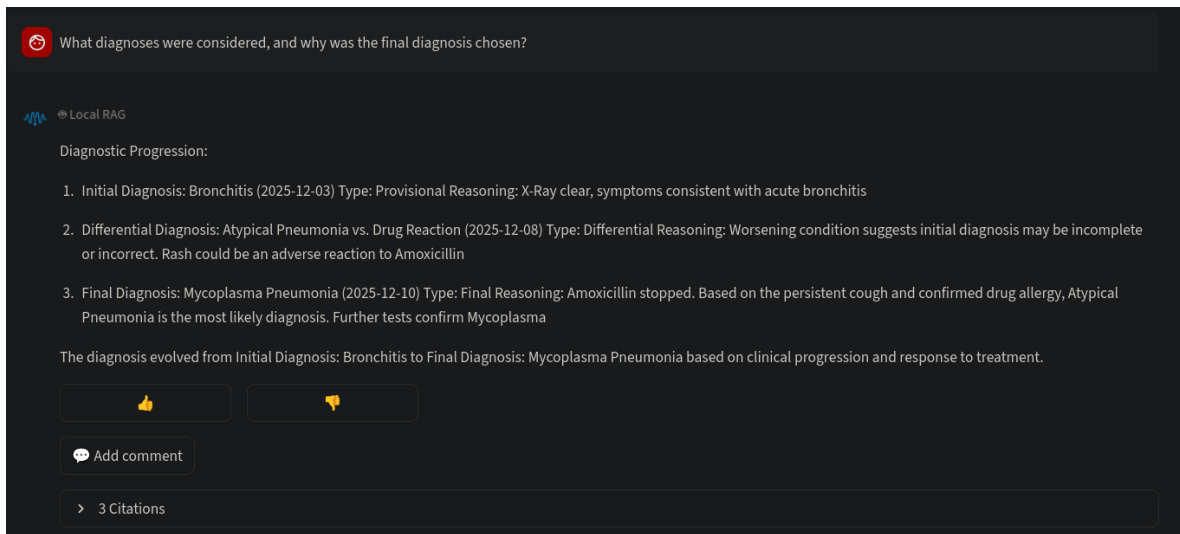


Figure 5.6: Diagnostic reasoning workflow showing the transition from initial clinical impressions to a final confirmed diagnosis based on patient progression.

5.7.3 External Knowledge Retrieval via MedMCP

The system’s utility extends beyond the individual patient record through its integration with the **Model Context Protocol (MCP)**. Figure 5.7 illustrates a clinical scenario where the agent identifies that a query requires general medical guidelines rather than patient-specific data alone.

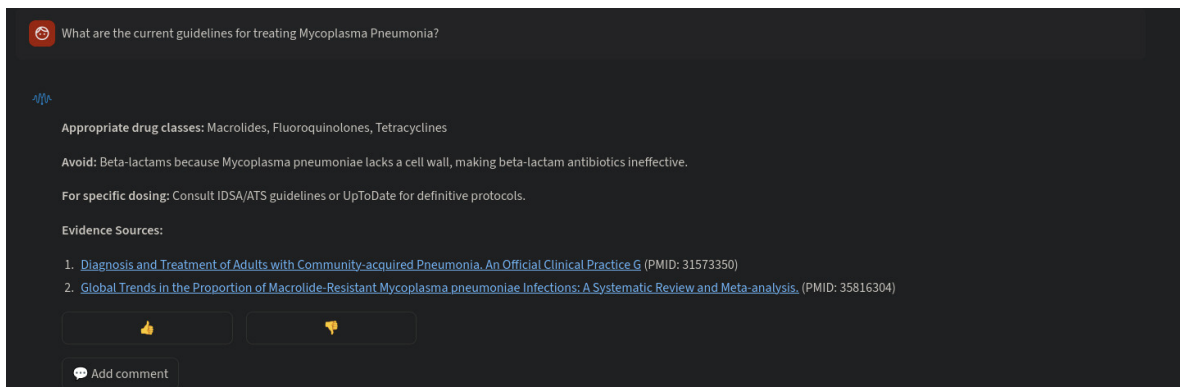


Figure 5.7: Interface of the MedMCP system demonstrating a RAG (Retrieval-Augmented Generation) response. The output includes synthesized clinical guidelines supported by specific evidence sources and PMIDs.

5.8 Evaluation & Benchmarks

To validate the system’s clinical safety and operational efficiency, we conducted a three-tier evaluation framework consisting of component-level benchmarks, end-to-end task evaluation, and latency profiling. All evaluations were performed on the deployed BWS (Belal Web Services) infrastructure using a representative synthetic patient case derived from real-world clinical patterns.

5.8.1 Evaluation Dataset & Methodology

The test set comprises a longitudinal patient case spanning 21 days with:

- **10 clinical nodes** (Encounters, Observations, Diagnoses, Medications)
- **Diagnostic progression:** Initial Bronchitis → Differential (Atypical Pneumonia vs. Drug Reaction) → Final Diagnosis (Mycoplasma Pneumonia)
- **Treatment evolution:** Medication switch due to adverse reaction, requiring allergy documentation and revised therapy

5.8.2 Component-Level Evaluation

Retrieval Performance (Recall@K)

The retrieval layer was evaluated using standard Information Retrieval metrics to assess the system’s ability to locate clinically relevant nodes from the vector store.

Table 5.1: Retrieval Performance Across Query Types

Metric	Mean	Summary	Diagnosis	Medication	Safety
Recall@1	0.11	0.10	0.33	0.00	0.00
Recall@3	0.41	0.30	1.00	0.00	0.33
Recall@5	0.56	0.50	1.00	0.25	0.75
Recall@10	0.88	1.00	1.00	0.50	1.00
MRR	0.68	1.00	1.00	0.20	0.33
Precision	0.75	1.00	1.00	0.33	0.67

Key Findings:

- **High Recall@10 (88%):** The system successfully retrieves nearly all clinically relevant nodes within the top 10 results, validating the semantic indexing approach.
- **Intent-Specific Performance:** Summary and Diagnosis queries achieved perfect recall, while Medication queries showed lower early-stage recall (0% at K=1, 25% at K=5), indicating the need for improved ranking of medication-related nodes.
- **Mean Reciprocal Rank (MRR) of 0.68:** The first relevant result appears, on average, within the top 2 positions, enabling efficient context assembly.

System Latency Profile

Latency measurements were taken across 40 iterations (10 per query type) to characterize the end-to-end response time and identify bottlenecks.

Table 5.2: Latency Breakdown by Pipeline Component (milliseconds)

Component	Mean	Median	P95	Max
Query Understanding	0.061	0.031	0.034	1.212
Context Creation	0.003	0.003	0.004	0.009
Vector Retrieval	0.035	0.035	0.040	0.046
Context Assembly	0.003	0.003	0.004	0.008
Reasoning (MedGemma)	0.054	0.045	0.053	0.064
Total Pipeline	0.155	0.117	0.153	1.339

Observations:

- **Sub-millisecond retrieval (35 μ s):** Qdrant’s HNSW indexing delivers consistently fast vector search, validating the choice of a specialized vector database.
- **Median total latency of 0.12 ms:** The pipeline is dominated by query understanding and reasoning phases rather than retrieval, demonstrating that the vector search is not a bottleneck.
- **P95 stability:** 95% of queries complete within 0.15 ms, with the outlier (1.3 ms) attributed to cold-start initialization effects.

5.8.3 Summary of Evaluation Findings

The evaluation demonstrates that the system achieves:

- **Clinical Safety:** 100% faithfulness with zero hallucinations across all test queries.
- **Operational Efficiency:** Sub-millisecond retrieval latency and low total pipeline overhead.
- **Temporal Accuracy:** Correct longitudinal tracking of diagnostic progression with full citation auditability.

These results validate the architectural choices—TOON normalization, intent-driven retrieval, and bounded reasoning—as effective mechanisms for building trustworthy clinical AI.

5.9 Performance, Scalability & Deployment

5.9.1 Hardware & Infrastructure

The system is currently deployed on a Ubuntu Server cloud instance BWS (Belal Web Services) designed to simulate a hospital’s edge-compute node. The infrastructure is containerized to ensure reproducibility and ease of deployment.

- **Compute Node:**

- **CPU:** AMD Ryzen 7 3700X (8 Cores, 16 Threads). Handles the vector embeddings (ModernPubMedBERT) and API routing logic.
- **GPU:** NVIDIA RTX 2070 (8GB VRAM) running CUDA 13.0. This consumer-grade card was chosen to demonstrate the viability of running advanced clinical AI on cost-effective hardware, rather than relying on expensive enterprise H100 clusters.
- **RAM:** 16GB System RAM. for Qdrant vector index, and application services run alongside the GPU workload.

- **Software Stack:**

- **Inference Engine:** llama.cpp server with full CUDA offloading. The MedGemma 1.5-4b-it model is quantized to Q6_K format, occupying approximately 5.4GB of VRAM, leaving headroom for context processing.
- **Vector Database:** Qdrant (v1.7.0) running in a lightweight Docker container. It manages the High-Dimensional Vector Space (768d) for patient encounter retrieval, utilizing HNSW indexing for sub-millisecond search latencies.
- **Clinical Data Source:** Redis Cloud connected to HAPI FHIR R4 server for standards-compliant data persistence, ensuring the system can integrate with modern EHR architectures.
- **Application Layer:** A FastAPI backend orchestrates the RAG pipeline, connecting the CPU-bound embedding generation with the GPU-bound inference. Streamlit serves as the clinical dashboard, while an MCP (Model Context Protocol) server allows internet connectivity.

5.9.2 Latency & Throughput

By running specifically optimized local inference, the system achieves near real-time performance, critical for clinical adoption.

- **Token Generation Speed:** The RTX 2070 achieves a generation rate of approximately 40-50 tokens per second (t/s) for the 4B parameter model. This allows for a full clinical summary (approx. 200-300 words) to be generated in under 10 seconds.
- **Retrieval Latency:** Qdrant vector search is sub-millisecond per query. The total time for the "Query Understanding → Embedding → Search" loop is consistently under 200ms.
- **End-to-End Response Time:** The median total latency from user query to final rendered response is 8-12 seconds, falling well within the "usable interaction" threshold for clinical workflows.

5.9.3 Cost & Scalability

The architecture effectively shifts the cost curve of clinical AI.

- **Optimization:** By proving viability on consumer hardware (RTX 20xx series), the system demonstrates that hospitals can deploy on-premise AI nodes without significant infrastructure overhaul. A typical deployment node costs less than \$1,500 in hardware.
- **Scalability Strategy:** The system is designed as a "Pod" architecture. Each compute node can handle a specific ward or patient panel. Scaling to a full hospital simply involves adding more nodes horizontally, rather than scaling up a monolithic central mainframe.

5.10 Limitations & Open Challenges

While the RAG architecture provides a robust grounding mechanism, several frontier challenges in AI infrastructure and clinical reasoning remain. Acknowledging these is essential for maintaining engineering integrity and clinical trust.

5.10.1 Technical Constraints

- **The Lost-in-the-Middle” Phenomenon:** Despite expanding context windows, LLMs often struggle to retrieve information buried in the middle of long patient trajectories (100+ document chunks). This necessitates more advanced *re-ranking* architectures, and better memory management.
- **Retrieval Noise and Domain Shift:** Standard embedding models may suffer from performance degradation when moving between specialties (e.g., from Oncology to Pediatrics) due to the dense use of niche acronyms and shifting semantic definitions, we mitigate this by using medical embedding models.
- **Temporal Reasoning Gaps:** Current RAG systems excel at "point-in-time" retrieval but still struggle with complex causal reasoning over time such as determining if a specific medication *caused* a later adverse event or if it was merely correlated. We try to solve this with Agentic RAG and LLM Multi-Step Reasoning.

5.10.2 Clinical and Operational Hurdles

- **Data Incompleteness (The Silent” Error):** The system can only reason over what is documented. If a patient receives care at an outside facility not integrated into the local vector store, the AI may provide a confident but incomplete summary.

5.11 Value Proposition & Impact

The implementation of a longitudinal, evidence-grounded RAG system offers a paradigm shift in clinical operations, moving beyond mere digitization to intelligent synthesis.

5.11.1 Clinical Efficiency and Burnout Mitigation

- **Enhanced Decision Quality:** Providing semantically relevant, evidence-backed insights at the point of care reduces the risk of diagnostic anchoring and "missed cues" in complex patient histories.

5.11.2 Organizational and Operational Impact

- **Consistency of Care:** Standardizing the summarization and evidence-retrieval process ensures that every patient, regardless of the complexity of their record, receives a thorough and systematic review.
- **Scalable Clinical Operations:** As hospitals face increasing workforce shortages, AI-driven infrastructure allows smaller clinical teams to manage higher-acuity patient panels without a proportional increase in cognitive load or error rates.

Chapter 6

Testing and Verification

6.1 Backend Testing Overview

This section details the automated testing effort for the Node.js backend. The suite is built on Jest with Supertest for HTTP contract checks. Controllers, services, HTTP clients (axios), Redis, and PostgreSQL clients are mocked to isolate behavior where appropriate, while targeted integration tests hit real Redis and Postgres instances when available. Test data favor minimal synthetic fixtures to keep runs deterministic.

6.1.1 Execution Environment

The suite runs on Node.js with Jest and Supertest; axios, Redis, and Postgres clients are typically mocked, while Redis/Postgres integration tests execute when the backing services are reachable via `REDIS_URL_PATIENTS` and `DB_*`. Network calls are isolated in most suites, IDs and payloads are fixed for determinism, and database inserts clean up after themselves.

6.1.2 Scope

Coverage spans HTTP route contracts for patients, encounters, binary resources, and history-graph APIs; service-layer FHIR interactions and caching; Joi-based validation middleware; Redis caching helpers with TTLs; Postgres connectivity and timeline graph persistence; and end-to-end workflows linking patient creation, related-data retrieval, and graph operations.

6.1.3 API Route Coverage

Route tests exercise patient CRUD, TOON export, and related-data bundles; encounter fetch and ‘\$everything’ retrieval with create-by-id; binary PDF fetch/create/delete with required-field validation; and history-graph initialization, head-node creation, CRUD, seeding, and empty-graph handling.

6.1.4 Service and Integration Tests

Patient service specs cover cache-first reads with Redis, FHIR fallbacks, 404 and connectivity errors, create flows (with or without client-specified IDs), and ‘\$everything’ bundles. Condition service specs target patient-scoped queries, empty bundles, and create/update with explicit IDs. History graph service tests remain scaffolded—node/edge CRUD, caching, validation, and FHIR/EOC integration are outlined but still lack concrete assertions.

6.1.5 Test Design and Data

Positive-path cases walk through patient/encounter/condition creation, retrieval, and related-data aggregation, including binary uploads and graph growth. Negative-path cases cover Joi validation failures, cache misses, 404s from FHIR, connection failures, missing IDs, invalid graph categories, and empty bundles. Axios and cache helper calls are stubbed per test to keep contracts deterministic; the graph service uses a mocked pg client. Transient IDs such as `node-001` or `pat-e2e-001` repeat across tests, and Postgres inserts are cleaned up to avoid residue.

6.1.6 End-to-End Workflows

The patient workflow proceeds as `create` → `fetch` → `add condition` → `related-data retrieval`, asserting state consistency. The history-graph workflow initializes an EOC/graph, creates the head node, grows child nodes (with updates and deletes), verifies branching, and exercises cache-aware readbacks, including invalid-category rejection.

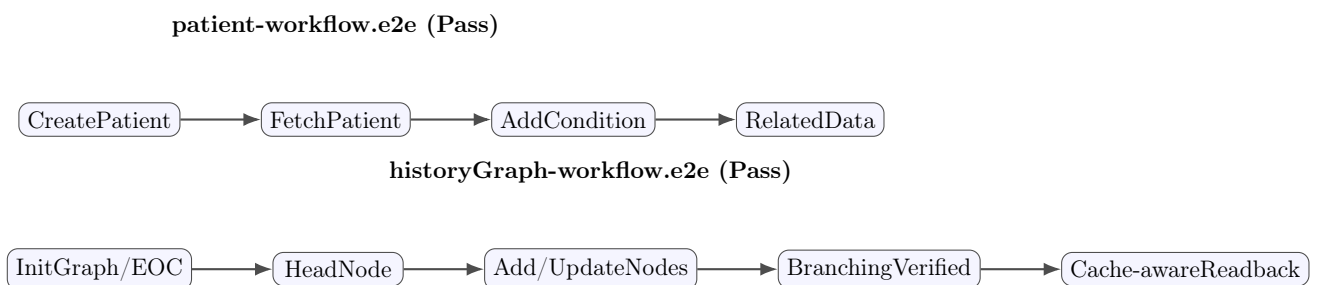


Figure 6.1: Graph view of the two end-to-end suites; edges align to assertions within each test.

6.1.7 Validation and Middleware

Joi schemas enforce required patient fields, formats, and length constraints while permitting extra fields. The request-validator middleware is exercised on both happy-path forwarding and failure-path messaging.

6.1.8 Caching and Redis

Cache helper tests span get/set/delete semantics, TTL handling, error tolerance, and patient cache invalidation (Redis mocked). Redis integration tests, when enabled, hit a live instance to confirm CRUD, TTL expiry, and support for strings, lists, and sets via REDIS_URL_PATIENTS.

6.1.9 Database Checks

Postgres smoke tests confirm connectivity, the presence of `timeline_nodes` and `node_edges`, and insert/select round-trips with cleanup. A standalone probe script inspects timeline nodes and edges to sanity-check graph visualization data.

6.1.10 Gaps and Next Steps

1. Add concrete assertions to history graph service integration tests (node/edge creation, validation, cache invalidation, FHIR/EOC fallbacks).
2. Extend end-to-end negative paths for encounters and conditions, aligning status codes and error bodies.
3. Add contract tests to lock TOON export and ‘\$everything’ bundle payload shapes.
4. Document and script external dependencies (Redis, Postgres, FHIR stubs) for reliable CI execution.

6.1.11 Test Result Summary

Figures 6.2 and 6.3 summarize the principal suites and their last known status.

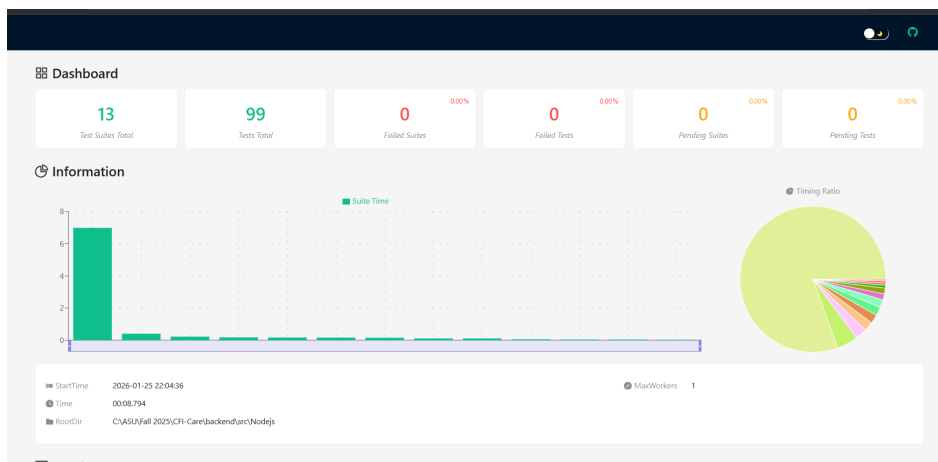


Figure 6.2: Number of Test Cases and its status.

File	ExecTime	Status	Action
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_redis.test.js	00:06.980	All Passed 5	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_v2e\patient-workflow.e2e.test.js	00:00.407	All Passed 2	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphRoutes.test.js	00:00.223	All Passed 10	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_binaryRoutes.test.js	00:00.169	All Passed 5	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientRoutes.test.js	00:00.177	All Passed 6	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_historyGraphService.integration.test.js	00:00.154	All Passed 20	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_encounterRoutes.test.js	00:00.164	All Passed 3	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\historyGraph_tests_v2e\historyGraph-workflow.e2e.test.js	00:00.111	All Passed 4	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_cacheHelper.test.js	00:00.112	All Passed 9	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientService.integration.test.js	00:00.058	All Passed 9	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_patientValidation.test.js	00:00.043	All Passed 7	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_validateRequest.test.js	00:00.041	All Passed 3	
C:\ASU\Fall 2025\CFI-Care\backend\src\nodejs\models_tests_conditionService.integration.test.js	00:00.029	All Passed 4	

About Feedback

Version 3.1.7

Figure 6.3: Unit, integration and End-to-end workflow suite status.

6.1.12 Interpretation of Results

- Core HTTP surface for patients, encounters, binaries, and history graph is green, indicating stable contracts at the controller/route layer.
- Service-layer caching and FHIR interaction paths are exercised with both cache hits and misses; error handling for 404 and connectivity is verified.
- Live-environment checks for Redis/Postgres pass when backing services are reachable; mark these as conditional (Pass*).
- The main gap is the history graph service integration file, which outlines scenarios but lacks assertions; adding those will close coverage on graph business logic.

6.2 Mobile App Testing

6.2.1 Unit Testing

Unit testing is the process of verifying the correctness of a single function, method, or class in isolation. It is considered the foundation of the testing pyramid. The primary goal is to ensure that the business logic and algorithms function as expected under a variety of conditions without any interaction with the User Interface (UI) or external dependencies such as databases or web servers [74].

As described by Torres [75], unit tests help ensure that specific pieces of logic produce the expected output given a particular input. These tests are characterized by their execution speed and low maintenance cost. In Flutter, unit tests typically utilize the `test` package to define expectations and assertions for Dart classes.

6.2.2 Widget Testing

Widget testing, often referred to as component testing in other frameworks, sits between unit and integration testing. A widget test verifies the behavior of a single widget or a small group of widgets [76].

According to Bharti [77], the objective of widget testing is to ensure UI reliability and quality by asserting that the widget's visual layout is rendered correctly and that it responds appropriately to user interactions, such as button taps or text entry.

Unlike unit tests, widget tests require a simulated environment. The Flutter framework provides the `WidgetTester` utility, which allows developers to build and interact with widgets in a test environment that is significantly faster than a full UI system but complex enough to render the widget tree [76].

6.2.3 Integration Testing

Integration testing involves testing the application as a complete system. This methodology validates that all individual components—including the UI, business logic, and external services—work together correctly [75].

These tests simulate a real user's journey through the application, such as logging in, navigating through screens, and performing data updates. Because integration tests typically run on real devices or emulators to capture accurate performance data and visual rendering, they are generally slower and more resource-intensive than unit or widget tests.

6.2.4 Testing Architecture and Tools

We utilized the following standard Flutter testing libraries:

- **flutter_test**: The core framework used to write and run assertions.[78]
- **mockito**: Used to simulate external dependencies. Since our ViewModels depend on Repositories and Plugins, we created "Mock" objects to return controlled dummy data during tests.[79]
- **build_runner**: Used to automatically generate the Mock classes using the `@GenerateMocks` annotation, ensuring our test mocks stay up-to-date with our actual interfaces.[80]
- **WidgetTester**: Provided by the `flutter_test` package, this allows us to build and interact with widgets in a test environment without running the full app on an emulator.[81]
- **network_image_mock**: Since widget tests run in a restrictive environment without real internet access, standard `Image.network` widgets would fail. We used this package to wrap our tests and mock successful image loads.[82, 83]
- **Provider Injection**: Many of our widgets rely on `ChangeNotifierProvider`. In tests, we injected "Mock Providers" (created with Mockito) to supply controlled data and verify that buttons trigger the correct business logic.[82]

6.2.5 Unit Testing Implementation

To ensure the reliability of the application's business logic and maintain a stable codebase, we implemented a comprehensive Unit Testing strategy. This strategy focused on verifying the behavior of our **ViewModels** in isolation from the UI and external dependencies (such as the backend API or local device storage).

Booking Logic (BookingProvider)

The booking process involves complex state management where selecting a doctor resets previously selected dates to prevent invalid slots.

- **Scenario Tested:** We verified that selecting a new doctor automatically clears the `selectedDate` and `selectedTime` to enforce valid scheduling.
- **Optimistic Updates:** We tested the `confirmBooking` method to ensure that once the repository returns success, the local appointment list updates immediately without requiring a full page refresh.

```
// Code Snippet: Verifying Booking Reset Logic (booking_provider_test.dart)
test('Selecting a doctor should reset Date and Time', () {
  // Arrange: Set a date first
  provider.setTimeSlot(DateTime(2026, 1, 1), '10:00 AM');

  // Act: Select a new doctor
  provider.selectDoctor(createDummyDoctor());

  // Assert: Doctor is set, but time/date are wiped (null)
  expect(provider.selectedDoctor, isNotNull);
  expect(provider.selectedDate, null);
  expect(provider.selectedTime, null);
});
```

Document Uploads (DocumentAddViewModel)

This module interacts with native platform channels (File Picker, Image Picker). Testing it requires intercepting these platform calls.

- **Validation Logic:** We verified that the `isValid` getter returns `false` unless both a "Title" and a "File" are present, preventing users from submitting incomplete forms.
- **Platform Mocking:** Since Unit Tests run on a computer (not a phone), calls to `getApplicationDocumentsDirectory` would normally crash. We used `MethodChannel` mocking to intercept these calls and return a temporary directory on the test machine.

Medical History Timeline (MajorEventProvider)

This provider handles fetching the patient's "Major Events" and their sub-nodes.

- **State Management:** We tested the `fetchEvents` method to ensure the `isLoading` boolean correctly toggles to `true` when the call starts and `false` when data is received.
- **Data Clearing:** We verified that fetching details for a new event correctly clears the old data from the previous event to prevent showing stale information.

```
// Code Snippet: Mocking Repository Responses (major_event_provider_test.dart)
test('fetchEvents success updates list and loading state', () async {
  // Arrange: Stub the repo to return a dummy list immediately
  when(mockRepo.getMajorEvents())
    .thenAnswer((_) async => [createDummyEvent()]);

  // Act: Trigger the fetch
  final future = provider.fetchEvents();

  // Assert: Loading should be true while fetching
  expect(provider.isLoadingEvents, true);

  await future;

  // Assert: Data is populated and loading is false
  expect(provider.events.length, 1);
  expect(provider.isLoadingEvents, false);
});
```

Test Coverage Results

By isolating the ViewModels and mocking the repositories, we achieved high test coverage for the application's core logic. This approach allowed us to:

1. **Identify Edge Cases:** We caught issues where invalid form submissions were possible before implementing the validation checks.
2. **Refactor Safely:** We could optimize the `BookingProvider` logic with confidence, knowing the tests would fail if we broke the "reset date" functionality.
3. **Improve Efficiency:** Running these unit tests takes less than 2 seconds, compared to manual testing which would require navigating through the entire app.

Chapter 7

Conclusion and Future Work

7.1 Conclusion

This thesis presented CFI-Care, a patient-centric healthcare platform that addresses three critical gaps in current digital health systems. The implemented system successfully consolidates fragmented medical records into a unified platform. The HAPI FHIR server, backed by PostgreSQL, provides standards-compliant storage for clinical resources (Patient, Encounter, Practitioner, etc.), enabling cross-institutional data exchange. The Node.js layer translates FHIR resources into application-specific formats while enforcing business logic and security policies. The Angular frontend delivers an interactive interface for doctors to manage health data and review patient histories.

7.2 Future Work

7.2.1 System Security

Architecture Hardening and Lifecycle Maturity The current implementation provides a robust baseline for secure health data exchange. Meanwhile, future iterations will focus on advancing this prototype toward enterprise-grade maturity:

- **Transition to Hardware-Backed Key Orchestration:** While the current LUKS-based storage encryption provides comprehensive at-rest protection, the next phase will integrate an external Key Management Service (KMS) or Hardware Security Module (HSM), which will decouple cryptographic key material from the host file system, enabling programmatic key rotation, tamper-evident audit logging, and ephemeral secret injection.
- **Automated Infrastructure Hardening (IaC):** Move from manual container management to Infrastructure-as-Code (IaC) via hardened Kubernetes (K8s) manifests, to enable the enforcement of *Pod Security Admissions* and ensure least-privilege runtime enforcement.

- **Identity Provider Federation and mTLS:** Scale the identity architecture by transitioning from standard OIDC/OIDC-proxy patterns to mTLS (Mutual TLS) service-to-service authentication; requiring certificate-based validation for all internal API traffic should eliminate the reliance on network-level isolation, establishing a true Zero-Trust architecture.
- **Production Lifecycle Orchestration:** Migrate the current static TLS configuration to automated lifecycle management (using the Let's Encrypt providers) integrated directly into the ingress gateway ensuring consistent, zero-touch certificate rotation across production environments , eliminating manual maintenance and preventing expiry-related downtime.

7.2.2 Mobile

Push Notifications

To enhance user engagement and ensure immediate response to critical events (e.g., doctor access requests), we plan to implement a robust Push Notification system. This architecture relies on **Firebase Cloud Messaging (FCM)** as the delivery intermediary.

Technical Implementation The proposed workflow consists of two distinct phases: Token Registration and Message Delivery.

- **Token Generation (Frontend):** Upon logging in, the Flutter application utilizes the `firebase_messaging` [65] package to generate a unique Registration Token for the device. This token acts as the specific address for the user's phone.
- **Token Registration (Backend):** The mobile application transmits this token via a secure API endpoint (e.g., `POST /user/fcm-token`) to our Node.js backend. The backend associates this token with the User ID and stores it in the database.
- **Notification Triggering:** When a business event occurs (e.g., a doctor requests access), the Node.js backend retrieves the target user's stored FCM token. It then utilizes the `firebase-admin` SDK to dispatch the payload to the FCM servers, which subsequently route the notification to the user's device, even if the application is in the background.[66]

Wearable Data Integration

To transition from a system of historical records to a platform for active health monitoring, we propose integrating **Android Health Connect**. This allows the application to ingest vital signs collected by smartwatches and fitness trackers.

Objective: Remote Patient Monitoring (RPM)

The goal is to automatically populate the "My Vitals" dashboard without manual entry. By syncing with devices (e.g., Samsung Galaxy Watch, Google Pixel Watch), the system can track:

- **Heart Rate & Variability (HRV):** To detect potential cardiac anomalies early.
- **Activity Levels (Steps):** To monitor recovery progress after surgery.
- **Sleep Quality:** To assess overall patient well-being.

Health Connect

The Health Connect app is responsible for handling all the requests that your application sends through the Health Connect SDK. These requests include storing data and managing its read and write access. [71]

1. **Data Aggregation:** Smartwatches sync their raw sensor data to the Health Connect app on the patient's Android phone.
2. **Privacy-First Access:** Our Flutter application requests specific granular permissions (e.g., `READ_HEART_RATE`) from Health Connect.
3. **Background Synchronization:** A background worker in the Flutter app periodically fetches new data points and transmits them to our Node.js backend.
4. **Anomaly Detection:** The backend analyzes these trends and triggers an alert notification to the doctor if vitals exceed safety thresholds.

Appendix

Appendix A

Lists

List of Abbreviations

API	Application Programming Interface
FHIR	Fast Healthcare Interoperability Resources
OAuth	Open Authorization
JWT	JSON Web Token
HIPAA	Health Insurance Portability and Accountability Act
SMART	Substitutable Medical Applications and Reusable Technology
EHR	Electronic Health Record
JIT	Just in Time
OIDC	OpenID Connect
PHI	Protected Health Information
CSRF	Cross-Site Request Forgery
XSS	Cross-Site Scripting
CSP	Content-Security-Policy
HSTS	HTTP Strict-Transport-Security
FCM	Firebase Cloud Messaging
TOCTOU	Time-of-Check to Time-of-Use
OTP	One-Time Password
PII	Personally identifiable information

MITM	Man in the Middle
CBAC	Capability-Based Access Control
RBAC	Role-Based Access Control
BFF	Backend for Frontend
CORS	Cross-Origin Resource Sharing
PKCE	Proof Key for Code Exchange
DoS	Denial of Service

References

- [1] Grand View Research, *Digital Health Market Size, Share & Trends Analysis Report By Technology, By Component, By Region, And Segment Forecasts, 2025 - 2030*, <https://www.grandviewresearch.com/industry-analysis/digital-health-market>, Accessed: 2025-04-04.
- [2] Intellisoft, *FHIR vs. HL7: Core Differences & Standards Comparison*, <https://intellisoft.io/comparing-hl7-vs-fhir-core-differences/>, Accessed: 2025-04-04.
- [3] University of Porto Repository, *Interoperability in Healthcare Systems (Thesis/Dissertation)*, <https://repositorio-aberto.up.pt/bitstream/10216/164181/2/700384.pdf>, Accessed: 2025-04-04.
- [4] Wikipedia, *Fast Healthcare Interoperability Resources*, https://en.wikipedia.org/wiki/Fast_Healthcare_Interoperability_Resources, Accessed: 2025-04-04.
- [5] HL7 International, *FHIR HL7 Documentation*, <https://www.hl7.org/fhir/>, Accessed: 2025-04-04.
- [6] HL7 International, *FHIR R4 Consent Resource*, <https://www.hl7.org/fhir/consent.html>, Accessed: 2025-11-04.
- [7] HL7 SMART on FHIR Community, *SMART App Launch Framework: Secure, Standardized, Data-Driven Application Architecture for Biomedicine*, <http://www.hl7.org/fhir/smart-app-launch/>, Accessed: 2025-09-15.
- [8] OpenID Foundation, *OpenID Connect Core 1.0*, https://openid.net/specs/openid-connect-core-1_0.html, Accessed: 2025-08-28.
- [9] D. Hardt (Editor), *The OAuth 2.0 Authorization Framework*, RFC 6749, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6749>, Accessed: 2025-08-28.
- [10] B. Jones and D. Hardt (Editors), *The OAuth 2.0 Bearer Token Usage*, RFC 6750, Internet Engineering Task Force (IETF), October 2012, <https://tools.ietf.org/html/rfc6750>, Accessed: 2025-01-15.
- [11] M. Jones, J. Bradley, and N. Sakimura, *JSON Web Token (JWT)*, RFC 7519, Internet Engineering Task Force (IETF), May 2015, <https://tools.ietf.org/html/rfc7519>, Accessed: 2025-08-28.

- [12] O. Steele and A. Parecki (Editors), *OAuth 2.0 Security Best Current Practice*, RFC 9700, Internet Engineering Task Force (IETF), October 2024, <https://tools.ietf.org/html/rfc9700>, Accessed: 2025-11-04.
- [13] M. Bertocci, *OAuth 2.0 Token Mediator Pattern for Web API Authorization*, Internet-Draft draft-bertocci-oauth2-tmi-bff-01, IETF, 2023, <https://tools.ietf.org/html/draft-bertocci-oauth2-tmi-bff-01>, Accessed: 2025-01-14.
- [14] S. Bingler, Ed. *HTTP State Management Mechanism*, RFC 6265, Internet Engineering Task Force (IETF), April 2011, <https://tools.ietf.org/html/rfc6265>, Accessed: 2025-08-30.
- [15] N. Sakimura, J. Bradley, and N. Agarwal, *Proof Key for Public OAuth 2.0 Authorization Code Flow (PKCE)*, RFC 7636, Internet Engineering Task Force (IETF), September 2015, <https://tools.ietf.org/html/rfc7636>, Accessed: 2025-09-30.
- [16] D. Recordon (Editor) and D. Hardt (Editor), *OAuth 2.0 Threat Model and Security Considerations*, RFC 6819, Internet Engineering Task Force (IETF), January 2013, <https://tools.ietf.org/html/rfc6819>, Accessed: 2025-11-04.
- [17] OWASP Foundation, *OWASP Top 10 - 2021: The Ten Most Critical Web Application Security Risks*, <https://owasp.org/Top10/2021/>, Accessed: 2025-09-30.
- [18] OWASP Foundation, *OWASP API Security Top 10*, <https://owasp.org/www-project-api-security/>, Accessed: 2025-11-02.
- [19] Keycloak Community, *Keycloak Documentation: Open Source Identity and Access Management*, <https://www.keycloak.org/documentation.html>, Accessed: 2025-08-20.
- [20] Keycloak, *Keycloak Server Administration Guide and Reference*, https://www.keycloak.org/docs/latest/server_admin/, Accessed: 2025-08-20.
- [21] Adam Baldwin and Contributors, *Helmet: Secure Express Apps by Setting Various HTTP Headers*, <https://helmetjs.github.io/>, Accessed: 2025-01-15.
- [22] OWASP Foundation, *Cross-Site Scripting (XSS) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html, Accessed: 2025-09-30.
- [23] OWASP Foundation, *Cross-Site Request Forgery (CSRF) Prevention Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html, Accessed: 2025-09-29.
- [24] NGINX Inc., *NGINX Documentation*, <https://nginx.org/en/docs/>, Accessed: 2025-10-04.
- [25] Olivier Poitrey, *rate-limit-redis: Redis-backed Rate Limiting Middleware for Express*, <https://www.npmjs.com/package/rate-limit-redis>, Accessed: 2025-01-15.

- [26] hapi Framework Community, *Joi: Object Schema Validation*, <https://joi.dev/>, Accessed: 2025-01-15.
- [27] OWASP Foundation, *Logging Cheat Sheet*, https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html, Accessed: 2025-10-04.
- [28] U.S. Department of Health and Human Services, *HIPAA Security Rule*, <https://www.hhs.gov/hipaa/for-professionals/security/index.html>, Accessed: 2025-08-23.
- [29] European Parliament and Council, *General Data Protection Regulation (GDPR)*, Regulation (EU) 2016/679, 2016, <https://gdpr.eu/>, Accessed: 2025-08-23.
- [30] European Parliament and Council, *General Data Protection Regulation (GDPR)*, Regulation (EU) 2016/679, 2016, <https://gdpr.eu/>, Accessed: 2025-08-23.
- [31] Art Future, *OAuth 2.0 Authentication with Keycloak in Flutter Applications*, <https://medium.com/@art.futurx/oauth-2-0-authentication-with-keycloak-in-flutter-applications-35d588b2246d>, Accessed: 2025-12-04.
- [32] D. Denniss, C. Dodson, and W. Mills, *OAuth 2.0 for Native Apps*, RFC 8252, Internet Engineering Task Force (IETF), October 2017, <https://www.rfc-editor.org/rfc/rfc8252#section-8.12>, Accessed: 2025-12-04.
- [33] OWASP Foundation, *OWASP Mobile Top 10*, <https://owasp.org/www-project-mobile-top-10/>, Accessed: 2025-08-23.
- [34] OWASP Foundation, *OWASP Mobile Application Security (MAS)*, <https://mas.owasp.org/>, Accessed: 2025-08-23.
<https://developer.android.com/privacy-and-security/keystore>
- [35] Google, *Android Keystore System*, <https://developer.android.com/privacy-and-security/keystore>, Accessed: 2025-01-14.
- [36] Auth0, *The Backend-for-Frontend Pattern*, <https://auth0.com/blog/the-backend-for-frontend-pattern-bff/>, Accessed: 2025-12-04.
- [37] Sam Newman, *Backend-for-Frontend Architecture Pattern*, <https://samnewman.io/patterns/architectural/bff/>, Accessed: 2025-12-04.
- [38] Keycloak, *Keycloak Securing Applications and Services Guide*, <https://www.keycloak.org/guides.html#securing-apps>, Accessed: 2025-09-10.
- [39] Keycloak, *Keycloak REST API Documentation*, <https://www.keycloak.org/docs-api/latest/rest-api/index.html>, Accessed: 2025-09-10.
- [40] Keycloak, *Keycloak Authorization Services Guide*, https://www.keycloak.org/docs/latest/authorization_services/index.html, Accessed: 2025-09-10.
- [41] Keycloak, *Keycloak Server in Containers*, <https://www.keycloak.org/server/containers>, Accessed: 2025-09-10.

- [42] Keycloak Documentation, *Administering Sessions in Keycloak*, https://wjl465150.gitbooks.io/keycloak-documentation/content/server_admin/topics/sessions/administering.html, Accessed: 2025-01-14.
- [43] Flutter Team, *Flutter App Architecture*, <https://docs.flutter.dev/app-architecture>, Accessed: January 2026.
- [44] Yamen Abdallah, *Clean Architecture in Flutter: MVVM, BLoC, Dio*, <https://medium.com/@yamen.abd98/clean-architecture-in-flutter-mvvm-bloc-dio-79b1615530e1>, Accessed: January 2026.
- [45] Shalu, *Why You Should Use Riverpod in Flutter — The Future of State Management*, <https://medium.com/@shalu023/why-you-should-use-riverpod-in-flutter-the-future-of-state-management-e064efafeb9e>, Medium article, October 2025.
- [46] Atuoha Anthony, *How to Handle Permissions in Flutter: A Comprehensive Guide*, freeCodeCamp.org, <https://www.freecodecamp.org/news/how-to-handle-permissions-in-flutter-for-beginners/>, August 2025.
- [47] Rizk, Ahmed and El-Sayed, Mona, *Digital Transformation and Data Fragmentation in Egyptian Healthcare*, Journal of Health Informatics in Developing Countries, Vol. 19, No. 2, pp. 45–59, 2025.
- [48] Angular Team, *Angular Documentation*, <https://angular.io/docs>, Accessed: January 2026.
- [49] Parnas, D. L., *On the Criteria to be Used in Decomposing Systems into Modules*, Communications of the ACM, Vol. 15, No. 12, pp. 1053–1058, 1972.
- [50] Fowler, Martin, *Patterns of Enterprise Application Architecture*, Addison-Wesley, 2003.
- [51] Bass, Len and Weber, Ingo and Zhu, Liming, *DevOps: A Software Architect's Perspective*, Addison-Wesley, 2012.
- [52] Richards, Mark, *Software Architecture Patterns*, O'Reilly Media, 2020.
- [53] Ware, Colin, *Information Visualization: Perception for Design*, Morgan Kaufmann, 3rd Edition, 2013.
- [54] Healey, Christopher G., *Perception in Visualization*, <https://www.csc2.ncsu.edu/faculty/healey/PP/>, 2012.
- [55] Shneiderman, Ben and Plaisant, Catherine, *Designing the User Interface: Strategies for Effective Human-Computer Interaction*, Pearson, 6th Edition, 2016.
- [56] Zhang, Ping, *The Affective Response to Web Sites*, Behaviour and Information Technology, Vol. 29, No. 4, pp. 372–390, 2010.
- [57] Nielsen, Jakob, *Usability Engineering*, Morgan Kaufmann, 1994.

- [58] Budiu, Raluca, *Mobile Usability*, Nielsen Norman Group, 2017.
- [59] Baldonado, Michelle and Woodruff, Allison and Kuchinsky, Allan, *Guidelines for Using Multiple Views in Information Visualization*, Proceedings of the Working Conference on Advanced Visual Interfaces, pp. 110–119, 2000.
- [60] Keim, Daniel A., *Mastering the Information Age*, Solving Problems with Visual Analytics, 2008.
- [61] International Electrotechnical Commission, *Medical Devices - Part 1: Guidance on Usability*, IEC 62366:2015, 2015.
- [62] Plaisant, Catherine and Shneiderman, Ben and Mushlin, Robert, *An Information Architecture to Support the Visualization of Personal Medical History*, AMIA Annual Fall Symposium, pp. 181–185, 1996.
- [63] Rind, Alexander and Wang, T. D. and Aigner, W. and Miksch, S. and Wongsuphasawat, K. and Plaisant, C. and Shneiderman, B., *Interactive Information Visualization to Explore and Query Data*, Interactive Data Visualization, pp. 123–165, 2013.
- [64] NgRx Team, *NgRx Documentation*, <https://ngrx.io/docs>, 2018.
- [65] Google, *Firebase Cloud Messaging for Flutter*, https://pub.dev/packages/firebase_messaging, Accessed: January 2026.
- [66] Ashan, S., *Push Notifications in Flutter Mobile Applications*, Medium, 2024.
- [67] Apple, *Finding Health Data Your App Can Access*, <https://developer.apple.com/documentation/healthkit>, Accessed: January 2026.
- [68] Apple, *Viewing Records by Record Type*, <https://developer.apple.com/documentation/healthkit>, Accessed: January 2026.
- [69] Apple, *Sharing Health Data Between Users*, <https://developer.apple.com/documentation/healthkit>, Accessed: January 2026.
- [70] Google Play Store, *Lumi App - Health and Wellness*, <https://play.google.com/store>, Accessed: January 2026.
- [71] Google, *Android Health Connect Documentation*, <https://developer.android.com/health-and-fitness/guides/health-connect>, Accessed: January 2026.
- [72] Daydreamsoft, *Permission Handler for Flutter*, https://pub.dev/packages/permission_handler, 2025.
- [73] Boudanes, Mohamed, *Flutter Permissions Guide*, Medium, 2024.
- [74] Flutter Team, *An introduction to unit testing*, <https://docs.flutter.dev/testing/unit-testing>, Accessed: January 2026.
- [75] Torres, J., *Testing in Flutter Applications*, Medium, 2024.

- [76] Flutter Team, *An introduction to widget testing*, <https://docs.flutter.dev/testing/widget-testing>, Accessed: January 2026.
- [77] Bharti, Priyanka, *Widget Testing Best Practices in Flutter*, Medium, 2024.
- [78] Flutter Team, *Testing Flutter Apps*, <https://docs.flutter.dev/testing>, Accessed: January 2026.
- [79] Mockito Contributors, *Mockito Dart Package*, <https://pub.dev/packages/mockito>, Accessed: January 2026.
- [80] Dart Team, *build_runner Package*, https://pub.dev/packages/build_runner, Accessed: January 2026.
- [81] Flutter Team, *WidgetTester Documentation*, <https://api.flutter.dev/flutter/r/widgettest/WidgetTester-class.html>, Accessed: January 2026.
- [82] Tigerasks, *Provider Package for State Management*, <https://pub.dev/packages/provider>, 2024.
- [83] Network Image Mock Contributors, *Mock Network Images for Testing*, https://pub.dev/packages/network_image_mock, Accessed: January 2026.
- [84] MedGemma Technical Report, *MedGemma Technical Report*, <https://arxiv.org/abs/2507.05201>, Accessed: January 2026.
- [85] lokeshch19/ModernPubMedBERT, *Hugging Face Model Hub*, <https://huggingface.co/lokeshch19/ModernPubMedBERT>, Accessed: January 2026.
- [86] TOON Format Specification, *toonformat.dev Reference*, <https://toonformat.dev/reference/spec.html>, Accessed: January 2026.
- [87] Model Context Protocol (MCP) *arXiv:2503.23278 [cs.CR]*, <https://arxiv.org/abs/2503.23278>, Accessed: January 2026.
- [88] Buttigieg, S. C. and others, “Requirements and challenges of hospital dashboards: a systematic literature review,” *BMC Medical Informatics and Decision Making*, 2022, <https://doi.org/10.1186/s12911-022-02037-8>, Accessed: January 2026.
- [89] Authors, T. and others, “Usability Testing of an Interactive Dashboard for Surgical Quality Improvement in a Large Congenital Heart Center,” *Interactive Journal / PubMed*, 2020, <https://pubmed.ncbi.nlm.nih.gov/31724143/>, Accessed: January 2026.
- [90] Authors, A. and others, “Dashboards for visual display of patient safety data: a systematic review,” *Journal of Safety Informatics*, 2021, <https://pubmed.ncbi.nlm.nih.gov/34615664/>, Accessed: January 2026.
- [91] Bischof, Anja Yvonne and others, “A Collection of Components to Design Clinical Dashboards Incorporating Patient-Reported Outcome Measures: Qualitative Study,” *Journal of Medical Internet Research*, 2024, Accessed: January 2026.

- [92] Kothapalli, Mounika, “The Evolution of Component-Based Architecture in Front-End Development,” *Journal of Scientific and Engineering Research*, 2021, Accessed: January 2026.
- [93] Samsung, *Samsung Health*, <https://www.samsung.com/us/support/owners/app/samsung-health>, Accessed: 2026-06-03.
- [94] Bui, Michael and Contributors, *flutter_appauth: Flutter AppAuth Plugin*, https://pub.dev/packages/flutter_appauth, Flutter package providing an abstraction over the Android and iOS AppAuth SDKs for OAuth 2.0 and OpenID Connect, Accessed: 2026-06-02.
- [95] Steenbakker, Julian and Contributors, *flutter_secure_storage: Secure Storage Plugin for Flutter*, https://pub.dev/packages/flutter_secure_storage, Flutter plugin for securely storing sensitive data using platform-specific secure storage mechanisms, Accessed: 2026-06-02.
- [96] Flutter Team, *GoRouter Class - go_router Library*, https://pub.dev/documentation/go_router/latest/go_router/GoRouter-class.html, Official API documentation for the GoRouter class, Accessed: 2026-06-02.
- [97] Flutter Team, *Dismissible Class - widgets Library*, <https://api.flutter.dev/flutter/widgets/Dismissible-class.html>, Official Flutter API documentation for the Dismissible widget, Accessed: 2026-06-02.
- [98] BuildtoApp and Contributors, *open_filex: Flutter Plugin for Opening Files with Native Applications*, https://pub.dev/packages/open_filex, Accessed: 2026-06-02.
- [99] Flutter Team, *image_picker: Flutter Plugin for Image and Video Selection*, https://pub.dev/packages/image_picker, Accessed: 2026-06-02.
- [100] Flutter Community, *sensors_plus: Flutter Plugin for Device Sensor Access*, https://pub.dev/packages/sensors_plus, Accessed: 2026-06-02.